



POLITECHNIKA
LUBELSKA
WYDZIAŁ MATEMATYKI
I INFORMATYKI TECHNICZNEJ

Katedra Informatyki Technicznej

Praca dyplomowa magisterska

na kierunku *Edukacja Techniczno-Informatyczna*

Zastosowanie macierzy MITRE ATT&CK w modelowaniu i
ocenie efektywności strategii obronnych wobec technik
ataków cybernetycznych

Application of the MITRE ATT&CK Matrix in Modeling and
Assessing the Effectiveness of Defense Strategies Against
Cyber Attack Techniques

Krystian Łęcki

96910

promotor: dr inż. Joanna Szulżyk-Cieplak

promotor pomocniczy: mgr inż. Jacek Zaburko

Lublin 2025

Spis treści

Wykaz skrótów	4
Wstęp	6
Cel i zakres pracy	7
1. Zagrożenia i mechanizmy obrony w cyberprzestrzeni	8
1.1 Rodzaje cyberzagrożeń	9
1.1.1 Malware - złośliwe oprogramowanie	9
1.1.2 Inżynieria społeczna i phishing	13
1.1.3 Ataki DoS i DDoS	14
1.1.4 Atak typu Man-in-the-Middle (MITM)	16
1.1.5 Atak typu Injection	16
1.1.6 Ataki na hasło	16
1.1.7 Ataki typu Zero-day	17
1.2 Systemy i metody organizacji obrony w cyberbezpieczeństwie	17
1.2.1 Istniejące strategie obronne	18
1.2.2 Frameworki cyberbezpieczeństwa	26
1.2.3 Standardy i regulacje w obszarze cyberbezpieczeństwa	29
2 Charakterystyka macierzy MITRE ATT&CK	36
2.1 Rodzaje macierzy ATT&CK	36
2.2 Kluczowe elementy macierzy ATT&CK	37
2.3 Technik ataków opisane w MITRE ATT&CK	38
2.4 Taktyki w macierzy MITRE ATT&CK	54
3 Metodyka badań	58
3.1 Cel i zakres badań	58
3.2 Metody i techniki badawcze	59
3.3 Narzędzia badawcze i środowisko testowe	60
3.4 Etapy realizacji badań	61
4 Opracowanie scenariuszy ataku na podstawie MITRE ATT&CK	63
4.1 Analiza wybranych ataków	63
4.1.1 Kryteria wyboru ataków	64
4.1.2 Opis wybranych ataków	64
4.2 Scenariusze ataku	66
4.2.1 Scenariusz A - Skanowanie portów (T1046)	67

4.2.2	Scenariusz B - Wykorzystanie skryptu PowerShell do pobrania i uruchomienia pliku wykonywalnego (T1059.001)	68
4.2.3	Scenariusz C - Wstrzykiwanie kodu do procesu (T1055)	69
4.2.4	Scenariusz D - Dumping pamięci LSASS (T1003.001).....	70
5	Symulacje cyberataków i analiza ich przebiegu.....	72
5.1	Przygotowanie maszyny wirtualnej.....	72
5.2	Scenariusz A (skanowanie portów)	74
5.3	Scenariusz B (Wykorzystanie skryptu PowerShell do pobrania i uruchomienia pliku wykonywalnego).....	80
5.4	Scenariusz C (Wstrzyknięcie kodu do procesu)	87
5.5	Scenariusz D (Dumping pamięci LSASS)	93
	Podsumowanie i wnioski	101
	Spis rysunków.....	108
	Spis tabel.....	109
	Streszczenie	110
	Summary	111

Wykaz skrótów

API - *Application Programming Interface* - interfejs programistyczny umożliwiający komunikację pomiędzy aplikacjami

ASR - *Attack Surface Reduction* - zestaw reguł ograniczających powierzchnię ataku w systemach operacyjnych

CAR - *Cyber Analytics Repository* - zbiór reguł detekcji opracowanych przez MITRE, służących do identyfikacji technik ataku

CLI - *Command Line Interface* - interfejs wiersza poleceń umożliwiający bezpośrednie wydawanie poleceń systemowi

COM - *Component Object Model* - technologia Microsoft umożliwiająca komunikację pomiędzy komponentami oprogramowania

DDoS - *Distributed Denial of Service* - rozproszony atak typu odmowa usługi, powodujący przeciążenie zasobów systemu

DID - *Defence in Depth* - strategia wielowarstwowej ochrony systemów informatycznych

DLP - *Data Loss Prevention* - system zapobiegający utracie lub nieautoryzowanemu ujawnieniu danych

DoS - *Denial of Service* - atak powodujący niedostępność usługi poprzez przeciążenie jej zasobów

DLL - *Dynamic Link Library* - biblioteka współdzielona zawierająca kod i dane wykorzystywane przez aplikacje systemu Windows

EDR - *Endpoint Detection and Response* - system monitorujący, wykrywający i reagujący na zagrożenia na punktach końcowych

ICS - *Industrial Control Systems* - systemy sterowania przemysłowego

IDPS - *Intrusion Detection and Prevention System* - system wykrywania i zapobiegania włamaniom

IAM - *Identity and Access Management* - system zarządzania tożsamością i kontrolą dostępu użytkowników

iOS - system operacyjny Apple stosowany w urządzeniach mobilnych

IoC - *Indicator of Compromise* - wskaźnik kompromitacji, czyli artefakt świadczący o możliwym naruszeniu bezpieczeństwa

IPS - *Intrusion Prevention System* - system zapobiegania włamaniom

IOD - *Inspektor Ochrony Danych* - osoba odpowiedzialna za nadzór nad przestrzeganiem przepisów o ochronie danych osobowych

MFA - *Multi-Factor Authentication* - uwierzytelnianie wieloskładnikowe

MitM - *Man-in-the-Middle* - atak polegający na przechwytywaniu i modyfikowaniu komunikacji między dwiema stronami

RDP - *Remote Desktop Protocol* - protokół zdalnego pulpitu opracowany przez firmę Microsoft

SMB - *Server Message Block* - protokół sieciowy umożliwiający współdzielenie plików

i drukarek w sieci

SIEM - *Security Information and Event Management* - system do gromadzenia i analizy logów bezpieczeństwa

SOAR - *Security Orchestration, Automation and Response* - system automatyzujący reakcję na incydenty bezpieczeństwa

SOC - *Security Operations Center* - centrum operacji bezpieczeństwa monitorujące i reagujące na incydenty

SSH - *Secure Shell* - protokół umożliwiający bezpieczne zdalne logowanie i zarządzanie systemem

SZBI - *System Zarządzania Bezpieczeństwem Informacji* - system zgodny z normą ISO/IEC 27001

SYN - *Synchronize* - flaga używana w procesie nawiązywania połączenia w protokole TCP

TCP - *Transmission Control Protocol* - protokół transportowy zapewniający niezawodną transmisję danych

VNC - *Virtual Network Computing* - technologia zdalnego sterowania komputerem

WMI - *Windows Management Instrumentation* - interfejs zarządzania i monitorowania komponentów systemu Windows

XDR - *Extended Detection and Response* - rozszerzony system detekcji i reakcji na zagrożenia

AI - *Artificial Intelligence* - sztuczna inteligencja

XSS - *Cross-Site Scripting* - atak polegający na wstrzyknięciu złośliwego kodu do strony internetowej.

CIS - *Center for Internet Security* - organizacja opracowująca wytyczne i standardy bezpieczeństwa systemów informatycznych

OT - *Operational Technology* - technologia operacyjna obejmująca systemy sterujące procesami przemysłowym

Wstęp

W dzisiejszych czasach, biorąc pod uwagę liczbę użytkowników Internetu, a także coraz częstsze wykorzystanie rozwiązań teleinformatycznych w administracji publicznej, mamy do czynienia z nasilaniem się cyberzagrożeń, które przybierają formę cyberprzestępczości, cyberterroryzmu czy incydentów sieciowych. Utrata cennych danych prowadzi do negatywnych konsekwencji zarówno dla osób prywatnych, jak i organizacji. Cyberbezpieczeństwo to proces ochrony wrażliwych danych przed uszkodzeniem lub kradzieżą.

Postępująca cyfryzacja i rozwój wzajemnie powiązanych infrastruktur teleinformatycznych przyczyniły się do istotnego wzrostu znaczenia modelowania zarówno istniejących, jak i nowych zagrożeń cybernetycznych we współczesnym świecie. Aby sprostać temu wyzwaniu, jednym z głównych rozwiązań jest dostęp do obszernej bazy wiedzy na temat taktyk, technik i procedur cyberprzestępców, takiej jak macierz MITRE ATT&CK. Jest to publicznie dostępna baza wiedzy, która jest stale aktualizowane w oparciu o pojawiające się zagrożenia cybernetyczne. Dostarcza ona różnych informacji na temat motywacji, zainteresowań czy docelowych regionów ataków. Pomaga w doborze sposobu ochrony przed atakami oraz zawiera cenne zalecenia łagodzące skutki ataku.

Cel i zakres pracy

Celem pracy jest ocena strategii obronnych przed atakami cybernetycznymi poprzez wykorzystanie macierzy MITRE ATT&CK jako narzędzia, które obejmuje techniki ataków i metody ich przeciwdziałania.

Praca składa się ze wstępu, w którym sprecyzowano jej cel, pięciu rozdziałów merytorycznych oraz podsumowania, w którym zawarto końcowe wnioski. Pierwszy rozdział skupia się na tematyce cyberzagrożeń i sposobach obrony w cyberprzestrzeni. Omówiono tam klasyfikację najczęściej spotykanych rodzajów ataków, a także zaprezentowano istniejące strategie ochronne, frameworki oraz normy i przepisy obowiązujące w dziedzinie cyberbezpieczeństwa. Drugi rozdział poświęcony jest opisowi macierzy MITRE ATT&CK. Zawiera szczegółowy wykaz elementów jej struktury, takich jak taktyki, techniki i podtechniki wykorzystywane w atakach. Przedstawiono też sposób, w jaki klasyfikuje się zagrożenia oraz rolę tej macierzy w analizie i ocenie efektywności zastosowanych strategii obronnych. Trzeci rozdział opisuje metodykę badań - w tym dobór narzędzi, technik oraz konfigurację środowiska testowego. W rozdziale czwartym omówiono przygotowane scenariusze ataków, które opierają się na technikach z macierzy MITRE ATT&CK. Dla każdej symulacji wskazano cel działania, środowisko testowe, przebieg ataku, a także oczekiwane wskaźniki kompromitacji (IoC). Do każdego scenariusza dołączono też opis strategii obronnej, dostosowanej do wykorzystanej techniki. Piąty rozdział przedstawia przebieg przeprowadzonych symulacji w środowisku wirtualnym oraz analizę uzyskanych wyników. Opisano tam szczegóły dotyczące konfiguracji maszyny testowej, dołączono dokumentację w postaci zrzutów ekranu z przebiegu testów, a także przedstawiono analizę logów pochodzących z narzędzi takich jak Sysmon, PowerShell czy Windows Defender. Ostatni rozdział będący podsumowaniem zawiera wnioski końcowe dotyczące skuteczności zastosowanych strategii obronnych oraz praktycznej użyteczności macierzy MITRE ATT&CK w procesie modelowania i oceny odporności systemów informatycznych na cyberzagrożenia.

1. Zagrożenia i mechanizmy obrony w cyberprzestrzeni

Cyberatak to próba uzyskania dostępu do sieci lub systemu komputerowego przez cyberprzestępców, hakerów lub innych przeciwników cyfrowych, zwykle w celu zmiany, kradzieży, zniszczenia lub ujawnienia danych [15]. Technologie cyberataków stają się coraz bardziej wyrafinowane, wymierzone w każdą infrastrukturę sieciową, która posiada luki w zabezpieczeniach. Jako użytkownik Internetu wprowadzający dane osobowe, ważne jest, aby zrozumieć te zagrożenia. Dane te są wysoko cenione przez cyberprzestępców, którzy wykorzystują je do swoich celów, a nawet sprzedają w dark necie, gdzie cyberprzestępczość działa jak ogromna podziemna organizacja zdolna do gromadzenia, manipulowania i używania skradzionych danych przeciwko ofiarom [12].

Najprościej rzecz ujmując, cyberzagrożenie wskazuje, że cyberprzestępca próbuje uzyskać nieautoryzowany dostęp do sieci w celu przeprowadzenia cyberataku [39]. Cyberataki mogą być wymierzone w szerokie grono ofiar, od użytkowników indywidualnych po przedsiębiorstwa, a nawet instytucje państwowe. W przypadku ataków na firmy lub inne organizacje, celem atakującego jest zwykle uzyskanie dostępu do poufnych i cennych zasobów firmy, takich jak własność intelektualna, dane klientów lub inne dane personalne [8,15].

Firmy świadczące usługi finansowe, w tym firmy księgowe, inwestycyjne, ubezpieczeniowe i konsultingowe, codziennie zajmują się bardzo wrażliwymi danymi, takimi jak dane uwierzytelniające i dane osobowe. Informacje te mają ogromną wartość dla atakujących, którzy mogą przekierowywać płatności, sprzedawać prywatne dane w dark necie lub blokować dostęp do ważnych plików w celu wyłudzenia dużych sum pieniędzy. Wiele osób zakłada, że zagrożone są tylko duże banki i instytucje, ale rzeczywistość jest taka, że zagrożenia cybernetyczne wymierzają ataki w firmy każdej wielkości. Więc zrozumienie najczęstszych zagrożeń i ocena obszaru narażonego jest pierwszym kluczowym krokiem do zbudowania silnej obrony dla organizacji [1,38].

1.1 Rodzaje cyberzagrożeń

Współczesne cyberzagrożenia mogą przybierać różne formy. W obliczu różnorodności metod ataków, ważne jest, aby zrozumieć, jak mogą one wyglądać i jakie techniki są wykorzystywane przez cyberprzestępców. W tym podrozdziale zostaną omówione popularne formy cyberzagrożeń, z którymi użytkownicy i organizacje mogą spotkać się podczas codziennej działalności w sieci.

1.1.1 Malware - złośliwe oprogramowanie

Malware jest to skrót od *malicious software*. To oprogramowanie, które zostało napisane w celu wyrządzenia szkody systemowi komputerowemu lub jego użytkownikom. Prawie każdy współczesny cyberatak wiąże się z jakimś rodzajem złośliwego oprogramowania. Cyberprzestępcy wykorzystują ataki *malware*, aby uzyskać nieautoryzowany dostęp i uniemożliwić działanie zainfekowanych systemów, np. niszczyć dane, kraść poufne informacje, a nawet usuwając pliki krytyczne dla systemu operacyjnego [39].

Ataki złośliwego oprogramowania stają się coraz bardziej wyrafinowane i powszechne, stanowiąc poważne zagrożenie dla osób fizycznych, firm i rządów na całym świecie. Ataki te mogą spowodować znaczne straty finansowe, utratę reputacji i naruszenie bezpieczeństwa. Wraz z postępem technologicznym zmieniają się taktyki tych, którzy starają się wykorzystać luki w zabezpieczeniach. Dlatego tak ważne jest, aby być na bieżąco z najnowszymi informacjami w dziedzinie cyberbezpieczeństwa i wdrażać solidne środki ochronne, po to by ograniczyć ryzyko związane z atakami złośliwego oprogramowania [13].

Złośliwe oprogramowanie to ogólny termin określający szereg zagrożeń internetowych, w tym wirusy, oprogramowanie szpiegujące, oprogramowanie reklamowe, oprogramowanie ransomware i inne rodzaje szkodliwego oprogramowania. Wirus komputerowy to po prostu jeden z rodzajów złośliwego oprogramowania [41].

Tabela 1.1 Typy oprogramowania Malware

Typ	Opis
Robak	Jeden z najczęstszych rodzajów złośliwego oprogramowania. Rozprzestrzenia się w sieciach komputerowych, wykorzystując luki w zabezpieczeniach systemu operacyjnego. Jest to samodzielny program, który replikuje się w celu zainfekowania innych komputerów bez konieczności podejmowania jakichkolwiek działań przez kogokolwiek.
Koń trojański	Trojan lub inaczej koń trojański podszywa się pod legalne oprogramowanie, aby nakłonić użytkownika do uruchomienia złośliwego oprogramowania. Ponieważ wygląda wiarygodnie, użytkownicy pobierają go i nieumyślnie pozwalają na infekcję swojego urządzenia. W odróżnieniu od robaków, trojan wymaga tzw. „żywiciela” czyli uruchomienia przez użytkownika, aby zacząć działać. Po zainstalowaniu może być wykorzystywany przez cyberprzestępców do usuwania, modyfikowania lub kradzieży danych, szpiegowania aktywności użytkownika, przejmowania kontroli nad urządzeniem w celu włączenia go do botnetu, a także do uzyskiwania nieautoryzowanego dostępu do sieci.
Wirus	Wirus to fragment kodu, który wstawia się do aplikacji. Jest wykonywany po uruchomieniu aplikacji. Po dostaniu się do sieci może zostać wykorzystany do kradzieży poufnych danych, przeprowadzania ataków DDoS lub przeprowadzania ataków ransomware. Wirus, zwykle rozprzestrzeniający się za pośrednictwem zainfekowanych stron internetowych, udostępniania plików lub pobierania załączników do wiadomości e-mail. Wirus będzie uśpiony, dopóki zainfekowany plik hosta lub program nie zostanie aktywowany. Gdy tak się stanie, może się replikować i rozprzestrzeniać w systemie.
Ransomware	Ransomware to złośliwe oprogramowanie zaprojektowane w celu zablokowania użytkownikom dostępu do jego danych lub odmowy dostępu do nich do czasu zapłacenia okupu. Ransomware od wielu lat stanowi stałe zagrożenie dla organizacji z różnych branż.

	Ponieważ coraz więcej firm decyduje się na transformację cyfrową, znacznie wzrosło prawdopodobieństwo, że staną się celem ataku ransomware.
Adware	Adware, skrót od <i>advertising-supported software</i> . Oprogramowanie o wyświetla niechciane, a czasem złośliwe reklamy na ekranie komputera lub urządzenia mobilnego, przekierowuje wyniki wyszukiwania do witryn reklamowych lub przechwytuje dane użytkownika, które mogą zostać sprzedane reklamodawcom bez zgody użytkownika. Nie każde oprogramowanie reklamowe to złośliwe oprogramowanie, niektóre są legalne i bezpieczne w użyciu.
Spyware	Oprogramowanie szpiegujące to forma złośliwego oprogramowania, które ukrywa się na urządzeniu, monitoruje aktywność i kradnie poufne informacje, takie jak dane finansowe, informacje o koncie, loginy i inne. Oprogramowanie szpiegujące może rozprzestrzeniać się, wykorzystując luki w oprogramowaniu lub być dołączane do legalnego oprogramowania.
Keylogger	Keylogger to rodzaj oprogramowania szpiegującego, które monitoruje aktywność użytkownika. Po zainstalowaniu w złośliwych celach keyloggery mogą być wykorzystywane do kradzieży danych haseł, informacji bankowych lub innych poufnych informacji. Keyloggery mogą zostać wprowadzone do systemu poprzez phishing, socjotechniki lub nieświadome pobranie przez użytkownika.
Boty i Botnety	Bot to komputer, który został zainfekowany złośliwym oprogramowaniem, dzięki czemu może być zdalnie kontrolowany przez hakera. Taki Bot jest czasami nazywany „komputerem zombie”. Po przejęciu nad nim kontroli może być następnie wykorzystany do przeprowadzenia większej liczby ataków lub stać się częścią zbioru botów zwanych botnetem. Botnety mogą obejmować miliony urządzeń, ponieważ rozprzestrzeniają się niewykryte. Botnety pomagają hakerom w licznych złośliwych działaniach, w tym atakach DDoS, wysłaniu spamu i wiadomości

	phishingowych oraz rozprzestrzenianiu innych rodzajów złośliwego oprogramowania.
Złośliwe oprogramowanie bez plików	Złośliwe oprogramowanie bezplikowe to rodzaj złośliwego oprogramowania, które wykorzystuje legalne programy do infekowania komputera. Nie opiera się na plikach i nie pozostawia śladów, co utrudnia wykrycie i usunięcie. Bez przechowywania w pliku lub bez instalowania bezpośrednio na komputerze, infekcje bezplikowe trafiają bezpośrednio do pamięci, a złośliwa zawartość nigdy nie dotyka dysku twardego. Cyberprzestępcy coraz częściej zwracają się ku bezplikowemu złośliwemu oprogramowaniu jako skutecznej alternatywnej formie ataku. Utrudnia to wykrycie ataku tradycyjnemu programowi antywirusowemu.
Bomba logiczna	Bomby logiczne to rodzaj złośliwego oprogramowania, które aktywuje się tylko po uruchomieniu, na przykład w określonym dniu i godzinie lub po dwudziestym zalogowaniu się na konto. Wirusy i robaki często zawierają bomby logiczne, które dostarczają swój ładunek (tj. złośliwy kod) w określonym czasie lub gdy spełniony jest inny warunek. Szkody spowodowane przez bomby logiczne są różne, od zmiany bajtów danych po uniemożliwienie odczytania dysków twardych.
Hybrydy	Obecnie większość złośliwego oprogramowania to połączenie różnych typów złośliwego oprogramowania, często zawierającego części trojanów i robaków, a czasami wirusa. Zwykle złośliwe oprogramowanie pojawia się dla użytkownika końcowego jako trojan, ale po uruchomieniu atakuje inne ofiary w sieci jak robak.

Źródło: Opracowanie własne na podstawie [41].

1.1.2 Inżynieria społeczna i phishing

Inżynieria społeczna, często nazywana "hakowaniem ludzi", polega na manipulowaniu ofiarami w taki sposób by podjęły działania, które ujawnią poufne dane, zagrażą dobrobytowi finansowemu ofiary lub organizacji, której są częścią, albo w inny sposób zagrażą bezpieczeństwu osobistemu lub organizacyjnemu [40].

Phishing jest najbardziej znaną i najbardziej rozpowszechnioną formą socjotechniki. Phishing wykorzystuje podstępne wiadomości e-mail, załączniki do wiadomości e-mail, wiadomości tekstowe lub rozmowy telefoniczne, aby nakłonić ludzi do udostępnienia danych osobowych lub danych logowania, pobrania złośliwego oprogramowania, wysłania pieniędzy cyberprzestępcom lub podjęcia innych działań, które mogą narazić ofiary na cyberprzestępstwa [40].

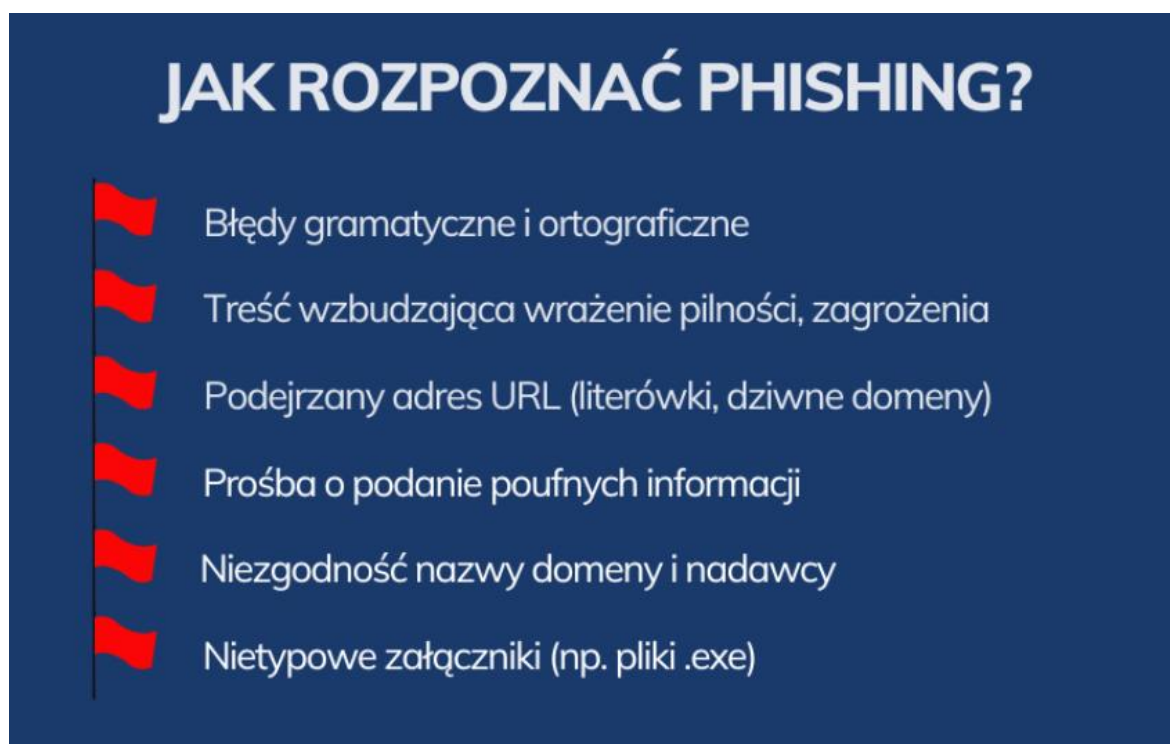
Tabela 1.2 Typy ataków phishingowych

Typ	Opis
Spear phishing	Ataki <i>phishingowe</i> , które manipulują konkretną osobą, często wykorzystując dane z publicznych profili ofiary w mediach społecznościowych, aby oszustwo było bardziej przekonujące.
Whale phishing	Spear phishing wymierzony w kadrę kierowniczą korporacji lub osoby zamożne.
Business email compromise (BEC)	Oszustwa, w których cyberprzestępcy podszywają się pod kadrę kierowniczą, dostawców lub zaufanych partnerów biznesowych, aby nakłonić ofiary do przelania pieniędzy lub udostępnienia poufnych danych.

Źródło: Opracowanie własne na podstawie [40].

Atakujący mogą również przeprowadzać ataki, tworząc strony internetowe, które wyglądają bardzo podobnie do legalnych. Jeśli użytkownik nie zwraca szczególnej uwagi na szczegóły, łatwo jest pomylić fałszywą witrynę z prawdziwą [37]. To oszustwo nazywane

jest podszywaniem się pod nazwę domeny (*domain name spoofing*). Istnieje też atak znany jako *DNS spoofing*. Polega on na tym, że cyberprzestępcy wykorzystują fałszywą stronę internetową lub nazwę domeny, która podszywa się pod prawdziwą, aby nakłonić użytkownika do wprowadzenia poufnych informacji. E-maile phishingowe często używają sfałszowanych nazw domen nadawcy, aby wiadomość e-mail wydawała się bardziej wiarygodna i uzasadniona [40]. Rysunek 1.1 ilustruje jakie są cechy charakterystyczne ataku phishingowego.



Rysunek 1.1 Jak rozpoznać phishing [21]

1.1.3 Ataki DoS i DDoS

Atak typu denial-of-service (DoS) to cyberatak, który przeciąża witrynę, aplikację lub system ogromną ilością fałszywego ruchu. Sprawia to, że system staje się zbyt wolnym w działaniu lub całkowicie niedostępnym dla prawdziwych użytkowników [40]. Atak typu *denial-of-service* (DoS) jest jednym z najczęstszych rodzajów cyberataków. Cyberprzestępcy mogą przeprowadzać ataki DoS, w celu uzyskania dostępu do informacji przechowywanych na komputerze lub stronie internetowej lub zakłócić działania osoby lub organizacji odpowiedzialnej za prowadzenie atakowanego zasobu [37]. W przypadku ataku DoS użytkownicy nie są w stanie wykonywać rutynowych i niezbędnych zadań, takich jak

uzyskiwanie dostępu do poczty e-mail, stron internetowych, kont online czy innych zasobów obsługiwanych przez zaatakowany komputer lub sieć. Chociaż większość ataków DoS nie powoduje utraty danych i jest zwykle rozwiązywana bez płacenia okupu, kosztują one organizację czas, pieniądze i inne zasoby w celu przywrócenia ważnych operacji biznesowych [15].

Atak DDoS (*distributed denial-of-service*) jest podobny. Różnicą jest to, że wykorzystuje sieć podłączonych do Internetu, zainfekowanych złośliwym oprogramowaniem urządzeń lub botów, które są znane jako botnet. Atak ten ma na celu sparaliżowanie lub awarie atakowanego systemu (3). Ataki DDoS są szybsze i trudniejsze do zablokowania niż ataki DoS, ponieważ wiele systemów musi zostać zidentyfikowanych i zneutralizowanych, aby powstrzymać atak [15]. Schemat działania ataku DDoS przedstawia rysunek 1.2.



Rysunek 1.2 Schemat działania ataku DDoS [14]

1.1.4 Atak typu Man-in-the-Middle (MITM)

Ataki typu *man-in-the-middle* (MitM) przechwytują i mogą sterować komunikacją między dwiema stronami, które uważają, że komunikują się ze sobą bezpośrednio [12]. W ataku typu *man-in-the-middle* (MITM) cyberprzestępca podsłuchuje połączenie sieciowe w celu przechwycenia i przekazania wiadomości między dwiema stronami oraz kradzieży danych. Niezabezpieczone sieci Wi-Fi są często szczęśliwym terenem łowieckim dla hakerów, którzy chcą przeprowadzić ataki MITM [40].

1.1.5 Atak typu Injection

W tych atakach hakerzy wstrzykują złośliwy kod do programu lub pobierają złośliwe oprogramowanie w celu wykonania zdalnych poleceń. Umożliwia im to odczytanie lub modyfikację bazy danych lub zmianę danych witryny. Istnieje kilka rodzajów ataków iniekcyjnych.

Dwa najczęstsze to:

- SQL Injection - polegają na wykorzystaniu składni języka SQL do fałszowania tożsamości, modyfikowania, niszczenia lub blokowania dostępu do istniejących danych, a nawet przejęcia kontroli nad serwerem bazy danych,
- Cross-Site Scripting (XSS) - podobne do SQL Injection, ale zamiast wyciągania danych z bazy danych zazwyczaj infekują użytkowników odwiedzających daną stronę internetową [40].

1.1.6 Ataki na hasło

Jak nazwa wskazuje, ataki te polegają na tym, że cyberprzestępcy próbują odgadnąć lub ukraść hasło lub dane logowania do konta użytkownika. Wiele ataków na hasła wykorzystuje socjotechnikę, aby nakłonić ofiary do nieświadomego udostępnienia tych poufnych danych. Jednak hakerzy mogą również używać ataków *brute force* w celu kradzieży haseł, wielokrotnie próbując różnych kombinacji haseł, aż jedna z nich zakończy się sukcesem [40].

1.1.7 Ataki typu Zero-day

Exploit zero-day to rodzaj cyberataku, który wykorzystuje lukę zero-day, czyli nieznaną lub jeszcze niezatakaną lukę w zabezpieczeniach sprzętu lub oprogramowania komputerowego. "Dzień zerowy" odnosi się do faktu, że dostawca oprogramowania lub urządzenia ma "zero dni", czyli nie ma czasu na naprawienie luk w zabezpieczeniach, ponieważ atakujący mogą już je wykorzystać do uzyskania dostępu do podatnych na ataki systemów [40].

1.2 Systemy i metody organizacji obrony w cyberbezpieczeństwie

Strategie obrony przed cyberatakami obejmują szereg praktyk i frameworków mających na celu ochronę zasobów cyfrowych przed coraz bardziej wyrafinowanymi zagrożeniami cybernetycznymi.

Najczęściej używany termin "standard" odnosi się do dokumentów ustalonych przez organizacje zawodowe. Są to zestawy praktyk lub metod technicznych, które pomagają organizacjom zabezpieczyć swoje środowisko cybernetyczne. Standard jest opisywany jako stan idealny z minimalnym limitem osiągnięć. Wiele międzynarodowych organizacji, stowarzyszeń i konsorcjów odgrywa istotną rolę w opracowywaniu norm. Zgodnie z „www.standards.org.au” normy są reprezentowane jako dokumenty określające specyfikacje, procedury i wytyczne, mające na celu zapewnienie bezpieczeństwa, spójności i niezawodności produktów, usług i systemów [35]. Ponadto, w oparciu o definicję podaną przez ISO/IEC, normy są dokumentami lub regułami opracowanymi na podstawie ogólnego porozumienia i zatwierdzonymi przez osobę prawną. Są to dokumenty które pomagają osiągnąć optymalne wyniki, służąc jako wytyczne, modele lub próbki, w określonym kontekście. Standard praktycznie spełnia wymagania użytkowników, uwzględnia ograniczenia technologii i zasobów, a także spełnia wymagania weryfikacyjne [10].

Regulacje dotyczące cyberbezpieczeństwa często opierają się na standardach zgodności, które określają wymagania dotyczące ochrony danych i systemów informatycznych. Choć różne standardy mogą się różnić w szczegółach, zazwyczaj dążą do osiągnięcia wspólnego celu: stworzenia zestawu zasad, które są łatwe do wdrożenia, przestrzegania i dostosowywania do specyfiki technologicznej danej organizacji. Główne wymogi dotyczące zgodności mogą obowiązywać zarówno na poziomie lokalnym, jak

i międzynarodowym. Niezależnie od tego, gdzie znajduje się firma czy na jakich rynkach działa i przetwarza dane. Dodatkowo, mechanizmy nadzoru regulacyjnego określają również, jakie rodzaje danych są przechowywane przez organizacje oraz ich charakter [19].

Frameworki zapewniają ustrukturyzowany zestaw wytycznych i najlepszych rozwiązań w zakresie bezpieczeństwa danych i prywatności. Ramy te są często kształtowane przez ekspertów branżowych i mają na celu pomóc firmom w poruszaniu się po złożonym krajobrazie cyberbezpieczeństwa. Przestrzegając zaufanych ram, organizacje mogą upewnić się, że dokładają należytej staranności w celu ochrony poufnych danych, ograniczenia zagrożeń bezpieczeństwa, a nawet przestrzegania przepisów prawnych. Ramy te służą wielu celom. Po pierwsze, oferują przewodnik o tym jak stworzyć bezpieczne środowisko dostosowane do konkretnych potrzeb. Po drugie, pomagają ustandaryzować protokoły bezpieczeństwa, ułatwiając organizacjom bezpieczną komunikację i współpracę. Nieprzestrzeganie odpowiednich ram bezpieczeństwa może skutkować poważnymi konsekwencjami finansowymi i prawnymi, nie wspominając o potencjalnym uszczerbku na reputacji marki [33].

1.2.1 Istniejące strategie obronne

1. Zero Trust Security

Architektura zerowego zaufania (ang. *zero trust architecture*) to architektura cyberbezpieczeństwa, która ma na celu zapobieganie naruszeniom danych i ograniczanie wewnętrznego ruchu bocznego [5]. Jest to struktura zbudowana w oparciu o zasadę „nigdy nie ufaj, zawsze weryfikuj”. Nakazuje ścisłą weryfikację tożsamości dla każdej osoby i urządzenia próbującego uzyskać dostęp do zasobów w sieci prywatnej. Takie podejście skutecznie minimalizuje powierzchnię ataku i ogranicza ryzyko rozprzestrzeniania się zagrożeń, nawet jeśli atakujący uzyska początkowy dostęp [47].

Architektura zerowego zaufania nie jest pojedynczą architekturą, ale zbiorem zasad przewodnich dotyczących przepływu pracy, projektowania systemu i operacji, które można wykorzystać do poprawy stanu bezpieczeństwa. Organizacje powinny dążyć do stopniowego wdrażania zasad zerowego zaufania, zmian w procesach i rozwiązań technologicznych, które chronią ich zasoby danych i funkcje biznesowe według przypadków użycia [5].

Filary architektury Zero Trust

Architektura Zero Trust opiera się na kilku podstawowych filarach, które wspólnie wymuszają solidną infrastrukturę zabezpieczeń:

- Weryfikacja tożsamości - pierwsza linia obrony
Silna weryfikacja tożsamości ma kluczowe znaczenie w środowisku Zero Trust. Zastosowanie uwierzytelniania wieloskładnikowego i niezawodnych protokołów uwierzytelniania gwarantuje, że tylko autoryzowani użytkownicy uzyskują dostęp do zasobów. Ciągłe uwierzytelnianie i autoryzacja dodatkowo wzmacniają bezpieczeństwo, weryfikując tożsamość użytkownika podczas całej sesji,
- Zaufanie do urządzenia - zapewnianie bezpieczeństwa punktów końcowych
Zbudowanie zaufania do urządzeń jest kluczowe, aby zapobiec nieautoryzowanemu dostępowi z urządzeń, które mogą być niebezpieczne lub niezarządzone. W tym celu warto wdrożyć rozwiązania zabezpieczające dla punktów końcowych, takie jak monitorowanie stanu urządzeń oraz wykrywanie i reagowanie na zagrożenia. Dzięki temu można mieć pewność, że wszystkie urządzenia spełniają niezbędne standardy bezpieczeństwa, zanim uzyskają dostęp.
- Segmentacja sieci - minimalizacja ruchu bocznego
Segmentacja sieci odgrywa kluczową rolę w powstrzymywaniu naruszeń bezpieczeństwa i zapobieganiu ruchom bocznym. Dzieląc sieć na mniejsze, odizolowane strefy, organizacje mogą ograniczyć zasięg ataków i uniemożliwić atakującym łatwe przechodzenie przez sieć,
- Dostęp z minimalnymi uprawnieniami - ograniczanie uprawnień użytkownika
Przestrzeganie zasady dostępu z minimalnymi uprawnieniami ma fundamentalne znaczenie dla modelu Zero Trust. Użytkownikom należy przyznać tylko niezbędne uprawnienia do wykonywania określonych, powierzonych im zadań. Ogranicza to potencjalne szkody spowodowane przejętymi kontami i zmniejsza ryzyko nieautoryzowanego dostępu do poufnych danych,
- Ochrona danych - zabezpieczanie informacji w spoczynku i ruchu
Ochrona danych jest kluczowym elementem modelu Zero Trust. Wdrożenie rozwiązań szyfrowania i solidnych kontroli dostępu zapewnia ochronę poufnych danych zarówno w spoczynku, jak i podczas przesyłania informacji [47].

Kluczowe kroki potrzebne do wdrożenia modelu Zero Trust

- Identyfikacja zakresu: identyfikacja krytycznych zasobów, aplikacji i danych, które wymagają ochrony. Wiąże się to z dokładną oceną infrastruktury IT organizacji i wzorców przepływu danych,
- Identyfikacja użytkowników i urządzeń: ustanowienie kompleksowego spisu wszystkich użytkowników i urządzeń, które będą uzyskiwać dostęp do sieci. Dotyczy to pracowników, wykonawców, partnerów i urządzeń,
- Implementowanie zarządzania tożsamościami i dostępem (IAM): wdrożenie niezawodnych rozwiązań IAM, aby zarządzać tożsamościami użytkowników, uwierzytelniać żądania dostępu i egzekwować szczegółowe zasady kontroli dostępu.
- Segmentacja sieci: podzielenie sieci na mniejsze, odizolowane segmenty, aby ograniczyć wpływ naruszeń bezpieczeństwa i zapobiec ruchom bocznym,
- Wdrażanie narzędzi zabezpieczeń: implementowanie podstawowych narzędzi zabezpieczeń, takich jak uwierzytelnianie wieloskładnikowe (MFA), systemy wykrywania i zapobiegania włamaniom (IDPS) oraz rozwiązania zapobiegania utracie danych (DLP),
- Monitorowanie i konserwacja: stałe monitorowanie sieci pod kątem podejrzanej aktywności oraz regularne przeglądanie i aktualizacja zasad bezpieczeństwa, aby dostosować się do zmieniających się zagrożeń [47].

2. Defence in depth

Defence-in depth to kompleksowa strategia mająca na celu ochronę krytycznych zasobów przy pomocy wielu środków ochronnych. W przeciwieństwie do pojedynczej bariery bezpieczeństwa, DID opiera się na kombinacji praktyk mających na celu ochronę przed zagrożeniami cybernetycznymi [43]. Defence in depth zapobiega stratom lub minimalizuje je poprzez zastosowanie wielu skoordynowanych mechanizmów. Mechanizmy te mogą obejmować kontrole techniczne, operacyjne i organizacyjne, które działają razem w celu zapewnienia kompleksowego systemu obronnego [23].

Filary Defence in depth

Ochrona w głąb opiera się na trzech głównych filarach, które kierują wdrażaniem środków ochronnych:

- Wiele linii obrony - oznacza to wdrożenie kilku barier w całym systemie w celu

ochrony przed przewidywanymi zagrożeniami. Te mechanizmy obronne powinny być rozmieszczone w kluczowych punktach potencjalnych scenariuszy zagrożeń,

- a każda warstwa powinna skutecznie blokować określone typy ataków lub ograniczać ich konsekwencje,
- Unikanie pojedynczych punktów awarii - aby strategia bezpieczeństwa nie opierała się na pojedynczym elemencie obronnym, organizacje zmniejszają prawdopodobieństwo wystąpienia katastrofalnej awarii. Jeśli jedna warstwa zabezpieczeń zawiedzie, inne warstwy nadal będą na miejscu, aby powstrzymać zagrożenie i zapobiec jego eskalacji,
- Różnorodność w warstwach obronnych - pojedynczy element obronny, taki jak zaporę sieciową lub program antywirusowy, sam w sobie nie wystarczy. Warstwy powinny mieć zróżnicowany charakter, w tym mieszankę obrony technicznej, operacyjnej i organizacyjnej. Na przykład bariery techniczne mogą obejmować zapory sieciowe i systemy wykrywania włamań, podczas gdy bariery operacyjne mogą obejmować szkolenia personelu i programy uświadamiające w zakresie bezpieczeństwa [23].

Kluczowe warstwy Defence in depth

Defence in depth składa się z trzech podstawowych części: kontroli administracyjnej, kontroli fizycznej i kontroli technicznej, które mają na celu ochronę administracyjnych, fizycznych i technicznych aspektów sieci.

- Kontrole administracyjne - to środki bezpieczeństwa, które składają się z zasad i procedur skierowanych do pracowników organizacji. Administratorzy systemu i zespoły ds. zabezpieczeń ustalają te zasady i praktyki, aby ograniczyć uprawnienia użytkowników i wskazać im, jak zwiększyć bezpieczeństwo. Obejmuje to kontrolę dostępu do zasobów firmowych, systemów wewnętrznych oraz innych wrażliwych danych i aplikacji. Przykładami środków kontroli administracyjnej są polityki bezpieczeństwa informacji, ramy zarządzania ryzykiem stron trzecich, strategie zarządzania ryzykiem informacyjnym oraz oceny ryzyka w zakresie cyberbezpieczeństwa,
- Kontrole fizyczne - to środki bezpieczeństwa, które chronią centra danych, systemy IT i inne zasoby fizyczne przed zagrożeniami, takimi jak nieautoryzowany dostęp lub kradzież danych. Środki takie jak ochroniarze, kamery przemysłowe, skanery

dowodów osobistych i zabezpieczenia biometryczne, które uniemożliwiają fizyczny dostęp lub podlegają fizycznej kontroli,

- Kontrola techniczna – to środki bezpieczeństwa, które chronią bezpieczeństwo sieci i zasoby IT przy użyciu różnych rodzajów sprzętu i oprogramowania. Przykładami są systemy ochrony przed włamaniami lub wykrywania włamań, zapory aplikacji internetowych, uwierzytelnianie dwuskładnikowe lub wieloskładnikowe, dane biometryczne, wirtualne sieci prywatne i szyfrowane kopie zapasowe [34].

Zasada działania ochrony w głąb w praktyce

Prawidłowo wdrożona ochrona w głąb zmienia sposób, w jaki organizacja podchodzi do bezpieczeństwa. Staje się wielowymiarową strategią ochrony, która koordynuje różne warstwy obrony architektury w celu osiągnięcia głębi bezpieczeństwa.

- Początkowa obrona - koncentruje się na zapobieganiu atakom docierającym do krytycznych punktów infrastruktury. Mogą to być zapory sieciowe, oprogramowanie antywirusowe i systemy zapobiegania włamaniom (IPS),
- Kolejne zabezpieczenia - jeśli atakującemu uda się ominąć początkowe zabezpieczenia, dodatkowe warstwy, takie jak systemy wykrywania włamań (IDS), uwierzytelnianie wieloskładnikowe (MFA) i segmentacja sieci, mogą zablokować dalszą eskalację ataku,
- Ostatnie linie obrony - jeśli atak zdoła zagrozić systemowi, ostatnia linia obrony ma na celu powstrzymanie szkód i jak najszybsze odzyskanie sprawności. Może to obejmować kopie zapasowe danych, plany reagowania na incydenty i mechanizmy odzyskiwania po awarii, które pomagają zminimalizować wpływ ataku i zapewnić ciągłość biznesową [23].

3. Extended Detection and Response (XDR)

Rozszerzone wykrywanie i reagowanie (XDR) stanowi znaczącą ewolucję w dziedzinie cyberbezpieczeństwa, oferując organizacjom kompleksowe rozwiązanie do walki z nowoczesnymi zagrożeniami. Jest to zaawansowane rozwiązanie z zakresu cyberbezpieczeństwa, które rozszerza możliwości wykrywania i reagowania w punktach końcowych, integrując dane i szczegółowe informacje z wielu źródeł zabezpieczeń w sieciach i środowiskach chmurowych organizacji [44]. Oprogramowanie XDR zbiera dane o cyberzagrożeniach ze źródeł, które zwykle są rozłączone. Agreguje i ujednolica te

dane w jedną platformę bezpieczeństwa. XDR koreluje alerty zabezpieczeń i zdarzenia w różnych domenach, zapewniając kontekstowy wgląd w to, co dzieje się w infrastrukturze IT organizacji. Analizuje obciążenia pod kątem luk w zabezpieczeniach, wektorów zagrożeń złośliwego oprogramowania i całego ekosystemu IT. Pomaga również określać priorytety i klasyfikować zdarzenia w momencie ich wystąpienia. Wszystkie dane gromadzone przez platformy XDR są znormalizowane w celu obsługi zaawansowanych aplikacji analitycznych i sztucznej inteligencji (AI), które mogą identyfikować anomalie i wykrywać potencjalne zagrożenia bezpieczeństwa. Analitycy bezpieczeństwa używają narzędzi XDR do korelowania danych oraz określania głównej przyczyny i zakresu incydentów związanych z bezpieczeństwem [24].

Filary XDR

Technologia XDR wspiera wykrywanie zagrożeń i reagowanie na nie za pomocą wieloetapowego procesu, który obejmuje następujące kroki:

- Zbieranie i pozyskiwanie danych - pierwszym krokiem dla systemu XDR jest zebranie odpowiednich danych telemetrycznych. Narzędzia XDR pobierają dane z punktów końcowych, czujników sieciowych, platform chmurowych, systemów tożsamości, poczty e-mail i innych źródeł. Typy danych, które są zbierane, obejmują aktywność punktów końcowych, ruch sieciowy, dane dziennika, metadane plików, szczegóły procesu, zachowanie użytkownika i alerty IT. Duże ilości danych historycznych i danych zbieranych w czasie rzeczywistym są konsolidowane na platformie XDR, gdzie są zwykle przechowywane w data lake'u, zdolnym do obsługi różnych formatów danych. Dane te mogą być ustrukturyzowane, częściowo ustrukturyzowane i nieustrukturyzowane,
- Analityka i wykrywanie zagrożeń - narzędzia XDR agregują zebrane dane i stosują reguły korelacji, modele uczenia maszynowego, analizę zachowań użytkowników i podmiotów oraz inne zaawansowane techniki analityczne w celu wykrywania znanych i nieznanych zagrożeń bezpieczeństwa. Szczegółowe informacje analityczne są prezentowane w ujednoliconej konsoli zarządzania, która zapewnia wgląd w zagrożenia w różnych środowiskach IT. Analitycy bezpieczeństwa mogą badać wykryte zagrożenia przy użyciu analizy osi czasu, zapytań wyszukiwania zagrożeń i innych funkcji XDR,

- Zautomatyzowane reagowanie i ograniczanie zagrożeń - na podstawie zidentyfikowanych zagrożeń platformy XDR uruchamiają zautomatyzowane działania reagowania zgodnie z zaplanowanymi wcześniej scenariuszami. Możliwe reakcje obejmują izolowanie zainfekowanych systemów, zatrzymywanie procesów aplikacji, blokowanie adresów IP lub domen, wyłączanie kont użytkowników oraz kwarantannę wiadomości e-mail. Takie działania są koordynowane w różnych narzędziach zabezpieczeń takich jak: EDR, zapory ogniowe, oprogramowanie antywirusowe, systemy zarządzania informacjami i zdarzeniami bezpieczeństwa (SIEM), platformy orkiestracji, automatyzacji i reagowania na zagrożenia (SOAR), lub za pomocą innych środków kontroli bezpieczeństwa zintegrowane z technologią XDR,
- Scentralizowane wykrywanie - XDR centralizuje procesy związane z wykrywaniem, badaniem, wyszukiwaniem zagrożeń, umożliwiając analitykom bezpieczeństwa przełączanie się między tymi procesami w razie potrzeby bez uruchamiania innego narzędzia [24].

Takie podejście łączy i integruje dane z różnych źródeł zabezpieczeń, w tym punktów końcowych, ruchu sieciowego, zapór sieciowych, platform chmurowych oraz systemów zarządzania tożsamością i dostępem. Całościowy widok zapewnia kompleksowe zrozumienie stanu zabezpieczeń organizacji.

4. Security Operations Center

SOC to skrót od Security Operations Center, czyli Centrum Operacji Bezpieczeństwa. Jest to zespół, który zapewnia bezpieczeństwo organizacji przed zagrożeniami [32]. Security Operations Center to scentralizowana jednostka przeznaczona do monitorowania i analizowania problemów związanych z bezpieczeństwem. Jej głównym celem jest ochrona cennych danych i systemów organizacji przed hakerami i innymi cyberzagrożeniami. SOC wykorzystuje różne narzędzia i procesy w celu zwiększenia bezpieczeństwa cybernetycznego, zapewniając, że potencjalne zagrożenia są szybko identyfikowane i łagodzone. Zespoły w ramach SOC współpracują w celu skrócenia czasu reakcji i zminimalizowania szkód spowodowanych naruszeniami bezpieczeństwa [48].

Działanie SOC

Centrum Operacji Bezpieczeństwa jest przede wszystkim zespołem odpowiedzialnym za wykrywanie i reagowanie na incydenty i zagrożenia cybernetyczne. SOC może również przeprowadzać oceny luk w zabezpieczeniach, testy penetracyjne, wyszukiwanie zagrożeń i audyty pod kątem zgodności z przepisami. SOC wykonuje następujące działania:

- Monitorowanie - SOC stale zbiera i analizuje dane dotyczące zabezpieczeń i zdarzeń w czasie rzeczywistym z całej infrastruktury IT organizacji. Obejmuje to dane z urządzeń lokalnych, chmury, systemy ICS i OT, systemy zdalne i urządzenia mobilne,
- Wykrywanie - Security Operations Center identyfikuj nietypowe wzorce, rozbieżności lub inne wskaźniki naruszenia bezpieczeństwa (IoC) na podstawie zgromadzonych danych. Potencjalne zagrożenia są kategoryzowane według poziomu istotności i oceniane w celu określenia, czy są to rzeczywiste zagrożenia, które powinny zaniepokoić organizację. Zautomatyzowane narzędzia do wykrywania mogą być również wykorzystywane do izolowania rzeczywistych zagrożeń,
- Reagowanie - po wykryciu SOC podejmuje natychmiastowe działania, aby reagować na incydenty i wdraża odpowiednie środki zaradcze w celu przeciwdziałania zagrożeniu. Po zneutralizowaniu incyduentu SOC przywraca sieć i systemy do stanu wyjściowego, a utracone dane są odzyskiwane,
- Analiza - SOC przeprowadza dogłębną analizę przyczyn incyduentu przy użyciu logów i innych informacji w celu określenia źródła zdarzenia. Może to pomóc w zapobieganiu podobnym incydentom w przyszłości [16].

Filary Security Operations Center

- Personel - wykwalifikowani analitycy, osoby reagujące na incydenty i łowcy zagrożeń zapewniają skuteczne monitorowanie i analizę,
- Technologia - zaawansowane narzędzia, takie jak systemy zarządzania informacjami i zdarzeniami zabezpieczeń (SIEM), pomagają w wykrywaniu incyduentów i zarządzaniu nimi,

- Procesy - ugruntowane procesy wykrywania incydentów, reagowania na nie i odzyskiwania mają kluczowe znaczenie dla utrzymania bezpiecznego środowiska [48].

1.2.2 Frameworki cyberbezpieczeństwa

1. NIST Cybersecurity Framework

Model bezpieczeństwa cybernetycznego NIST to dobrowolny zestaw zasad opartych na istniejących standardach, wytycznych i praktykach, które pomagają organizacjom zarządzać ryzykiem związanym z cyberbezpieczeństwem i zmniejszać je. National Institute of Standards and Technology, czyli amerykańska agencja federalna mająca funkcje analogiczną do Głównego Urzędu Miar stworzyła ramy, które zapewniają ujednoliconą terminologię do identyfikowania, zarządzania i komunikowania ryzyka cyberbezpieczeństwa wewnętrznym i zewnętrznym interesariuszom. Użycie tego frameworku jest dobrowolne, ale może znacznie poprawić stan bezpieczeństwa organizacji. U podstaw NIST Cybersecurity Framework leży zbiór standardów branżowych i najlepszych praktyk w zakresie zarządzania ryzykiem związanym z cyberbezpieczeństwem. Jego elastyczność umożliwia dostosowanie go do unikalnych potrzeb biznesowych, dzięki czemu nadaje się do wielu branż. Struktura składa się z trzech sekcji: Podstawy, Poziomy Implementacji i Profile. Każdy element ma kluczowe znaczenie dla dostarczenia strategii zarządzania cyberbezpieczeństwem [29].

Rdzeń struktury

Sercem modelu jest jego rdzeń ramowy, składający się z pięciu obszarów funkcjonalnych: identyfikacja, ochrona, wykrywanie, reagowanie i odzyskiwanie. Jest to zestaw pożądaných działań i wyników w zakresie cyberbezpieczeństwa zorganizowanych w kategorie i dostosowanych do odniesień informacyjnych. Funkcje te służą jako podstawowe filary organizowania i ustalania priorytetów działań związanych z cyberbezpieczeństwem w organizacji. Realizując te podstawowe funkcje, organizacje mogą ustanowić kompleksowy program cyberbezpieczeństwa dostosowany do ich konkretnych celów i tolerancji ryzyka. Rdzeń składa się z trzech części: Funkcji, Kategorii i Podkategorii. Rdzeń zawiera pięć funkcji wysokiego poziomu: Identify, Protect, Detect, Respond i Recover. Te pięć funkcji ma zastosowanie nie tylko do zarządzania ryzykiem w cyberprzestrzeni, ale także do zarządzania ryzykiem w ogóle [20,31].

- Identify - funkcja ta rozpoczyna się od zrozumienia ważnych zasobów, procesów i danych organizacji. Uzyskując jasny obraz tego, czego należy bronić, można opracować strategię skutecznego zarządzania ryzykiem związanym z cyberbezpieczeństwem. Ten krok obejmuje zarządzanie aktywami, ocenę ryzyka i analizę otoczenia biznesowego,
- Protect - koncentruje się na wdrażaniu zabezpieczeń w celu zapewnienia ochrony krytycznych usług. Obejmuje to kontrolę dostępu, bezpieczeństwo danych i szkolenia uświadamiające. Wzmacniając środki zapobiegawcze, organizacja może zmniejszyć prawdopodobieństwo wystąpienia incydentu cybernetycznego i zminimalizować potencjalne szkody,
- Detect - odpowiada za szybkie wykrywanie zdarzeń związanych z cyberatakami. Ma kluczowe znaczenie dla zminimalizowania ich wpływu. Funkcja Detect obejmuje zarówno procesy monitorowania, jak i wykrywania. Działania w funkcji wykrywania obejmują ciągłe monitorowanie, technologie wykrywania zagrożeń oraz analiza zdarzeń bezpieczeństwa,
- Respond - w przypadku incydentu cybernetycznego kluczowa jest szybka i skoordynowana reakcja. Funkcja Respond przedstawia kroki mające na celu powstrzymanie i złagodzenie skutków naruszenia zabezpieczeń. Wiąże się to z planowaniem reakcji na incydenty, strategiami komunikacyjnymi oraz aspektami prawnymi i finansowymi,
- Recover - funkcja ta kładzie nacisk na przywrócenie systemów i usług do normalnego działania po zdarzeniu związanym z cyberbezpieczeństwem. Opracowując niezawodny plan odzyskiwania, organizacje mogą zminimalizować przestoje i zapewnić ciągłość działania. Obejmuje to planowanie procesu odzyskiwania, wdrażanie usprawnień oraz komunikację [29].

Poziomy implementacji

Poziomy implementacji w ramach NIST CSF zapewniają organizacjom mechanizm do skutecznej oceny i komunikowania swojego stanu bezpieczeństwa cybernetycznego. Poziomy te, od poziomu 1 (częściowego) do poziomu 4 (adaptacyjnego), odzwierciedlają stopień, w jakim praktyki zarządzania ryzykiem cybernetycznym są zintegrowane z kulturą i operacjami organizacji.

Profile

Profile w NIST CSF umożliwiają organizacjom dostosowanie struktury zgodnie z ich unikatowymi priorytetami i wymaganiami dotyczącymi zarządzania ryzykiem. Profil reprezentuje pożądaný stan wyników cyberbezpieczeństwa w oparciu o cele biznesowe organizacji, apetyt na ryzyko i dostępne zasoby. Dostosowując swoje działania w zakresie cyberbezpieczeństwa do określonych wyników profilu, organizacje mogą dostosować swoje podejście, aby skutecznie reagować na najpilniejsze zagrożenia i luki w zabezpieczeniach [31].

2. CIS Controls

Środki kontroli bezpieczeństwa CIS (CIS Controls) to precyzyjnie określony, uporządkowany według priorytetów i uproszczony zestaw najlepszych praktyk, które pomagają wzmocnić poziom cyberbezpieczeństwa. Obecnie tysiące specjalistów ds. cyberbezpieczeństwa z całego świata korzysta z kontroli CIS lub przyczynia się do ich rozwoju poprzez proces wspólnej konsultacji społecznościowej [17].

Poziomy wdrożenia CIS Controls

Krytyczne środki kontroli bezpieczeństwa CIS to zestaw najlepszych praktyk, które zalecają, jak zwalczać najczęstsze zagrożenia cyberbezpieczeństwa. Mają one zastosowanie do wszystkich organizacji.

Są one podzielone na trzy grupy wdrożeniowe, z których każda kolejna warstwa stanowi rozwinięcie poprzedniej, dostosowane do możliwości organizacji:

- Podstawowy poziom wdrożenia (Basic Controls) - polega na zastosowaniu kontroli 1-6 i jest zalecana dla wszystkich organizacji. Te sześć mechanizmów kontroli można wdrożyć przy niewielkich nakładach zasobów, a mimo to zapewnia podstawowy poziom ochrony, z którego mogą korzystać nawet najmniejsze organizacje,
- Średni poziom wdrożenia (Foundational Controls) - polega na zastosowaniu kontroli z podstawowego poziomu wdrożenia oraz kontroli 7 - 16 i jest zalecana dla organizacji średniego szczebla, które mają więcej zasobów i specjalistów ds. cyberbezpieczeństwa,
- Zaawansowany poziom wdrożenia (Organizational Controls) - polega na zastosowaniu wszystkich mechanizmów kontroli bezpieczeństwa i jest przeznaczone dla dużych organizacji, które dysponują bogatymi zasobami i solidną wiedzą z

zakresu cyberbezpieczeństwa.

Te podstawowe zasady pozwalają specjalistom IT szybko i skutecznie reagować na rosnące problemy związane z bezpieczeństwem, co pozwala organizacjom zmniejszyć ryzyko związane z cyberbezpieczeństwem [18].

1.2.3 Standardy i regulacje w obszarze cyberbezpieczeństwa

1. ISO/IEC 27001

ISO (Międzynarodowa Organizacja Normalizacyjna) i IEC (Międzynarodowa Komisja Elektrotechniczna) tworzą wyspecjalizowany system światowej normalizacji. Organy krajowe, które są członkami ISO lub IEC, uczestniczą w opracowywaniu norm międzynarodowych za pośrednictwem komitetów technicznych ustanowionych przez odpowiednią organizację w celu zajmowania się określonymi dziedzinami działalności technicznej [4].

Standard ISO/IEC 27001 to lista wymagań, które organizacje muszą wdrożyć i utrzymywać, aby stworzyć solidny System Zarządzania Bezpieczeństwem Informacji (SZBI). Wymagania obejmują określenie zakresu systemu, zaangażowanie kierownictwa, polityki bezpieczeństwa, środki ochrony, audyty wewnętrzne, ocenę ryzyka oraz zarządzanie ryzykiem. Wymagania normy ISO 27001 obejmują wdrożenie odpowiedniego poziomu zasobów w celu ustanowienia, stosowania, zarządzania i ciągłego doskonalenia systemu zarządzania bezpieczeństwem informacji.

Lista wymagań ISO/IEC 27001 stanowi swoisty przewodnik do zbudowania kompleksowego i skutecznego systemu zarządzania bezpieczeństwem informacji oraz efektywnego programu audytów wewnętrznych. Jej realizacja pozwala skupić się na tym, co najważniejsze, czyli ochronie zasobów informacyjnych firmy i spełnianiu wymagań regulacyjnych [27].

Lista wymagań ISO 27001

Istnieje siedem wymagań (klauzul) ISO 27001 opisanych w klauzulach 4-10. Każda organizacja, która chce uzyskać zgodność z normą, musi je spełnić w odniesieniu do przyjętego zakresu swojego Systemu Zarządzania Bezpieczeństwem Informacji.

- Klauzula 4 (Kontekst organizacji) - określa kontekst, w jakim organizacja wdraża zgodność z ISO 27001. Zakres będzie zawierał informacje na temat

zidentyfikowanych zagrożeń i środków wdrożonych w celu ograniczenia nieautoryzowanego dostępu do poufnych informacji. Audytor korzysta również z tego zakresu podczas audytu ISO 27001, aby zrozumieć jakie ryzyka zostały zidentyfikowane i jakie środki bezpieczeństwa wprowadzono.

- Klauzula 5 (Przywództwo i zaangażowanie) - kierownictwo najwyższego szczebla i wyższego szczebla organizacji powinno wykazać się odpowiedzialnością i zaangażowaniem w przestrzeganie przepisów, uczestnicząc w programach szkoleniowych, przyczyniając się do realizacji celów związanych z bezpieczeństwem i zapewniając zespołowi zasoby wymagane do efektywnego wykonywania zadań.
- Klauzula 6 (Planowanie zarządzania ryzykiem) - norma ISO 27001 nie narzuca listy rzeczy, które każda organizacja powinna wdrożyć, aby uzyskać zgodność. Zamiast tego wymaga od organizacji dostosowania środków bezpieczeństwa i zasad unikatowych dla ich działalności, aby chronić SZBI przed incydentami bezpieczeństwa. Każda firma działa unikatowo. W związku z tym zagrożenia dla zachowania bezpieczeństwa, poufności i integralności danych wrażliwych znacznie się różnią.
- Klauzula 7 (Przydział zasobów) - norma ISO 27001 wymaga od organizacji alokacji zasobów w celu spełnienia wymagań normy ISO 27001. Niestety, większość organizacji błędnie rozumie tę klauzulę i ma trudności z przydzieleniem pełnoetatowych zasobów do wdrożenia i zarządzania ISO 27001. Ta klauzula stanowi, że wyznaczeni członkowie zespołu powinni odpowiadać za realizację wymagań dotyczących polityki i bezpieczeństwa w ramach SZBI, a także mieć dostęp do odpowiednich szkoleń i narzędzi wspierających ich działania.
- Klauzula 8 (Regularne oceny i oceny kontroli operacyjnych) - ISO 27001 wymaga od organizacji ciągłego monitorowania SZBI i oceny czy skuteczność wdrożonych kontroli i polityk jest skuteczna. Dzięki okresowym ocenom wydajności i ocenom ryzyka bezpieczeństwa oczekuje się, że organizacje będą ulepszać swoje systemy, aby konsekwentnie spełniać wymagania. Ponadto oceny wyników powinny być dokumentowane i przedstawiane jako dowody podczas audytu w celu wykazania zgodności.
- Klauzula 9 (Ocena wydajności) – Oceny te służą również jako doskonały przewodnik i ramy podczas przeprowadzania audytów wewnętrznych. Audytor zewnętrzny

wykorzystuje te oceny, aby sprawdzić, czy organizacja wdrożyła niezbędne mechanizmy kontroli i zasady, oraz czy są one zgodne z zakresem SZBI.

- Klauzula 10 (Plan doskonalenia i działań korygujących w przypadku niezgodności) -za każdym razem, gdy występuje niezgodność w SZBI, organizacja musi udokumentować ten przypadek wraz z przyczynami wyjaśniającymi, co spowodowało wystąpienie niezgodności i zastosowanymi środkami naprawczymi [27].

2. Rozporządzenie o Ochronie Danych Osobowych

Ogólne rozporządzenie o ochronie danych (RODO) to kompleksowe prawo o ochronie danych obejmujące Unię Europejską. Jest powszechnie uważane za jedno z najsurowszych przepisów dotyczących prywatności na świecie. RODO ujednolica przepisy dotyczące danych w UE i zapewnia osobom fizycznym kontrolę nad ich danymi osobowymi [30].

Celem ogólnego rozporządzenia o ochronie danych (RODO) jest ochrona danych osobowych w Internecie. W tym celu RODO wymaga, aby większość organizacji, które mają do czynienia z prywatnymi informacjami użytkowników, wyznaczyła pracownika odpowiedzialnego za nadzorowanie zgodności organizacji z RODO. Inspektor ochrony danych (IOD) jest punktem centralnym organizacji w zakresie RODO i musi posiadać ekspercką wiedzę na temat prawa i praktyk w zakresie ochrony danych [50].

Inspektor ochrony danych (IOD) odgrywa znaczącą rolę w przestrzeganiu tego rozporządzenia. Rola ta obejmuje nadzorowanie działań związanych z ochroną danych, udzielanie porad i działanie jako pośrednik między osobami, których dane dotyczą, a organami nadzorczymi.

Rola i obowiązki IOD

W art. 38 i art. 39 RODO [7] określono sześć głównych zadań przypisanych inspektorowi ochrony danych w europejskim prawie o ochronie danych.

- Monitorowanie zgodności z RODO i innymi przepisami o ochronie danych,
- Informowanie i doradzanie organizacji i jej pracownikom w zakresie ich obowiązków w zakresie przestrzegania RODO i innych przepisów o ochronie danych,
- Doradztwo w zakresie ocen skutków dla ochrony danych,
- Współpraca z organem nadzorczym i pełnienie funkcji punktu kontaktowego dla

organu nadzorczego w kwestiach związanych z przetwarzaniem danych,

- Zapewnienie ochrony praw osób, których dane dotyczą,
- Szkolenie personelu zaangażowanego w operacje przetwarzania danych.

Do obowiązków inspektora ochrony danych należy:

- Zapewnienie edukacji w zakresie zgodności,
- Prowadzenie szkoleń dla personelu,
- Przeprowadzanie audytów bezpieczeństwa,
- Zagwarantowanie stosowania środków ochrony danych.

Inżynierowie ochrony danych nadzorują strategię ochrony danych i jej wdrażanie, monitorują zgodność z przepisami o ochronie danych, udzielają fachowych wskazówek i ułatwiają zachowanie zgodności z przepisami i regulacjami dotyczącymi ochrony danych.

Istotnym aspektem roli IOD jest szkolenie personelu w zakresie ochrony danych, które gwarantuje, że pracownicy zaangażowani w przetwarzanie danych mają wiedzę na temat zgodności i najlepszych praktyk [36].

3. Dyrektywy NIS i NIS2

Dyrektywa NIS 1 jest jednym z rozwiązań legislacyjnych wprowadzonych przez UE w 2016 r., który spotkał się z pozytywnym oczekiwaniem. Dyrektywa ta miała na celu zwiększenie odporności cybernetycznej w całej Unii Europejskiej, zwłaszcza w sektorach krytycznych, takich jak opieka zdrowotna, energetyka, transport itp. W dyrektywie zaproponowano wspólne ramy, które ujednoliciły poziom cyberbezpieczeństwa między państwami członkowskimi.

Ramy te stanowią zbiór wiążących wymogów bezpieczeństwa dla operatorów infrastruktury. Operatorzy są zobligowani do wdrożenia odpowiednich środków w przypadku przyszłych i trwających cyberataków. Wymogi te obejmują zgłaszanie istotnych incydentów cyfrowych organom krajowym i współpracę z nimi w celu osiągnięcia wysokiego poziomu komunikacji między państwami członkowskimi a podmiotami objętymi zakresem dyrektywy. Ponadto w dyrektywie ustanowiono sankcje za nieprzestrzeganie przepisów, co sprawiło, że podmioty muszą działać zgodnie z dyrektywą [2,22].

Rozporządzenie NIS2 stanowi kontynuację i rozszerzenie wcześniejszej unijnej dyrektywy dotyczącej cyberbezpieczeństwa - **NIS**.

Dyrektywa NIS2 ma na celu zwiększenie bezpieczeństwa sieci i systemów

informacyjnych w UE poprzez zobowiązanie operatorów infrastruktury krytycznej i usług kluczowych obowiązkowi wdrożenia odpowiednich środków bezpieczeństwa i zgłaszania wszelkich incydentów odpowiednim organom. W porównaniu z NIS, NIS2 rozszerza swoje ogólnione wymagania dotyczące bezpieczeństwa oraz zakres objętych nim organizacji i sektorów, aby poprawić bezpieczeństwo łańcuchów dostaw, uprościć obowiązki sprawozdawcze oraz egzekwować bardziej rygorystyczne środki i sankcje w całej Europie.

Pierwotna dyrektywa w sprawie bezpieczeństwa sieci i informacji miała również na celu zwiększenie poziomu cyberbezpieczeństwa państw członkowskich UE, jednak jej wdrożenie napotkało wyzwania i skutkowało niespójnymi działaniami w całej Unii. W związku z rosnącymi zagrożeniami cybernetycznymi Komisja Europejska zaproponowała NIS2 jako uzupełnienie [45,49].

Nowe wymagania organizacyjne

Aby wzmocnić odporność Europy na obecne i przyszłe zagrożenia cybernetyczne, dyrektywa NIS2 wprowadza nowe wymagania i obowiązki dla organizacji w czterech nadrzędnych obszarach: zarządzanie ryzykiem, odpowiedzialność korporacyjna, obowiązki sprawozdawcze i ciągłość działania.

Zarządzanie ryzykiem

Aby zachować zgodność z nową dyrektywą, organizacje muszą podjąć środki w celu zminimalizowania zagrożeń cybernetycznych. Środki te obejmują zarządzanie incydentami, silniejsze bezpieczeństwo łańcucha dostaw, zwiększone bezpieczeństwo sieci, lepszą kontrolę dostępu i szyfrowanie.

Odpowiedzialność korporacyjna

NIS2 wymaga, aby kierownictwo korporacyjne nadzorowało, zatwierdzało i było szkolone w zakresie środków bezpieczeństwa cybernetycznego oraz przeciwdziałania zagrożeniom cybernetycznym. Naruszenia mogą skutkować karami dla kierownictwa, w tym odpowiedzialnością i potencjalnym tymczasowym zakazem pełnienia ról kierowniczych.

Obowiązki sprawozdawcze

Podmioty niezbędne i ważne muszą posiadać procedury umożliwiające szybkie zgłaszanie incydentów związanych z bezpieczeństwem, które mają istotny wpływ na świadczenie przez nie usług lub odbiorców. NIS2 ustala konkretne terminy powiadamiania, takie jak 24-godzinne "wczesne ostrzeżenie".

Ciągłość

Organizacje muszą zaplanować, w jaki sposób zamierzają zapewnić ciągłość działania w przypadku poważnych incydentów cybernetycznych. Plan ten powinien obejmować rozważania dotyczące odzyskiwania systemu, procedur awaryjnych i ustanowienia zespołu reagowania kryzysowego.

Minimalne środki

Oprócz czterech nadrzędnych obszarów wymagań, NIS2 wymaga, aby kluczowe i ważne podmioty wdrożyły podstawowe środki bezpieczeństwa w celu przeciwdziałania określonym formom prawdopodobnych zagrożeń cybernetycznych. Należą do nich:

- Oceny ryzyka i polityki bezpieczeństwa dla systemów informatycznych,
- Polityki i procedury oceny skuteczności środków bezpieczeństwa,
- Zasady i procedury dotyczące stosowania kryptografii oraz w stosownych przypadkach, szyfrowania,
- Plan postępowania w przypadku incydentów związanych z bezpieczeństwem,
- Bezpieczeństwo związane z zakupem systemów oraz rozwojem i eksploatacją systemów. Oznacza to posiadanie zasad postępowania i zgłaszania luk w zabezpieczeniach,
- Szkolenie z zakresu cyberbezpieczeństwa
- Procedury bezpieczeństwa dla pracowników mających dostęp do wrażliwych lub ważnych danych, w tym zasady dostępu do danych. Organizacje, których dotyczy problem, muszą również mieć przegląd wszystkich istotnych zasobów i upewnić się, że są one właściwie wykorzystywane i obsługiwane,
- Plan zarządzania operacjami biznesowymi w trakcie i po zdarzeniu związanym z bezpieczeństwem. Oznacza to, że kopie zapasowe muszą być aktualne. Musi również istnieć plan zapewnienia dostępu do systemów informatycznych i ich funkcji operacyjnych w trakcie i po incydencie bezpieczeństwa,

- Korzystanie z uwierzytelniania wieloskładnikowego, rozwiązań ciągłego uwierzytelniania, szyfrowania głosowego, wideo i tekstowego oraz szyfrowanej wewnętrznej komunikacji alarmowej,
- Bezpieczeństwo w łańcuchach dostaw i relacjach między firmą a bezpośrednim dostawcą. Firmy muszą wybrać środki bezpieczeństwa, które pasują do luk w zabezpieczeniach każdego bezpośredniego dostawcy. Następnie firmy muszą ocenić ogólny poziom bezpieczeństwa dla wszystkich dostawców [28].

2 Charakterystyka macierzy MITRE ATT&CK

Macierz MITRE ATT&CK to globalna baza wiedzy o taktykach i technikach cyberprzestępców oparta na rzeczywistych obserwacjach. Baza wiedzy ATT&CK jest wykorzystywana jako podstawa do opracowywania konkretnych modeli i metodologii obron przed cyberzagrożeniami [9,26].

Ramy te mają swoje korzenie w pracach, które MITRE wykonywało dla organizacji sponsorującej. Firma zwróciła się do MITRE z prośbą o pomoc w poprawie zdolności do wykrywania przeciwników w środowisku IT, co, jak zdał sobie sprawę zespół MITRE, wymagałoby zrozumienia, jak przeciwnicy zachowują się po naruszeniu granic przedsiębiorstwa.

Od samego początku MITRE ATT&CK było tworzone przez praktyków dla praktyków. Z tego powodu ramy zawsze były wysoce dostępne i szybko zyskały silne poparcie oddolne co przyczyniło się do jego popularności i powszechnej akceptacji [6,25].

MITRE ATT&CK jest fundamentem dla różnych aplikacji cyberbezpieczeństwa, oferując ustrukturyzowane podejście do zrozumienia i łagodzenia zachowań przeciwników. Zrozumienie i wykorzystanie podstawowych przypadków użycia MITRE ATT&CK ma kluczowe znaczenie dla każdej organizacji, która chce wzmocnić swoją obronę przed coraz bardziej wyrafinowanymi atakami. Zagłębiając się w te przypadki użycia, specjaliści ds. cyberbezpieczeństwa mogą wykorzystać ustrukturyzowaną wiedzę ATT&CK do lepszego przewidywania, wykrywania i przeciwdziałania wrogim działaniom [11,42].

2.1 Rodzaje macierzy ATT&CK

MITRE ATT&CK organizuje taktyki i techniki (oraz podtechniki) przeciwnika w macierze. Każda matryca zawiera taktyki i techniki odpowiadające atakom na określone domeny.

Macierz Enterprise

Macierz Enterprise zawiera wszystkie techniki przeciwników wykorzystywane w atakach na infrastrukturę przedsiębiorstwa. Macierz ta zawiera podmacierze dla platform Windows, MacOS i Linux, a także infrastrukturę sieciową, platformy chmurowe i technologie kontenerowe. Zawiera również matrycę technik przygotowawczych stosowanych przed atakiem.

Mobilna matryca

Mobile Matrix obejmuje techniki wykorzystywane w bezpośrednich atakach na urządzenia mobilne oraz w sieciowych atakach mobilnych, które nie wymagają dostępu do urządzenia mobilnego. Ta macierz zawiera podmacierze dla platform mobilnych iOS i Android.

Macierz ICS

Macierz ICS obejmuje techniki wykorzystywane w atakach na przemysłowe systemy sterowania, a w szczególności maszyny, urządzenia, czujniki i sieci wykorzystywane do sterowania lub automatyzacji operacji w fabrykach, przedsiębiorstwach użyteczności publicznej, systemach transportowych i innych krytycznych dostawcach usług [46].

2.2 Kluczowe elementy macierzy ATT&CK

Taktyki

Przeciwnicy stosują taktykę, aby osiągnąć określone cele, takie jak początkowy dostęp, wykonanie lub eksfiltracja. Każda taktyka reprezentuje cel strategiczny, kierując wyborem technik i procedur. Zespoły ds. bezpieczeństwa analizują te taktyki, aby przewidywać zagrożenia, przerywać łańcuchy ataków i wzmacniać obronę, zapewniając proaktywną postawę wobec ewoluujących zagrożeń cybernetycznych.

Techniki

Przeciwnicy wykorzystują rzucanie poświadczeń, ruch boczny i szyfrowanie danych, aby osiągnąć swoje cele. Zespoły ds. bezpieczeństwa analizują te techniki, aby zidentyfikować wzorce, opracować środki zaradcze i zwiększyć możliwości wykrywania. Rozumiejąc zawiłości każdej techniki, obrońcy mogą przewidywać ruchy atakującego i skutecznie łagodzić potencjalne zagrożenia.

Podtechniki

Przeciwnicy udoskonalają techniki do technik podrzędnych, takich jak spear-phishing za pośrednictwem usługi lub wstrzykiwania procesu w celu trwałości. Te działania pozwalają na bardziej precyzyjne strategie wykrywania i reagowania. Zespoły ds. bezpieczeństwa muszą przeanalizować te podtechniki, aby odkryć ukryte wzorce, zwiększając swoją zdolność do udaremniania wyrafinowanych ataków i ochrony krytycznych zasobów.

Procedury

Zespoły ds. bezpieczeństwa skrupulatnie dokumentują kroki przeciwników, od początkowego dostępu po eksfiltrację danych. Tworzą strategie ograniczania ryzyka oraz szczegółowe opisy przedstawiające metody wykrywania i reagowania. Procedury te umożliwiają szybką identyfikację zagrożeń, zapewniają terminowe i skuteczne środki zaradcze oraz wzmacniają obronę organizacji przed ewoluującymi cyberzagrożeniami [3,42].

2.3 Technik ataków opisane w MITRE ATT&CK

Najczęściej obserwowane techniki często wykorzystują legalne narzędzia systemowe, co umożliwia atakującym wtopienie się w zwykłe działania użytkownika i uniknięcie wykrycia. Zrozumienie tych technik ma kluczowe znaczenie dla opracowania skutecznych strategii obronnych.

Większość z piętnastu najczęściej używanych technik wykorzystuje legalne narzędzia systemowe. Podkreśla to ideę, że przeciwnicy próbują wyglądać jak prawowici użytkownicy.

1. T1059 - Command and Scripting Interpreter (Interpreter poleceń i skryptów)

Większość platform ma wbudowane interfejsy wiersza poleceń lub funkcje skryptów, dzięki czemu przeciwnicy mogą używać ich do wykonywania dowolnych poleceń, skryptów lub plików binarnych.

Ogólnie rzecz biorąc, T1059 jest najbardziej używaną techniką. Zdecydowana większość obserwacji jej występowania pochodzi z T1059.001 - PowerShell. Nie jest to zaskakujące, ponieważ jest to powszechne narzędzie używane przez atakujących ze względu na jego wszechobecność, wszechstronność i zdolność do ukrywania aktywności. Drugą najczęściej obserwowaną podtechniką jest T1059.003 - Windows Command Shell, co też nie dziwi ze względu na wszechobecność wiersza poleceń w środowiskach Windows. Następujące **podtechniki** stanowią mniej niż 5% obserwacji T1059:

- T1059.002 - AppleScript,
- T1059.004 - Unix Shell,
- T1059.005 - Visual Basic,
- T1059.006 - Python,
- T1059.007 - JavaScript.

Zapobieganie:

W celu zniwelowania ryzyka związanego z występowaniem tej techniki zalecane jest:

- Ograniczyć uprawnienia użytkowników do minimum,
- Blokować zdalny dostęp do interpreterów dla kont bez wyraźnej potrzeby dostępu do nich,
- Wyłączyć lub ograniczyć możliwość uruchamiania interpreterów takich jak powershell.exe, cmd.exe, python.exe na stacjach i serwerach, gdzie nie są potrzebne,
- Stosować listy dozwolonych aplikacji,
- Monitorować i kontrolować zmiany w konfiguracji systemów, które mogłyby otworzyć dostęp do interpreterów lub umożliwić ich nadużycie.

Wykrywanie:

Efektywne wykrywanie użycia techniki T1059 można osiągnąć poprzez:

- Analizę długości i struktury uruchamianych poleceń,
- Monitorowanie uruchomień interpreterów w kontekście nietypowych procesów lub nietypowego czasu aktywności,
- Rejestrowanie i kontrolę zdalnych sesji PowerShell i innych interpreterów,
- Wykrywanie anomalii w relacjach procesów,
- Łączenie zdarzeń związanych z interpreterami z innymi podejrzanymi działaniami [39].

2. T1027 - Obfuscated Files or Information (Zaciemnione pliki lub informacje)

Atakujący mogą szyfrować, kodować lub w inny sposób „zaciemniać” dane, pliki, skrypty lub polecenia, aby uniknąć wykrycia. Osoby atakujące mogą używać T1027 do kompresji, archiwizowania, szyfrowania lub dzielenia ładunków na wiele plików.

Większość obserwacji T1027 nie obejmowała podtechnik. Najczęściej obserwowaną podtechniką tego ataku jest T1027.002 - Software Packing. Przeciwnicy używają tej podtechniki, aby uniknąć wykrycia kodu, szczególnie w przypadku wykryć opartych na sygnaturach.

Inne podtechniki:

- T1027.001 - Binary Padding,
- T1027.003 - Steganography,
- T1027.004 - Compile After Delivery,

- T1027.005 - Indicator Removal from Tools,
- T1027.006 - HTML Smuggling.

Zapobieganie:

Aby ograniczyć ryzyko wykorzystania techniki T1027, rekomenduje się:

- Utrzymywanie spójnej i bezpiecznej konfiguracji systemów,
- Regularne stosowanie łatek i aktualizacji systemu,
- Wdrażanie rozwiązań antywirusowych i antymalware z funkcją wykrywania zaawansowanych technik zaciemniania oraz pakowania oprogramowania,
- Monitorowanie integralności oprogramowania i plików systemowych,
- Konfigurowanie i kontrolowanie ustawień zabezpieczeń systemu, tak by ograniczyć możliwość uruchamiania nieznanych lub niezweryfikowanych plików i skryptów,

Wykrywanie:

Detekcja wykorzystania techniki T1027 powinna opierać się na:

- Monitorowaniu zmian w plikach binarnych,
- Analizie logów systemowych i zdarzeń,
- Wykrywaniu aktywności narzędzi i procesów,
- Śledzeniu nieautoryzowanych zmian w plikach konfiguracyjnych i systemowych, które mogą wskazywać na przygotowania do ukrywania ładunków,
- Korelacji wykrytych zdarzeń z innymi sygnałami wskazującymi na potencjalny atak [39].

3. T1105 - Ingress Tool Transfer (Transfer narzędzi)

Przeciwnicy mogą przenosić narzędzia lub inne pliki z systemu dowodzenia i kontroli do naruszonego środowiska. Mogą przeprowadzać ataki typu *living-of-the-land* za pomocą natywnych narzędzi lub instalatorów i menedżerów pakietów dostępnych w systemach Windows, Linux i MacOS w celu pobrania plików. Atakujący mogą również pobierać pliki za pośrednictwem usług opartych na chmurze, takich jak Dropbox lub OneDrive, które synchronizują się z docelowymi systemami.

Zapobieganie

Aby ograniczyć ryzyko wykorzystania tej techniki, należy:

- Wprowadzić polityki kontroli przepływu informacji, które ograniczą nieautoryzowany transfer plików,
- Stosować ciągłe monitorowanie systemów i sieci w celu wykrywania nietypowych operacji transferu plików,
- Utrzymywać bezpieczną i spójną konfigurację systemów, aby zapobiec nieautoryzowanym zmianom,
- Ograniczyć funkcjonalność systemów do niezbędnego minimum, wyłączając zbędne usługi i funkcje, które mogłyby służyć do transferu plików,
- Zabezpieczyć granice sieci i systemów poprzez stosowanie zapór ogniowych i segmentacji sieci,
- Stosować skuteczne mechanizmy ochrony przed złośliwym oprogramowaniem,
- Regularnie monitorować systemy pod kątem podejrzanych działań i anomalii związanych z transferem plików.

Wykrywanie

Skuteczne wykrywanie tej techniki polega na:

- Analizie podejrzanych argumentów uruchamianych procesów,
- Monitorowaniu pobierania plików przy użyciu narzędzi takich jak BITSAdmin lub CertUtil,
- Wykrywaniu nietypowych działań związanych z pobieraniem plików,
- Łączeniu informacji z różnych źródeł, aby wykryć skoordynowane działania transferu narzędzi w systemie [39].

4. T1112 - Modify Registry (Modyfikacja rejestru)

Atakujący mogą używać wbudowanych narzędzi wiersza poleceń lub interfejsu API Win32 do interakcji z rejestrem systemu Windows w celu ukrycia informacji o konfiguracji, usunięcia informacji lub w ramach innych technik związanych wykonaniem kodu i utrzymaniem dostępu. Określone obszary rejestru zależą od uprawnień dostępu do konta, co może wymagać od przeciwników uzyskania uprawnień do modyfikowania na poziomie administratora. Rejestr systemu Windows jest istotnym składnikiem systemu Windows, co czyni go atrakcyjnym narzędziem do wykorzystania przez przeciwników.

Zapobieganie

Aby ograniczyć możliwość wykorzystania tej techniki, zaleca się:

- Stosowanie zasady minimalnych uprawnień (*Least Privilege*),
- Ograniczenie funkcjonalności systemu (*Least Functionality*), wyłączając lub blokując narzędzia i usługi, które umożliwiają modyfikację rejestru, jeśli nie są niezbędne.

Wykrywanie

Skuteczne wykrywanie techniki modyfikacji rejestru opiera się na monitorowaniu następujących zjawisk:

- Analiza różnic w uruchamianiu programów (autoru n differences),
- Wykrywanie wywołań narzędzi takich jak **reg.exe** z poziomu powłoki wiersza poleceń,
- Monitorowanie szybkiego wykonania serii podejrzanych poleceń, które mogą świadczyć o skryptowych modyfikacjach rejestru,
- Wykrywanie zdalnej edycji rejestru,
- Identyfikacja rzadkich lub nietypowych linii poleceń typowych dla technik Living off the Land Binaries and Scripts (LOLbins/LOLBAS),
- Monitorowanie specyficznych modyfikacji w kluczach rejestru [39].

5. T1070 - Indicator Removal (Usuwanie wskaźników)

Atakujący mogą tworzyć różne wskaźniki, charakterystyczne dla danej platformy, które mogą ujawnić ich obecność lub działanie w systemie. W celu ukrycia śladów intruzi mogą próbować usuwać lub modyfikować je, aby ukryć wszelkie dowody ich obecności lub utrudnić obronę. Ponieważ wskaźniki te są wykorzystywane podczas działań kryminalistycznych i reagowania na incydenty, ich usunięcie może utrudnić dochodzenie lub wydłużyć proces wykrywania włamań.

Podtechniki T1070:

- T1070.001 - Clear Windows Event Logs,
- T1070.003 - Clear Command History,
- T1070.004 - File Deletion,
- T1070.006 - Timestamp.

Zapobieganie

Aby ograniczyć skuteczność usuwania śladów, należy stosować kompleksowe mechanizmy bezpieczeństwa, takie jak:

- Kontrola i zarządzanie dostępem do kont,
- Monitorowanie systemu oraz dzienników zdarzeń,
- Ustawienia ochrony integralności plików i konfiguracji systemu,
- Regularne tworzenie kopii zapasowych i zarządzanie nimi.

Wykrywanie

Technikę wykrywa się przez analizę nietypowych działań w systemie, takich jak np.:

- Aktywność wskazująca na czyszczenie dzienników zdarzeń,
- Usuwanie historii poleceń w konsoli PowerShell [39].

6. T1204 - User Execution (Wykonanie przez użytkownika)

Atakujący może oczekiwać, że użytkownik wykona czynność, która spowoduje uruchomienie aplikacji. Typowymi przykładami egzekucji przez użytkownika są ataki phishingowe i socjotechniczne. Przeciwnicy mogą wysłać złośliwy link, plik lub obraz, aby użytkownik mógł go otworzyć lub nakłonić użytkowników, aby włączyli oprogramowanie zdalnego dostępu w celu zapewnienia im bezpośredniej kontroli nad systemem.

Zapobieganie

Aby ograniczyć skuteczność tej techniki, organizacje powinny wdrożyć środki zapobiegawcze, takie jak:

- Konfiguracja systemów ograniczająca możliwość uruchamiania nieautoryzowanego oprogramowania,
- Mechanizmy ochrony przed złośliwym kodem, w tym analiza otwieranych załączników i odnośników w odizolowanym środowisku,
- Ograniczanie funkcjonalności systemów do niezbędnego minimum,
- Systemy wykrywania i blokowania spamu oraz mechanizmy walidacji danych wejściowych,
- Regularne aktualizowanie systemów i oprogramowania,
- Stałe monitorowanie aktywności w systemie oraz edukacja użytkowników w zakresie rozpoznawania prób phishingu.

Wykrywanie

Wykrycie tej techniki opiera się na obserwacji nietypowego zachowania systemu po wykonaniu potencjalnie szkodliwego pliku lub łącza, np.:

- Tworzenie lub modyfikowanie plików w katalogach systemowych przez skrypty wsadowe,
- Uruchomienie oprogramowania znanego z użycia w atakach [39].

7. T1564 - Hide Artifacts (Ukrywanie artefaktów)

Przeciwnicy mogą próbować ukryć artefakty, takie jak pliki, konta użytkowników lub katalogi, aby uniknąć wykrycia. Mogą wykorzystywać funkcje systemu operacyjnego do ukrywania artefaktów lub używać wirtualizacji do tworzenia izolowanych regionów obliczeniowych, aby uniknąć typowych narzędzi i konfiguracji bezpieczeństwa.

Najczęściej obserwowaną podtechniką używaną w tej technice jest T1564.003 - Hidden Window. Przeciwnicy mogą użyć tej techniki, aby ukryć swoje działania przed użytkownikiem. Drugą najczęściej obserwowaną techniką podrzędną jest T1564.004 - NTFS File Attributes. Przeciwnicy mogą wykorzystywać metadane atrybutu pliku do ukrywania złośliwych danych.

Inne podtechnik:

- T1564.001 - Hidden Files and Directories,
- T1564.002 - Hidden Users,
- T1564.008 - Email Hiding Rules.

Zapobieganie

Aby ograniczyć możliwość ukrywania artefaktów przez napastników, należy:

- Konfigurować systemy tak, by nie dopuszczały do działania nieautoryzowanych funkcji,
- Regularnie monitorować zmiany w konfiguracji systemowej i ustawieniach uprawnień,
- Stosować mechanizmy walidacji danych wejściowych,
- Wdrażać systemy integralności oprogramowania, które wykrywają manipulacje atrybutami plików,
- Ograniczać uprawnienia użytkowników tylko do niezbędnego minimum,

- Monitorować anomalie związane z regułami pocztowymi oraz ukrytymi kontami użytkowników.

Wykrywanie

Wykrywanie ukrywania artefaktów może wymagać:

- Analizy plików systemowych pod kątem ukrytych atrybutów,
- Monitorowania procesów, które tworzą okna aplikacji niewidoczne dla użytkownika,
- Rejestracji i analizy zmian w kontach użytkowników i uprawnieniach,
- Weryfikacji nietypowych reguł pocztowych, które mogą przekierowywać lub ukrywać wiadomości e-mail [39].

8. T1055 - Process Injection

Atakujący mogą wstrzykiwać kod do procesów, aby uzyskać dostęp do pamięci procesu lub podmienia uprawnień. Wykonując wstrzykiwanie procesów, przeciwnicy są w stanie ukryć się w legalnych procesach, aby uniknąć zabezpieczeń opartych na procesach.

Podtechniki:

- T1055.001 - Dynamic-link Library Injection,
- T1055.002 - Portable Executable Injection,
- T1055.003 - Thread Execution Hijacking,
- T1055.012 - Process Hollowing.

Zapobieganie

Aby ograniczyć możliwość wykorzystania wstrzykiwania do procesu, zaleca się:

- Restrykcyjne zarządzanie kontami użytkowników, w tym ograniczenie liczby kont z uprawnieniami administracyjnymi,
- Wdrożenie zasady separacji obowiązków - użytkownicy i procesy nie powinni mieć zbędnych uprawnień ani możliwości ingerowania w inne procesy,
- Stosowanie zasady najmniejszych uprawnień (Least Privilege),
- Ograniczanie możliwości dynamicznych modyfikacji procesów i ustawień systemowych,
- Ustanowienie granic bezpieczeństwa między procesami i blokowanie niezaufanego kodu,
- Stosowanie oprogramowania antywirusowego i systemów ochrony przed złośliwym

kodem,

- Regularne aktualizowanie systemów i łatanie znanych podatności,
- Wdrożenie ciągłego monitorowania systemów pod kątem nieautoryzowanych modyfikacji w pamięci procesów.

Wykrywanie

W celu wykrycia prób wstrzykiwania kodu do procesów należy:

- Monitorować próby ładowania bibliotek DLL w nietypowych kontekstach,
- Wykrywać anomalie związane z uruchamianiem procesów i tworzeniem wątków w kontekście innych, legalnych procesów,
- Analizować różnice w strukturze plików wykonywalnych w pamięci w porównaniu do ich wersji na dysku,
- Korzystać z reguł detekcyjnych opartych na technikach analizy behawioralnej i heurystycznej [39].

9. T1003 - OS Credential Dumping (Zrzut poświadczeń systemu operacyjnego)

Atakujący mogą używać przechowywanych lokalnie danych uwierzytelniających w celu uzyskania loginu do konta i materiałów uwierzytelniających, dzięki którym uzyskają dostęp do zastrzeżonych informacji lub przeprowadzenia ruchu bocznego.

Podtechniki:

- T1003.001 - LSASS Memory,
- T1003.002 - Security Account Manager,
- T1003.003 - NTDS,
- T1003.004 - LSA Secrets,
- T1003.005 - Cached Domain Credentials,
- T1003.006 - DCSync,
- T1003.007 - Proc Filesystem,
- T1003.008 - /etc/passwd and /etc/shadow.

Zapobieganie

Aby ograniczyć skuteczność zrzutu poświadczeń, zaleca się wdrożenie następujących działań:

- Ograniczenie uprawnień użytkowników,
- Segmentacja systemów - rozdzielenie ról i zadań systemów w sieci,
- Ochrona procesów i pamięci,
- Silne polityki haseł,
- Wyłączenie niepotrzebnych usług,
- Zabezpieczenie plików systemowych,

Wykrywanie

Detekcja zrzutu poświadczeń może być realizowana poprzez analizę zachowań systemowych, logów oraz monitorowanie anomalii w dostępie do krytycznych zasobów. Szczególne znaczenie mają następujące obserwacje:

- Monitorowanie procesu LSASS - wykrywanie prób dostępu do pamięci procesu lsass.exe, tworzenia zrzutów pamięci lub iniekcji kodu do tego procesu,
- Nieautoryzowane użycie narzędzi administracyjnych pozyskiwania poświadczeń,
- Podejrzane operacje na plikach systemowych,
- Analiza logów zabezpieczeń - wykrywanie nietypowych logowań, aktywności administracyjnej poza godzinami pracy, nagłych eskalacji uprawnień lub uruchamiania podejrzanych procesów,
- Korelacja zachowań użytkowników i hostów - identyfikacja nietypowych schematów zachowań użytkowników i odchylenia od normy [39].

10. T1021 - Remote Services (Usługi zdalne)

Atakujący mogą używać usług zdalnych w połączeniu z ważnymi kontami w celu wykorzystania usług akceptujących połączenia zdalne, takich jak RDP, telnet, SSH lub VNC. Niektóre platformy mają również natywne narzędzia do zdalnego zarządzania, takie jak Apple Remote Desktop w systemie MacOS, których przeciwnicy również mogą użyć do zdalnego wykonywania kodu. Jeśli serwery i stacje robocze są połączone z domeną, atakujący mogą użyć jednego zestawu danych logowania, aby poruszać się po serwerach i uzyskiwać dostęp do innych systemów.

Najczęściej obserwowaną podtechniką jest T1021.006 - Windows Remote Management.

Inne podtechniki:

- T1021.001 - Remote Desktop Protocol,
- T1021.002 - SMB/Windows Admin Shares,
- T1021.003 - Distributed Component Object Model,
- T1021.004 - SSH,

Zapobieganie

Aby ograniczyć skuteczność techniki T1021, można zastosować następujące zasady:

- Ustanowienie zasad silnego uwierzytelniania (dla wszystkich kont ze zdalnym dostępem),
- Ograniczenie do minimum liczby kont z uprawnieniami dostępu zdalnego oraz wdrożenie zasady najmniejszych możliwych uprawnień,
- Zastosowanie zapór sieciowych i reguł dostępu ograniczających ruch RDP, SSH i innych protokołów,
- Wyłączenie nieużywanych usług zdalnych na wszystkich urządzeniach,
- Wdrożenie kontroli dostępu do usług zdalnych,
- Regularne aktualizowanie oprogramowania,

Wykrywanie

Efektywne wykrywanie użycia techniki T1021 można osiągnąć poprzez:

- Rejestrowanie i analizowanie prób logowania do usług zdalnych,
- Monitorowanie użycia narzędzi systemowych umożliwiających zdalne połączenia,
- Wykrywanie nieautoryzowanego przesyłu danych między systemami w sieci LAN lub do/z zewnętrznych adresów IP,
- Wykrywanie prób nadużycia istniejących kont użytkowników w celu logowania do innych systemów,
- Analiza logów zabezpieczeń systemów operacyjnych i zapór sieciowych w poszukiwaniu anomalii i prób połączeń z użyciem RDP, SMB, SSH itp. [39].

11. T1486 - Data Encrypted for Impact (Szyfrowanie danych)

Atakujący mogą szyfrować dane w zaatakowanych docelowych, aby zakłócić dostępność zasobów systemowych i sieciowych. Tego typu atak utrudnia lub nawet

uniemożliwia użytkownikom lub usługom dostęp do plików kluczowych.

Zapobieganie

Aby zapobiec skutecznemu wykorzystaniu techniki T1486, zaleca się wdrożenie poniższych działań prewencyjnych:

- Ograniczenie uprawnień użytkowników do minimum,
- Egzekwowanie zasad kontroli dostępu i segmentacji systemów krytycznych,
- Wdrożenie polityki tworzenia regularnych kopii zapasowych,
- Przechowywanie kopii zapasowych w lokalizacjach izolowanych od systemów,
- Zapewnienie alternatywnych lokalizacji przechowywania i przetwarzania danych w razie awarii,
- Stosowanie rozwiązań antywirusowych i EDR wykrywających i blokujących próby szyfrowania danych oraz znane ransomware,
- Egzekwowanie spójnych polityk integralności oprogramowania i firmware.

Wykrywanie

W celu skutecznego wykrycia techniki T1486, organizacje powinny wdrożyć następujące metody analizy:

- Monitorowanie aktywności plików pod kątem masowych operacji szyfrowania w krótkim czasie, co może wskazywać na rozpoczęcie ataku ransomware,
- Wykrywanie anomalii w zachowaniu procesów użytkowników, np. nagłego dostępu do wielu plików lub katalogów, które wcześniej nie były używane,
- Analiza logów systemowych w poszukiwaniu aktywności związanej z edytowaniem lub usuwaniem kopii zapasowych,
- Monitorowanie uruchamiania procesów skojarzonych z narzędziami do szyfrowania lub znanych pakietów ransomware,
- Wykrywanie modyfikacji uprawnień plików i katalogów, szczególnie jeśli są one wykonywane przez nietypowych użytkowników,
- Korzystanie z honeypotów plikowych, które generują alarmy w przypadku próby ich modyfikacji przez nieautoryzowane procesy [39].

12. T1091 - Replication Through Removable Media (Replikacja za pomocą nośników wymiennych)

Atakujący mogą uzyskać początkowy dostęp do systemów, modyfikując systemy formatujące nośniki wymienne, modyfikując oprogramowanie układowe nośnika lub kopiując złośliwe oprogramowanie na nośniki wymienne i wykorzystując funkcje automatycznego uruchamiania w systemie. Ruch boczny może wystąpić, gdy przechowywane pliki wykonywalne są modyfikowane lub zmieniana jest ich nazwa, aby wyglądały na uzasadnione. Urządzenia mobilne mogą być również celem infekowania i rozprzestrzeniania złośliwego oprogramowania po podłączeniu do systemu.

Zapobieganie

Aby zapobiec wykorzystaniu tej techniki, należy:

- Wprowadzić kontrolę dostępu, która ograniczy możliwość wykonywania nieautoryzowanych operacji na nośnikach wymiennych,
- Stosować zasadę najmniejszych uprawnień,
- Utrzymywać i egzekwować bezpieczną konfigurację systemów, zapobiegając wykorzystaniu funkcji automatycznego uruchamiania,
- Regularnie inwentaryzować komponenty systemowe, w tym nośniki USB i inne urządzenia peryferyjne,
- Ograniczyć lub całkowicie zablokować użycie nośników wymiennych w środowiskach o wysokim poziomie ryzyka,
- Wdrożyć procesy monitorowania podatności i skanowania nośników pod kątem znanych luk i zagrożeń,
- Kontrolować dostęp do portów USB oraz innych interfejsów wejścia i wyjścia, aby zapobiec nieautoryzowanemu podłączaniu urządzeń,
- Stosować skuteczne oprogramowanie antywirusowe, zdolne do wykrywania i blokowania złośliwego kodu na nośnikach wymiennych,
- Monitorować systemy w czasie rzeczywistym pod kątem podejrzanych działań związanych z podłączaniem nośników lub uruchamianiem plików z ich zawartości.

Wykrywanie

W przypadku tej techniki nie zostały zdefiniowane konkretne reguły detekcji CAR [39].

13. T1082 - System Information Discovery (Odkrywanie informacji o systemie)

Atakujący może zbierać informacje o systemie operacyjnym i sprzęcie do lepszego kształtowania złośliwego kodu i dalszych etapów ataków. Ataki te mogą wykorzystywać natywne narzędzia, takie jak systeminfo w systemie Windows, narzędzie konfiguracji systemu w systemie MacOS lub interfejs wiersza poleceń urządzenia sieciowego, w celu zebrania szczegółowych informacji o systemie. Przeciwnicy mogą korzystać z tych informacji, w połączeniu z innymi formami zbierania informacji, aby uniknąć wykrycia i przeprowadzić bardziej ukierunkowane ataki.

Zapobieganie

Organizacje mogą zastosować środki pośrednie, takie jak:

- Ograniczenie możliwości uruchamiania narzędzi systemowych przez użytkowników bez uzasadnionej potrzeby,
- Monitorowanie uprawnień kont i stosowanie zasady najmniejszych przywilejów,
- Segmentacja sieci i stosowanie list kontroli dostępu,
- Konfiguracja hostów tak, aby ograniczać wyświetlanie lub udostępnianie szczegółowych informacji systemowych przez interfejsy CLI i API,
- Blokowanie lub monitorowanie podejrzanych skryptów zawierających ciągi charakterystyczne dla działań odkrywczych.

Wykrywanie

Działania związane z techniką T1082 można wykrywać za pomocą reguł analizy zachowania, z uwzględnieniem następujących wskaźników:

- Wykrywanie szybkiego wykonania szeregu podejrzanych poleceń systemowych,
- Monitorowanie poleceń uruchamianych z poziomu użytkownika, które normalnie wymagają uprawnień administracyjnych lub rzadko są stosowane w codziennej pracy,
- Uruchomienie poleceń odkrywczych bezpośrednio po dostaniu się do systemu może świadczyć o działaniach atakującego po uzyskaniu dostępu [39].

14. T1047 - Windows Management Instrumentation

Instrumentacja zarządzania Windows (WMI) to natywna funkcja administracyjna systemu Windows służąca do uzyskiwania dostępu do składników systemu Windows.

Atakujący mogą nadużywać usługi WMI do interakcji z systemami lokalnymi w celu wykonywania złośliwych poleceń i kodów.

Zapobieganie

Aby ograniczyć skuteczność techniki T1047, zaleca się wdrożenie następujących środków:

- Wyłączenie lub ograniczenie dostępu do WMI dla użytkowników, którzy nie wymagają tej funkcji w codziennej pracy,
- Zastosowanie zasady najmniejszych uprawnień,
- Monitorowanie i kontrola dostępu do narzędzi takich jak wmic.exe, PowerShell, czy interfejsy COM/WMI,
- Wdrożenie silnych polityk uwierzytelniania oraz kontroli sesji zdalnych,
- Regularna aktualizacja systemów oraz aplikacji w celu eliminacji znanych zagrożeń związanych z WMI,
- Ograniczenie możliwości wykonywania zdalnych poleceń WMI z niezaufanych hostów.

Wykrywanie

W celu wykrycia nadużycia WMI, warto monitorować:

- Użycie narzędzi takich jak wmic.exe, powershell.exe oraz aktywność w przestrzeni COM/WMI,
- Nietypowe zdalne wywołania WMI, szczególnie z hostów, które zwykle nie inicjują połączeń do innych systemów,
- Zdarzenia z logów systemowych,
- Połączenia WMI używające kont użytkowników niepowiązanych z administracją systemów,
- Korelacja zdarzeń WMI z innymi podejrzanymi aktywnościami [39].

15. T1562 - Impair Defenses (Osłabienie mechanizmów obronnych)

Atakujący mogą złośliwie modyfikować składniki środowiska ofiary, aby utrudnić lub wyłączyć mechanizmy detekcyjne i obronne ofiary. Mogą również manipulować mechanizmami agregacji i analizy zdarzeń, aby utrudnić działania związane z audytem i wykrywaniem incydentów.

Najczęściej używaną techniką podrzędną jest T1562.001 - Disable or Modify Tools. Przeciwnicy mogą używać tej podtechniki do zatrzymywania usług defensywnych, edytowania lub usuwania kluczy rejestru lub modyfikowania plików konfiguracyjnych. Drugą najczęściej obserwowaną techniką podrzędną jest T1562.004 - Disable or Modify System Firewall. Ta podtechnika umożliwia przeciwnikom wykonywanie komunikacji C2, eksfiltracji danych lub ruchu bocznego.

Zapobieganie

Aby ograniczyć skuteczność tej techniki, należy:

- Zarządzać kontami użytkowników i nadawać im tylko niezbędne uprawnienia,
- Wprowadzić ścisłe reguły kontroli dostępu i egzekwować je na poziomie systemu operacyjnego i oprogramowania,
- Wdrożyć zasadę separacji obowiązków, aby uniemożliwić jednej osobie jednoczesny dostęp administracyjny i możliwość ingerencji w systemy bezpieczeństwa,
- Włączyć ciągle monitorowanie systemów i konfiguracji,
- Ograniczyć funkcjonalność systemu do absolutnego minimum,
- Wymuszać silne mechanizmy uwierzytelniania użytkowników i identyfikacji,
- Regularnie przeprowadzać testy penetracyjne i skanowanie podatności, które mogą ujawnić słabe punkty w konfiguracji zabezpieczeń,
- Zapewnić integralność oprogramowania i konfiguracji przez stosowanie mechanizmów kontroli zmian oraz podpisów cyfrowych.

Wykrywanie

W celu skutecznego wykrywania tej techniki należy:

- Monitorować szybkie wykonanie sekwencji podejrzanych poleceń w krótkim czasie,
- Wykrywać działania użytkowników, którzy próbują zatrzymać usługi ochronne Windows,
- Analizować wszelkie próby manipulacji interfejsem wiersza poleceń narzędzi zabezpieczających,
- Wykrywać działania polegające na wyłączaniu rejestrowania zdarzeń w systemie Windows, co może wskazywać na próbę ukrycia śladów działania [39].

2.4 Taktyki w macierzy MITRE ATT&CK

1. TA0043 - Reconnaissance (Rozpoznanie)

Przeciwnik stara się zebrać informacje, które może wykorzystać do planowania przyszłych operacji.

Rozpoznanie składa się z technik, w których atakujący angażują się w aktywne lub pasywne zbieranie informacji, które można wykorzystać do wsparcia namierzenia elementów podatnych na ataki. Takie informacje mogą obejmować szczegóły dotyczące organizacji, infrastruktury lub personelu atakowanej instytucji. Informacje te mogą być wykorzystywane przez atakującego do pomocy w innych fazach cyklu życia przeciwnika, takich jak wykorzystanie zebranych informacji do planowania i wykonywania dostępu początkowego do systemu ofiary, określania priorytetów działań po naruszeniu zabezpieczeń lub prowadzenia dalszych działań zwiadowczych [26].

2. TA0042 - Resource Development (Rozwijanie zasobów)

Przeciwnik stara się pozyskać zasoby, które może wykorzystać do wsparcia swojego ataku.

Rozwój zasobów składa się z technik, które polegają na tworzeniu, kupowaniu lub kradzieży zasobów, które można wykorzystać do wspierania ataku na dany cel. Takie zasoby obejmują infrastrukturę, konta lub umiejętności techniczne. Atakujący mogą wykorzystać te zasoby w kolejnych etapach ataku poprzez używanie zakupionych domen do obsługi komunikacji i kontroli, kont e-mail do przeprowadzenia ataku phishingowego i wyłudzenia informacji w ramach dostępu początkowego [26].

3. TA0001 - Initial Access (Początkowy dostęp)

Przeciwnik próbuje dostać się do sieci.

Taktyka początkowego dostępu obejmuje wszystkie techniki używane przez przeciwników w celu wejścia do sieci. Przykłady metod obejmują ataki phishingowe i wykorzystywanie aplikacji publicznych. Pomyślne wykonanie dostępu początkowego może prowadzić do dalszych możliwości wykorzystania, takich jak eskalacja uprawnień i kradzież danych [26].

4. TA0002 - Execution (wykonanie)

Atakujący wykonuje próbę uruchomienia złośliwego kodu.

Wykonywanie składa się z technik, które powodują, że kod kontrolowany przez atakującego jest uruchamiany w systemie lokalnym lub zdalnym. Techniki, które uruchamiają złośliwy kod, są często łączone z technikami wszystkich innych taktyk, aby osiągnąć szersze cele, takie jak eksploracja sieci lub kradzież danych. Przykładowo przeciwnik może użyć narzędzia dostępu zdalnego do uruchomienia skryptu programu PowerShell, który wykonuje rozpoznawanie systemów zdalnych [26].

5. TA0003 - Persistence (Upór)

Przeciwnik stara się utrzymać swój dostęp do systemu.

Persistence składa się z technik używanych przez przeciwników do utrzymywania obecności w systemie po ponownym uruchomieniu, zmienionych poświadczeniach i innych przerwach, które mogą odciąć ich dostęp. Techniki używane do utrzymania ich obecności obejmują wszelkie zmiany dostępu, akcji lub konfiguracji, które pozwalają im utrzymać pozycje w systemach, na przykład poprzez zastępowanie lub przejmowanie legalnego kodu lub dodawanie kodu uruchamianego przy starcie systemu [26].

6. TA0004 - Privilege Escalation

Przeciwnik próbuje uzyskać najwyższe możliwe uprawnienia.

Eskalacja uprawnień składa się z technik używanych przez przeciwników w celu uzyskania uprawnień wysokiego poziomu w systemie lub sieci. Przeciwnicy często mogą wchodzić do sieci i eksplorować ją z nieuprzywilejowanym dostępem, ale wymagane są od nich wyższe uprawnienia, aby mogli zrealizować swoje cele. Typowymi podejściami są wykorzystanie słabości systemu oraz błędnych konfiguracji i luk w zabezpieczeniach [26].

7. TA0005 - Defense Evasion (Unikanie obrony)

Przeciwnik stara się uniknąć wykrycia.

Unikanie obrony składa się z technik, których przeciwnicy używają, aby uniknąć wykrycia podczas przeprowadzania ataku. Techniki stosowane do omijania zabezpieczeń obejmują odinstalowywanie lub wyłączanie oprogramowania zabezpieczającego lub zaciemnianie, szyfrowanie danych i skryptów. Przeciwnicy również nadużywają zaufanych procesów, aby ukryć i zamaskować swoje złośliwe oprogramowanie [26].

8. TA0006 - Credential Access (Dostęp do poświadczeń)

Przeciwnik próbuje wykraść nazwy kont i hasła.

Dostęp do poświadczeń składa się z technik kradzieży danych uwierzytelniających, takich jak loginy i hasła. Techniki używane do uzyskiwania poświadczeń obejmują rejestrowanie naciśnień klawiszy lub zrzucanie poświadczeń. Korzystanie z legalnych poświadczeń może dać przeciwnikom dostęp do systemów, utrudnić ich wykrycie i dać możliwość utworzenia kolejnych kont, aby pomóc w osiągnięciu dalszych celów ataków [26].

9. TA0007 - Discovery (Rozpoznanie środowiska)

Przeciwnik próbuje poznać środowisko ofiary.

Rozpoznanie składa się z technik, które przeciwnik może wykorzystać do uzyskania wiedzy o systemie i sieci wewnętrznej. Techniki te pomagają przeciwnikom obserwować otoczenie i orientować się przed podjęciem decyzji o tym, jak działać. Pozwalają również atakującemu na zbadanie, co mogą kontrolować i co znajduje się wokół ich punktu wejścia, by określić, w jaki sposób może to pomóc w realizacji ich obecnych celów. Do zgromadzenia informacji o środowisku często używane są natywne narzędzia systemu operacyjnego [26].

10. TA0008 - Lateral Movement (Ruch boczny)

Przeciwnik próbuje przemieszczać się po środowisko ofiary.

Ruch boczny składa się z technik używanych przez przeciwników do uzyskania dostępu i kontrolowania zdalnych systemów w sieci. Realizacja ich głównego celu często wymaga zbadania sieci w celu znalezienia odpowiedniego zasobu, a następnie uzyskania do niego dostępu. Osiągnięcie celu często wiąże się z przechodzeniem przez wiele systemów i kont. Atakujący mogą zainstalować własne narzędzia dostępu zdalnego, aby wykonać ruch boczny lub użyć legalnych danych uwierzytelniających oraz natywne narzędzia systemu operacyjnego i sieciowe, co pozwala działać im w bardziej ukryty sposób [26].

11. TA0009 - Collection (Zbieranie danych)

Atakujący stara się zebrać dane potrzebne do realizacji swojego ataku.

Zbieranie danych składa się z technik, które przeciwnicy mogą wykorzystać do gromadzenia informacji, oraz źródeł, które są istotne do realizacji celów operacyjnych ataku. Często etapem po zebraniu danych jest albo kradzież (eksfiltracja) danych, albo

wykorzystanie danych do głębszego zbadania środowiska ofiary. Typowe źródła docelowe to różne typy dysków, przeglądarki internetowe, nagrania audio i wideo oraz poczta e-mail. Do często występujących metod zbierania danych zalicza się przechwytywanie zrzutów ekranu oraz rejestrowanie naciśnień klawiszy [26].

12. TA0011 - Command and Control (Dowodzenie i kontrola)

Atakujący próbuje komunikować się z zaatakowanymi systemami, aby je kontrolować.

Dowodzenie i kontrola składają się z technik, które przeciwnicy mogą wykorzystywać do komunikowania się z systemami znajdującymi się pod ich kontrolą w sieci ofiary. Przeciwnicy często próbują naśladować normalny, oczekiwany ruch, aby uniknąć wykrycia. Istnieje wiele sposobów, w jakie przeciwnik może ustanowić dowodzenie i kontrolę z różnymi poziomami ukrycia, w zależności od struktury sieci i mechanizmów obronnych ofiary [26].

13. TA0010 - Exfiltration (Ekstrafiltracja danych)

Atakujący wykonuje próbę kradzieży danych.

Eksfiltracja składa się z technik, które przeciwnicy mogą wykorzystać do kradzieży danych z sieci. Po zebraniu danych cyberprzestępcy często przygotowują je tak, aby uniknąć wykrycia podczas ich usuwania. Może to obejmować kompresję i szyfrowanie danych. Techniki ekstrafiltracji zazwyczaj obejmują przesyłanie danych przez kanał dowodzenia i kontroli lub kanał alternatywny, a także mogą obejmować nakładanie ograniczeń dotyczących rozmiaru przesyłanych danych [26].

14. TA0040 - Impact (Wpływ)

Atakujący próbuje manipulować, zakłócać lub niszczyć systemy i dane ofiary.

Wpływ składa się z technik stosowanych przez przeciwników w celu zakłócenia dostępności lub naruszenia integralności poprzez manipulowanie procesami biznesowymi i operacyjnymi. Techniki te mogą obejmować niszczenie lub manipulowanie danymi. W niektórych przypadkach procesy biznesowe mogą wyglądać na działające prawidłowo, mimo że zostały zmienione w sposób działający na korzyść atakującego. Techniki te mogą być wykorzystywane przez przeciwników do realizacji ich celu końcowego lub do zapewnienia zatuszowania naruszenia poufności [26].

3 Metodyka badań

Poniższy rozdział opisuje sposób przeprowadzenia badań empirycznych przedstawionych w pracy. Zawiera cel i zakres badań, pytania badawcze i hipotezy, zastosowane metody i techniki, pełne zestawienie narzędzi i konfiguracji środowiska testowego oraz szczegółowy plan etapów realizacji eksperymentów (procedury powtarzalne).

3.1 Cel i zakres badań

Celem badań jest zweryfikowanie użyteczności macierzy MITRE ATT&CK jako narzędzia do modelowania zagrożeń oraz oceny efektywności strategii obronnych w warunkach kontrolowanych symulacji. Badanie koncentruje się na sprawdzeniu, czy zalecane mitygację z macierzy MITRE ATT&CK skutecznie działają wobec technik ataków reprezentowanych we wspomnianej macierzy.

Szczegółowe pytania badawcze:

1. Czy mechanizmy obronne wskazywane przez MITRE ATT&CK wpływają na sukces poszczególnych technik ataku w środowisku testowym?
2. Jakie wskaźniki generują poszczególne techniki ataku i czy są one wykrywalne w standardowych logach (Sysmon, Event Log, PowerShell, Firewall)?

Hipotezy:

1. Proste, łatwe do wdrożenia mitygację z macierzy MITRE ATT&CK istotnie ograniczają skuteczność poszczególnych cyberataków.
2. Sysmon wraz z właściwą konfiguracją (Event ID 1, 3, 7, 8, 10) rejestruje kluczowe zdarzenia niezbędne do wykrycia i odtworzenia sekwencji działań na każdym etapie ataku.

Uzasadnienie wyboru obszaru tematycznego:

Wybór tematu wynika z jego dużej aktualności oraz praktycznego znaczenia w dziedzinie cyberbezpieczeństwa. W obliczu rosnącej złożoności cyberataków, konieczne staje się przejście od reaktywnego modelu obrony do podejścia, które opiera się na

proaktywnym modelowaniu zachowań przeciwnika.

Macierz MITRE ATT&CK to obecnie uznawany standard i wspólny język dla całej branży, co czyni z niej doskonałą podstawę do badań. Ta praca ma na celu wypełnienie luki pomiędzy teoretycznymi zaleceniami obronnymi a ich rzeczywistą, potwierdzoną skutecznością.

3.2 Metody i techniki badawcze

W pracy wykorzystano metodologię łączącą analizę teoretyczną z serią praktycznych symulacji ataków w środowisku laboratoryjnym. Poniżej przedstawiono szczegółowy opis zastosowanych metod i technik badawczych:

1. Analiza literatury i dokumentacji

Przeprowadzono przegląd istniejącej dokumentacji, w tym oficjalnych materiałów frameworku MITRE ATT&CK oraz publikacji technicznych, w celu identyfikacji i zrozumienia wybranych technik ataku, odpowiadających im środków zaradczych (*mitigations*) oraz typowych wskaźników kompromitacji (IoC).

2. Modelowanie scenariuszy ataków

Na podstawie teoretycznej analizy wybrano kluczowe techniki z macierzy MITRE ATT&CK, które następnie przekształcono w szczegółowe, operacyjne scenariusze testowe. Dla każdego scenariusza określono oczekiwaną sekwencję działań (taktyki i techniki) oraz potencjalne artefakty, które mogą pojawić się na różnych etapach ataku.

3. Eksperyment w kontrolowanym środowisku

Główną część badania stanowiły powtarzalne symulacje ataków w odizolowanym środowisku wirtualnym, stworzonym przy użyciu oprogramowania VirtualBox. Jako cel ataku wybrano system Windows 10.

Symulacje dla każdego scenariusza przeprowadzono w dwóch konfiguracjach:

- Konfiguracja referencyjna (*Baseline*): Środowisko z podstawową konfiguracją bezpieczeństwa, ale bez testowanych mechanizmów obronnych,
- Konfiguracja z obroną: Środowisko wzbogacone o wdrożoną, konkretną strategię obronną zalecaną przez MITRE ATT&CK przed wykonaniem ataku.

4. Pozyskiwanie i analiza danych telemetrycznych

W trakcie eksperymentów zbierano szczegółową telemetryczną systemową i sieciową.

Analizie poddawano logi z następujących źródeł:

- Sysmon (zdarzenia 1, 3, 7, 8, 10),
- PowerShell (zdarzenie 4104 z logu operacyjnego),
- Dziennik bezpieczeństwa systemu Windows (zdarzenie 4688),
- Dzienniki zapory sieciowej (plik pfirewall.log).

5. Ocena efektywności obrony

Dla każdego zrealizowanego scenariusza przeprowadzono szczegółową analizę skuteczności. Ocena ta opierała się na trzech kluczowych aspektach:

- Skuteczność ataku: Zbadano, czy operacja zakończyła się sukcesem, co określono na podstawie osiągnięcia celu operacyjnego przez atakującego (np. zrealizowanie ładunku),
- Skuteczność detekcji: Sprawdzono, czy w zebranej telemetrycznej występowały wskaźniki kompromitacji (IoC), które mogłyby pomóc w wykryciu ataku.

3.3 Narzędzia badawcze i środowisko testowe

Poniżej przedstawiono konfigurację środowiska testowego oraz zestaw narzędzi wykorzystanych w badaniach.

1. Infrastruktura testowa

Badania zostały przeprowadzone w odizolowanym wirtualnym środowisku. Kluczowym elementem infrastruktury był fizyczny host z oprogramowaniem wirtualizacyjnym VirtualBox, na którym uruchomiono maszyny wirtualne w sieci typu Host-Only, co zapewniło pełną izolację od zewnętrznych sieci.

2. Konfiguracja systemów

- Maszyna docelowa („Ofiara”): Windows 10 z aktywnymi mechanizmami bezpieczeństwa.

3. Narzędzia diagnostyczne

- Atomic Red Team - do wykonywania testów zgodnych z technikami MITRE ATT&CK,
- Sysmon - z konfiguracją rejestrującą zdarzenia: 1 (tworzenie procesu),

3 (połączenie sieciowe), 7 (ładowanie bibliotek), 8 (tworzenie wątku zdalnego), 10 (dostęp do procesu),

- PowerShell 5+ - jako główne środowisko wykonawcze testów,
- Windows Defender z włączoną ochroną w czasie rzeczywistym i funkcjami ASR,
- Zapora systemu Windows - skonfigurowana w trybie blokowania domyślnego z logowaniem.

4. Mechanizmy rejestracji zdarzeń

- Logi Sysmon (Event ID 1, 3, 7, 8, 10),
- PowerShell Script Block Logging (Event ID 4104),
- Audyt bezpieczeństwa systemu Windows (Event ID 4688),
- Dzienniki zapory sieciowej (pfirewall.log).

3.4 Etapy realizacji badań

Plan postępowania badawczego:

1. Selekcja i analiza przypadków testowych

Przeprowadzono analizę macierzy MITRE ATT&CK, aby wybrać reprezentatywne techniki ataków, które obejmują różne etapy cyberataku:

- Rozpoznanie (T1046 - Skanowanie sieci),
- Wykonanie (T1059.001 - PowerShell),
- Eskalacja uprawnień (T1055 - Wstrzykiwanie procesów),
- Dostęp do poświadczeń (T1003.001 - Pamięć LSASS).

Wybór technik oparty był na ich popularności, dostępności jednoznacznych wskaźników kompromitacji (IoC) oraz możliwości ich zastosowania w testach.

2. Projektowanie scenariuszy badawczych

Dla każdej z wybranych technik stworzono szczegółowy scenariusz, który uwzględniał:

- Środowisko wykonawcze i warunki początkowe,
- Sekwencję kroków ataku z dokładnymi poleceniami,
- Konfigurację mechanizmów obronnych zgodnie z zaleceniami MITRE,
- Oczekiwane wskaźniki kompromitacji,

- Kryteria oceny skuteczności ataku i detekcji.

3. Przygotowanie infrastruktury testowej

Stworzono środowisko badawcze, które obejmowało:

- Konfigurację maszyny wirtualnej z systemem Windows 10,
- Instalację narzędzi Atomic Red Team i Sysmon,
- Włączenie rejestracji zdarzeń PowerShell oraz audytu bezpieczeństwa,
- Konfigurację mechanizmów Windows Defender i zapory sieciowej,
- Utworzenie migawki systemu w stanie początkowym.

4. Przeprowadzenie eksperymentów

Dla każdego scenariusza wykonano następujące kroki:

- Przywrócenie środowiska do stanu początkowego,
- Przeprowadzenie ataku w warunkach *baseline*,
- Eksport logów i dokumentacji wizualnej,
- Ponowne przywrócenie migawki,
- Wdrożenie strategii obronnej i powtórzenie ataku,
- Zbieranie danych wynikowych.

5. Analiza wyników

- Wybrano kluczowe wpisy z logów systemowych,
- Porównano skuteczność ataków w warunkach bazowych oraz po wdrożeniu zabezpieczeń,
- Oceniono obecność wskaźników kompromitacji w teledetrii,
- Przeanalizowano działanie mechanizmów obronnych.

4 Opracowanie scenariuszy ataku na podstawie MITRE ATT&CK

W rozdziale trzecim skupiono się na przekształceniu pojęć zawartych w macierzy MITRE ATT&CK na realistyczny model zagrożeń, który posłuży jako podstawa do symulacji, a następnie testowania mechanizmów obronnych. Proces ten rozpoczyna się od zidentyfikowania kluczowych faz ataku - od rekonesansu infrastruktury (*reconnaissance*), przez fazę dostarczenia i wykonania szkodliwego kodu, aż po ukrycie aktywności atakującego i zwińczenie pozyskaniem danych uwierzytelniających. Każdy z tych etapów omówiono w kontekście konkretnych technik ATT&CK, ich mechanizmów działania oraz typowych wskaźników kompromitacji (IoC), np. nietypowych wpisów w logach systemowych, procesów uruchomionych z uprawnieniami administratora czy prób odczytu pamięci procesów chronionych.

Z tej analizy uzyskano powtarzalne scenariusze ataków, sekwencję pewnej liczby technik, łatwo odtwarzalnych w typowym środowisku wirtualnym. Każdy scenariusz podaje opis działań atakującego, wymagań sprzętowych i programowych oraz oczekiwanych śladów wykonanego ataku, a następnie wykorzystuje je do potwierdzenia skuteczności wybranych zabezpieczeń defensywnych. Tak przygotowana mapa zagrożeń umożliwia dokładne omówienie, w jaki sposób i dlaczego niektóre mechanizmy obronne zadziałały lub zawiodły. Stanowi to zatem rozdział między teoretycznym omówieniem macierzy, a praktyczną symulacją, na której opiera się reszta pracy.

4.1 Analiza wybranych ataków

Celem tego podrozdziału jest przedstawienie ataków z macierzy MITRE ATT&CK wybranych do ich wykonania podczas symulacji oraz wyjaśnienie ich wyboru. Każdy z nich będzie podstawą do opracowania szczegółowego scenariusza ataku. Kluczowy aspektem analizowanym podczas symulacji będzie ocena skuteczności środków obronnych (*mitigations*) oraz zdolności do wykrycia ich objawów (*detections*).

4.1.1 Kryteria wyboru ataków

Do wyboru rodzaju ataków zostały zastosowane następujące kryteria:

1. Odtwarzalność

Każda z technik musi być łatwa do odtworzenia w prostym środowisku symulacyjnym, czyli na standardowej maszynie wirtualnej z zainstalowanym systemem operacyjnym, bez dodatkowego specjalistycznego oprogramowania.

2. Zakres taktyk

Taktyki posiadają fazę rozpoznania (*Reconnaissance*), wykonania kodu (*Execution*), unikania wykrycia (*Defense Evasion*) oraz kradzieży poświadczeń (*Credential Access*).

3. Wykrywanie

Wybrane metody powinny pozostawiać w systemie ofiary charakterystyczne wskaźniki pozwalające na ich jednoznaczną identyfikację.

4. Dokumentacja i wsparcie

Każda technika jest dobrze opisana macierzy MITRE ATT&CK co pozwala na jej łatwe odwzorowanie i zrozumienie.

4.1.2 Opis wybranych ataków

Przypadek A

Skanowanie portów (T1046) - faza Reconnaissance

Atakujący mogą próbować uzyskać listę usług uruchomionych na zdalnych hostach i urządzeniach infrastruktury sieci lokalnej, w tym tych, które mogą być podatne na zdalne wykorzystanie oprogramowania. Jedną z typowych metod pozyskiwania tych informacji jest skanowanie portów [26].

Celem atakującego podczas wykonywania tego procesu jest zidentyfikowanie otwartych portów TCP na hoście ofiary, co umożliwia dalsze planowanie ataku. Mechanizm działania sprowadza się do wysyłania pakietów SYN do kolejnych portów i analizowania odpowiedzi. Do symulacji wystarczy narzędzie nmap w trybie SYN scan lub prosta sekwencja poleceń PowerShell. Oczekiwane IoC to seria zdarzeń połączeń wychodzących w logach Sysmon oraz wpisy w logu zapory Windows pokazujące zablokowane pakiety.

Przypadek B

Wykonanie poleceń PowerShell (T1059.001) - faza Execution

Atakujący mogą używać poleceń i skryptów programu PowerShell do zrealizowania swoich celów. PowerShell to potężny interaktywny interfejs wiersza poleceń i środowisko skryptowe znajdujące się w systemie operacyjnym Windows. Przeciwnicy mogą używać programu PowerShell do wykonywania wielu akcji, w tym odnajdywania informacji i wykonywania kodu [26].

Technika ta umożliwia atakującemu uruchomienie dowolnego kodu w kontekście użytkownika, zwykle przez zdalne pobranie i wykonanie skryptu. W praktyce atak polega na wywołaniu PowerShell z odpowiednim parametrem dzięki czemu omija się domyślne restrykcje. Przykładowym narzędziem może być standardowy powershell.exe. Kluczowymi IoC są wpisy w dzienniku PowerShell pełną treść uruchamianych poleceń, a także zdarzenia procesu powershell.exe w logach Sysmon z nietypowymi parametrami.

Przypadek C

Wstrzykiwanie kodu do procesu (T1055) - Defense Evasion

Atakujący mogą wstrzykiwać kod do procesów w celu uniknięcia zabezpieczeń opartych na procesach, a także ewentualnego podniesienia swoich uprawnień. Uruchamianie kodu w kontekście innego procesu może umożliwić dostęp do pamięci procesu, zasobów systemowych i sieciowych oraz prawdopodobnie podwyższonych uprawnień. Wykonanie ataku za pomocą wstrzyknięcia procesu może również pomóc uniknąć wykrycia przez zabezpieczenia, ponieważ wykonanie jest ukryte w postaci legalnego procesu.

Istnieje wiele różnych sposobów wstrzykiwania kodu do procesu, z których wiele nadużywa legalnych funkcji. Te implementacje istnieją dla każdego głównego systemu operacyjnego, ale zazwyczaj są specyficzne dla platformy [26].

Aby ukryć swój kod przed narzędziami zabezpieczającymi, atakujący może wstrzyknąć go do pamięci zaufanego procesu, np. explorer.exe lub svchost.exe. Operacja ta wymaga wywołania systemowego API: alokacji pamięci, zapisu kodu i uruchomienia go w nowym wątku. Charakterystyczne IoC to ulokowany w logach Sysmon Event 8 sygnalizujący uruchomienie wątku w obcym procesie, Event 10 rejestrujący nieautoryzowany dostęp do pamięci procesu oraz Event 7 wskazujący na załadowanie nietypowej biblioteki DLL w kontekście procesu systemowego.

Przypadek D

Dumping pamięci LSASS (T1003.001) - faza Credential Access

Przeciwnicy mogą próbować uzyskać dostęp do materiałów uwierzytelniających przechowywanych w pamięci procesów usługi podsystemu zabezpieczeń lokalnych (LSASS). Po zalogowaniu się użytkownika system generuje i przechowuje różne materiały uwierzytelniające w pamięci procesu LSASS. Te materiały uwierzytelniające mogą być zbierane przez użytkownika administracyjnego lub SYSTEM i wykorzystywane do przeprowadzania ruchu bocznego przy użyciu alternatywnego materiału uwierzytelniającego [26].

Celem tej techniki jest odzyskanie poświadczeń użytkowników z procesu lsass.exe. Atakujący może użyć narzędzi takich jak procdump.exe lub „Mimikatz” do wykonania zrzutu pamięci, a następnie analizować go lokalnie. Typowe IoC obejmuje Event 10 z parametrem pełnego dostępu do lsass.exe, Event 4688 w Security Log dla procesu procdump.exe, a także obecność pliku zrzutu w katalogu tymczasowym.

4.2 Scenariusze ataku

W tej podrozdziale przedstawione zostaną szczegółowo opracowane scenariusze ataku, które będą stanowiły podstawę do przeprowadzenia symulacji i oceny mechanizmów obronnych. Dla każdego scenariusza zostaną zdefiniowane kroki ataku z przypisanymi odpowiednimi technikami zawartymi w macierzy MITRE ATT&CK, opis wymagań środowiskowych oraz oczekiwane wskaźnik kompromitacji (IoC). Scenariusze te posłużą następnie do przeprowadzenia symulacji i analizy skuteczności mechanizmów obronnych.

W ramach środowiska symulacyjnego utworzona została maszyna wirtualna w programie VirtualBox jako pojedynczy VM z systemem Windows 10 Pro uruchomionym w sieci Host-Only o adresie 192.168.56.101. Sieć ta została utworzona w celu izolacji od sieci zewnętrznej. Maszynie przydzielono minimalnie 4 GB RAM i oraz dysk systemowy z wystarczającą przestrzenią na artefakty testów

4.2.1 Scenariusz A - Skanowanie portów (T1046)

Scenariusz A ma na celu przeprowadzenie skanowania oraz odnalezienia otwartych portów TCP na hoście ofiary oraz weryfikację skuteczności mechanizmów obrony.

Środowisko testowe:

1. Maszyna VirtualBox „Ofiara” (Windows 10 Pro) skonfigurowana z:
 - Sysmon rejestrującym Event 3 (Network Connect),
 - Windows Defender,
 - PowerShell 5+.

Opis kroków ataku:

1. Przywrócenie „migawki” maszyny wirtualnej
2. Uruchomienie na maszynie wirtualnej skryptu PowerShell sprawdzający porty od 1 do 1024
 - Treść skryptu:

```
PS C:\Windows\system32> $start = Get-Date
PS C:\Windows\system32> 1..1024 | ForEach-Object {
>> if (Test-NetConnection -ComputerName 192.168.56.101 -Port $_ -InformationLevel Quiet){
>> Write-Output "$_ open"
>> }
```

Rysunek 4.1 Treść skryptu

3. Zarejestrowanie listy otwartych portów
4. Wygenerowanie zrzutu ekranu wyników skryptu na maszynie
5. Wyeksportowanie z Sysmon wszystkich wpisów Event 3 z okresu trwania testu

Strategia obronna (MITRE ATT&CK)

- **M1042 - Disable or Remove Feature or Program**

Przygotowanie obrony

- Wyłączenie niepotrzebnych usług sieciowych, by zredukować liczbę otwartych portów.

Oczekiwane wskaźniki kompromitacji (IoC)

- Wpisy Sysmon Event 3 rejestrujące próby połączeń TCP do kolejnych portów.

Scenariusz A pozwala na ocenę czy Sysmon skutecznie rejestruje nieautoryzowane próby połączeń.

4.2.2 Scenariusz B - Wykorzystanie skryptu PowerShell do pobrania i uruchomienia pliku wykonywalnego (T1059.001)

Scenariusz B polega na zdalnym pobraniu i uruchomieniu pliku wykonywalnego przy użyciu programu PowerShell oraz sprawdzeniu, czy istniejące mechanizmy obronne (Sysmon, Windows Defender, zaporę sieciową) zarejestrują próbę ataku.

Środowisko testowe:

1. Maszyna VirtualBox „Ofiara” (Windows 10 Pro) skonfigurowana z:
 - Sysmon rejestrującym Event 1 (Process Create), Event 3 (Network Connect), Event 7 (Image Load),
 - Włączonym PowerShell Logging (Event 4104 - Script Block Logging),
 - Windows Defender z aktywną ochroną w czasie rzeczywistym,
 - Windows Defender Firewall w trybie block-by-default.

Strategia obronna (MITRE ATT&CK)

- **M1049 - Antivirus/Antimalware**

Przygotowanie obrony

- Upewnienie czy ochrona antywirusowa w czasie rzeczywistym jest aktywna.

Opis kroków ataku:

1. Przywrócenie snapshotu czystej maszyny wirtualnej
2. Uruchomienie na maszynie wirtualnej skryptu:
 - Treść skryptu:
Invoke-AtomicTest T1059.001 -TestNumbers 1
3. Zrobienie zrzutu ekranu z komunikatem o uruchomieniu skryptu
4. Eksport z Sysmon wszystkich zdarzeń Zdarzenia 1, 3 i 7 okresu testowego
5. Eksportowanie dzienników programu PowerShell (zdarzenie 4104)
6. Przeglądanie dzienników usługi Windows Defender
7. Powtórzenie testu z wyłączoną ochroną antywirusa w czasie rzeczywistym

Oczekiwane wskaźniki kompromitacji (IoC)

- Wpisy Sysmon Event 1 rejestrujące utworzenie procesów powershell.exe i test.exe,

- Wpisy Sysmon Event 3 rejestrujące połączenie,
- Wpisy Sysmon Event 7 rejestrujące załadowanie pliku test.exe (jeśli nastąpiło).
- Wpisy PowerShell Operational (Event 4104),
- Alert lub blokada w Windows Defender (jeśli ochrona zadziałała),

Scenariusz B pozwala na ocenę, czy wdrożone mechanizmy detekcji i ochrony w systemie Ofiary wykrywają i reagują na próbę pobrania i uruchomienia pliku wykonywalnego za pomocą PowerShell, zgodnie z rekomendacjami MITRE ATT&CK dla techniki T1059.001.

4.2.3 Scenariusz C - Wstrzykiwanie kodu do procesu (T1055)

Scenariusz ten polega na wstrzyknięciu kodu do procesu systemowego oraz weryfikacji, czy mechanizmy wykrywania i obrony zarejestrują lub zablokują ten atak

Środowisko testowe:

1. Maszyna VirtualBox „Ofiara” (Windows 10 Pro) skonfigurowana z:
 - Sysmon rejestrującym Event 1 (Process Create), Event 7 (Image Load), Event 8 (CreateRemoteThread), Event 10 (Process Access),
 - Windows Defender z aktywną ochroną w czasie rzeczywistym.

Opis kroków ataku:

1. Przywrócenie snapshotu maszyny wirtualnej
2. Uruchomienie na maszynie wirtualnej skryptu:
 - Treść skryptu:
Invoke-AtomicTest T1055 -TestNumbers 1
3. Zrobienie zrzutu ekranu z komunikatem o próbie iniekcji
4. Eksport z Sysmon wszystkich zdarzeń Zdarzenia 8, 10 i 7 okresu testowego
5. Przeglądanie dzienników usługi Windows Defender

Strategia obronna (MITRE ATT&CK)

- **M1042 - Disable or Remove Feature or Program**

Przygotowanie obrony

- Włączenie reguł blokujących typowe sekwencje iniekcji kodu

Oczekiwane wskaźniki kompromitacji (IoC)

- Wpisy Sysmon Event 8 rejestrujące wykonanie CreateRemoteThread,
- Wpisy Sysmon Event 10 rejestrujące dostęp do pamięci procesu,
- Wpisy Sysmon Event 7 rejestrujące załadowanie nieautoryzowanej biblioteki DLL w procesie systemowym,
- Alert lub blokada w Windows Defender (jeśli ochrona zadziałała).

Dane wyjściowe scenariusza zostaną wykorzystane do ustalenia czy mechanizmy obronne skutecznie wykryły operacje iniekcji i czy Sysmon Events zarejestrował wszystkie etapy tego ataku.

4.2.4 Scenariusz D - Dumping pamięci LSASS (T1003.001)

Proces dumpingu pamięci LSASS umożliwia atakującemu przechwycenie poświadczeń użytkowników bezpośrednio z pamięci systemowej. Celem tego scenariusza jest upewnienie się, że istniejące narzędzia obrony (Sysmon, Windows Defender, Security Audit) rejestrują i zablokują próbę zrzutu pamięci LSASS.

Środowisko testowe:

1. Maszyna VirtualBox „Ofiara” (Windows 10 Pro) skonfigurowana z:
 - Sysmon rejestrującym Event 1 (Process Create), I Event 10 (Process Access),
 - Włączonym Security Auditem rejestrującym Event 4688 (Process Creation),
 - Windows Defender z aktywną ochroną w czasie rzeczywistym.

Opis kroków ataku:

1. Zapisanie czystego stanu maszyny wirtualnej
2. Uruchomienie na maszynie wirtualnej skryptu:
 - Treść skryptu:
Invoke-AtomicTest T1003.001
3. Zrobienie zrzutu komunikującego o uruchomieniu skryptu
4. Eksport wszystkich wpisów Sysmon Event 10 dotyczących dostępu do procesu lsass.exe.
5. Eksport wszystkich wpisów Sysmon Event 1 rejestrujących utworzenie procesu narzędzia do dumpu
6. Eksport wpisów Security Log Event 4688 rejestrujących uruchomienie narzędzia dumpującego.

7. Sprawdzenie, czy w katalogu tymczasowym pojawił się plik lsass.dmp.
8. Przeglądanie dzienników usługi Windows Defender

Strategia obronna (MITRE ATT&CK)

- **M1025 - Privileged Process Integrity**

Przygotowanie obrony

- Aktywowanie mechanizmu chroniącego proces LSASS przed zrzutem pamięci

Oczekiwane wskaźniki kompromitacji (IoC)

- Wpisy Sysmon Event 10 rejestrujące dostęp do pamięci procesu lsass.exe,
- Wpisy Sysmon Event 1 rejestrujące utworzenie procesu narzędzia do dumpu (np. procdump.exe),
- Wpisy Security Log Event 4688 rejestrujące uruchomienie narzędzia dumpującego lsass.exe,
- Pojawienie się pliku lsass.dmp w katalogu tymczasowym,
- Alert lub blokada w Windows Defender (jeśli ochrona zadziałała).

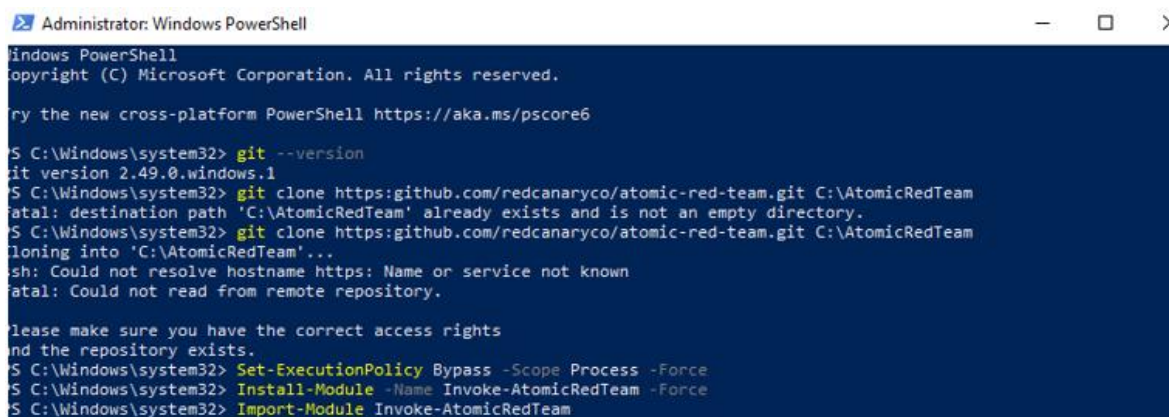
Wyniki scenariusza zostaną wykorzystane do oceny czy mechanizmy obronne skutecznie przechwyciły operacje zrzutu pamięci LSASS oraz czy zdarzenia Sysmon i Security Audit zarejestrowały wszystkie etapy tego ataku.

5 Symulacje cyberataków i analiza ich przebiegu

5.1 Przygotowanie maszyny wirtualnej

Przed przystąpieniem do symulacji ataków przygotowano jedną, spójną maszynę wirtualną z zainstalowanym systemem Windows 10 Pro, działającą w sieci typu Host-Only (adres 192.168.56.101).

Pierwszym krokiem było sklonowanie repozytorium Atomic Red Team co przedstawiono na Rys.5.1 do katalogu C:\AtomicRedTeam oraz instalacja modułu Invoke-AtomicRedTeam co ilustruje Rys. 5.1.



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

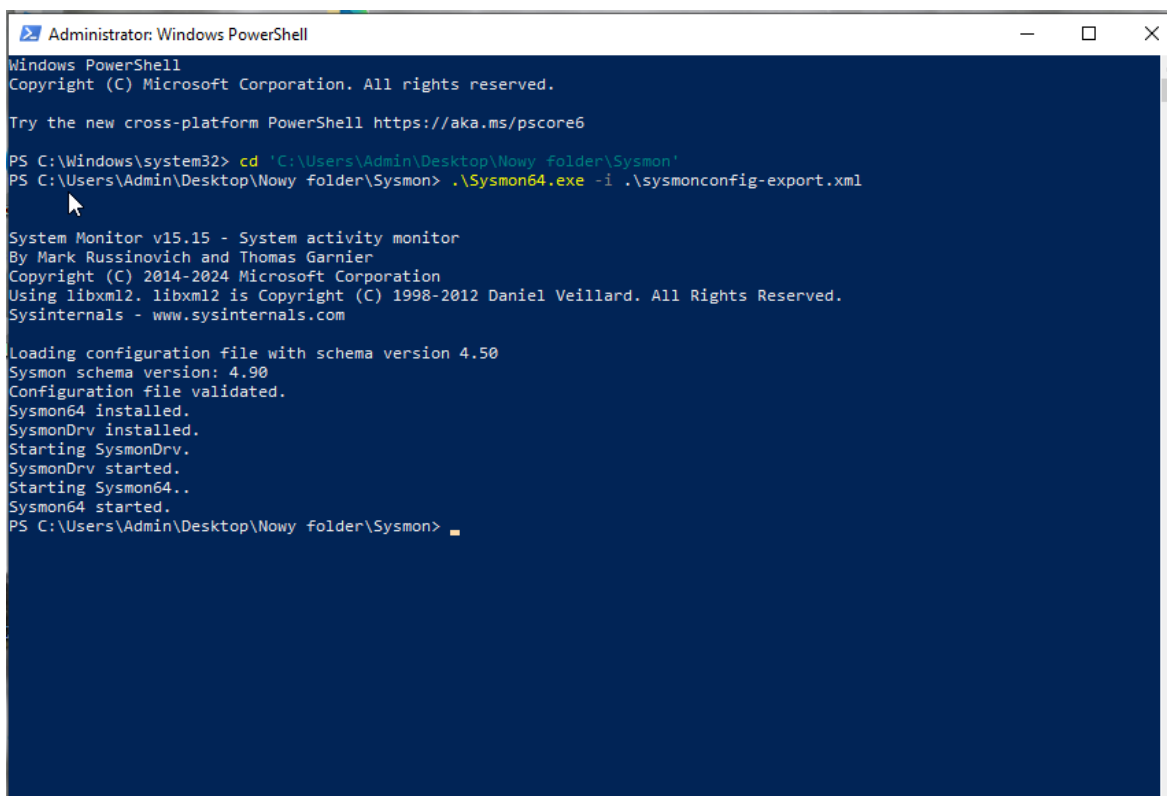
Try the new cross-platform PowerShell https://aka.ms/pscore6

S C:\Windows\system32> git --version
git version 2.49.0.windows.1
S C:\Windows\system32> git clone https://github.com/redcanaryco/atomic-red-team.git C:\AtomicRedTeam
fatal: destination path 'C:\AtomicRedTeam' already exists and is not an empty directory.
S C:\Windows\system32> git clone https://github.com/redcanaryco/atomic-red-team.git C:\AtomicRedTeam
Cloning into 'C:\AtomicRedTeam'...
ssh: Could not resolve hostname https: Name or service not known
fatal: Could not read from remote repository.

Please make sure you have the correct access rights
and the repository exists.
S C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
S C:\Windows\system32> Install-Module -Name Invoke-AtomicRedTeam -Force
S C:\Windows\system32> Import-Module Invoke-AtomicRedTeam
```

Rysunek 5.1 Instalacja modułu Invoke-AtomicRedTeam

Potem zainstalowano i odpowiednio skonfigurowano Sysmon, wykorzystując plik sysmon-config.xml, tak aby rejestrował zdarzenia związane z procesami, połączeniami sieciowymi oraz wszelkimi wstrzyknięciami kodu. Zrzut ekranowy z Rysunku 5.2 potwierdza, że ten etap zakończył się pomyślnie.

A screenshot of an Administrator: Windows PowerShell window. The terminal shows the execution of Sysmon64.exe with the -i flag and a configuration file path. The output displays Sysmon version 15.15, copyright information, and the successful installation and starting of SysmonDrv and Sysmon64.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

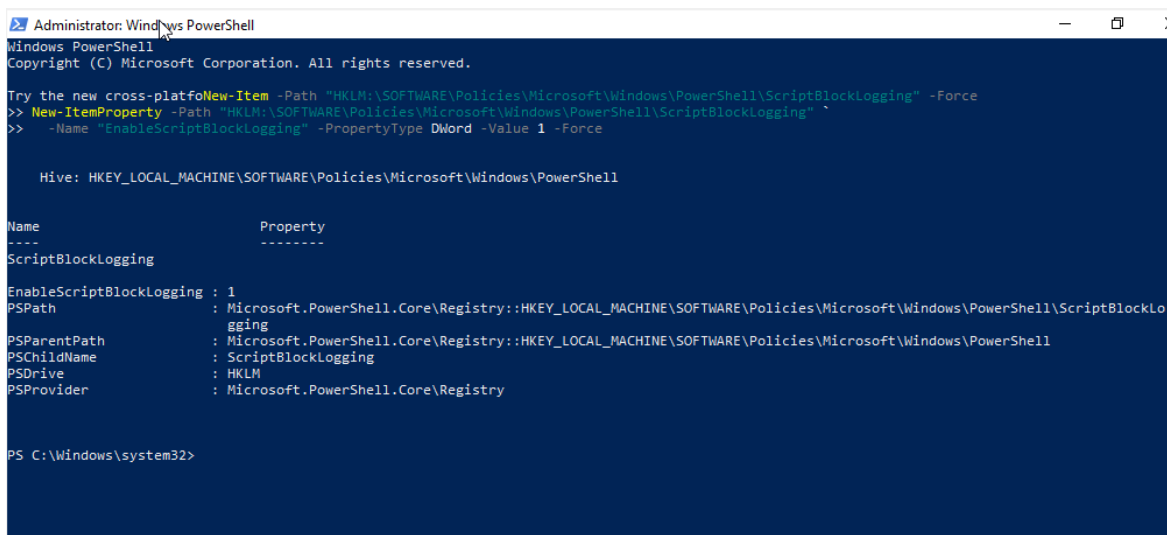
PS C:\Windows\system32> cd 'C:\Users\Admin\Desktop\Nowy folder\Sysmon'
PS C:\Users\Admin\Desktop\Nowy folder\Sysmon> .\Sysmon64.exe -i .\sysmonconfig-export.xml

System Monitor v15.15 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2024 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.50
Sysmon schema version: 4.90
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.
PS C:\Users\Admin\Desktop\Nowy folder\Sysmon>
```

Rysunek 5.2 Instalacja Sysmon

Następnie zweryfikowano działanie Windows Defender Firewall w trybie block-by-default. Na koniec włączono rejestrowanie zdarzenia 4104 Rys. 5.4 oraz rejestrowanie zdarzenia 4668 dla PowerShella Rys. 5.3

A screenshot of an Administrator: Windows PowerShell window. The terminal shows two commands to create a registry value 'EnableScriptBlockLogging' with a value of 1. The output shows the registry path and a table of properties for the new registry item.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

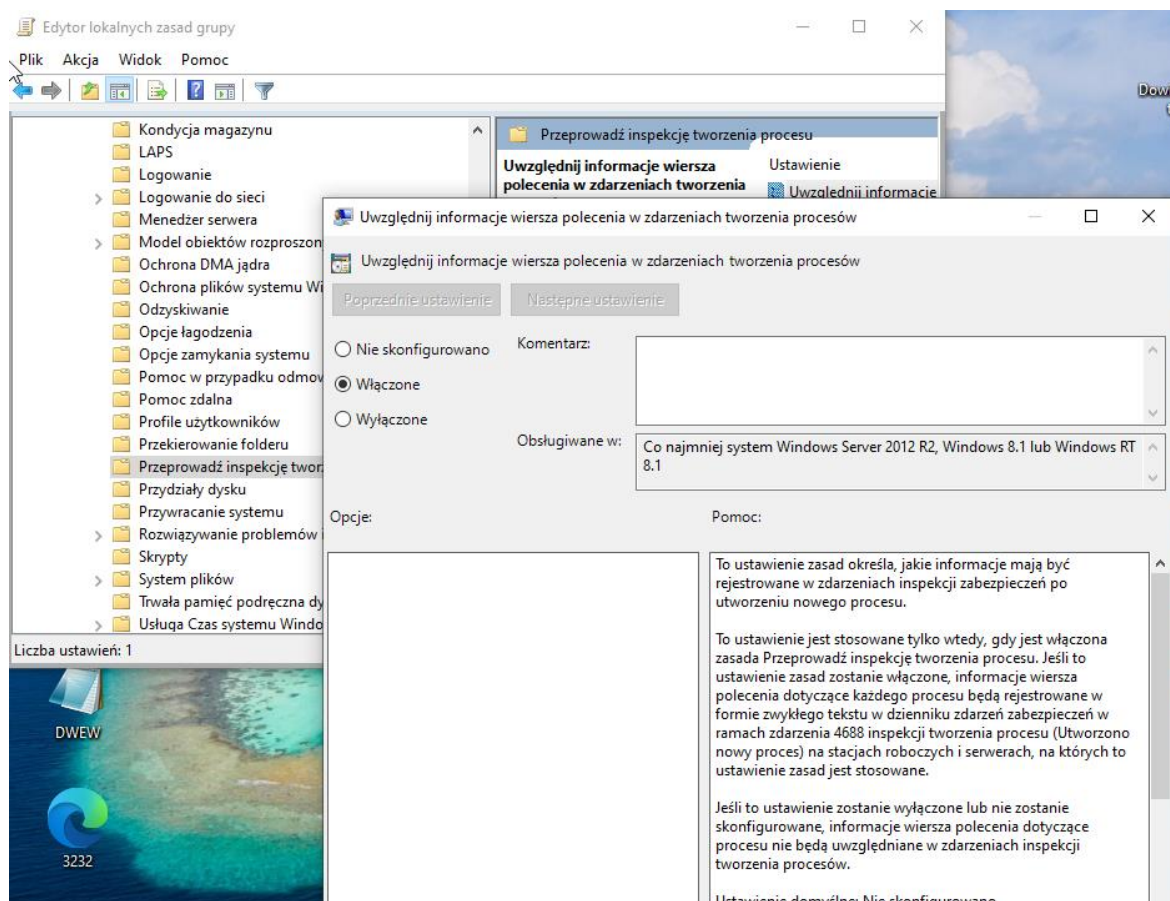
PS C:\Windows\system32> New-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging" -Name "EnableScriptBlockLogging" -PropertyType DWord -Value 1 -Force

Hive: HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell

Name                Property
----                -
ScriptBlockLogging
EnableScriptBlockLogging : 1
PSPath                   : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLo
gging
PSParentPath             : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell
PSChildName              : ScriptBlockLogging
PSDrive                  : HKLM
PSProvider               : Microsoft.PowerShell.Core\Registry

PS C:\Windows\system32>
```

Rysunek 5.3 Skrypt uruchamiający rejestrację zdarzenia 4104 dla PowerShella



Rysunek 5.4 Włączenie rejestrowania event 4668 dla PowerShella

5.2 Scenariusz A (skanowanie portów)

Scenariusz A miał na celu sprawdzenie czy narzędzia monitorujące system potrafią wykryć aktywność związaną ze skanowaniem portów TCP. Takie działanie może być częścią fazy rozpoznania przed właściwym atakiem. Symulację przeprowadzono na maszynie wirtualnej, na której zainstalowano Sysmon oraz aktywny firewall systemu Windows, działający w trybie domyślnego blokowania połączeń.

Test polegał na uruchomieniu skryptu PowerShell Rys 5.5, który sprawdzał dostępność wszystkich portów od 1 do 1024.

Treść skryptu:

```
PS C:\Windows\system32> $start = Get-Date
PS C:\Windows\system32> 1..1024 | ForEach-Object {
>> if (Test-NetConnection -ComputerName 192.168.56.101 -Port $_ -InformationLevel Quiet){
>> Write-Output "$_ open"
>> }
}
```

Rysunek 5.5 Treść skryptu

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> ipconfig

Windows IP Configuration

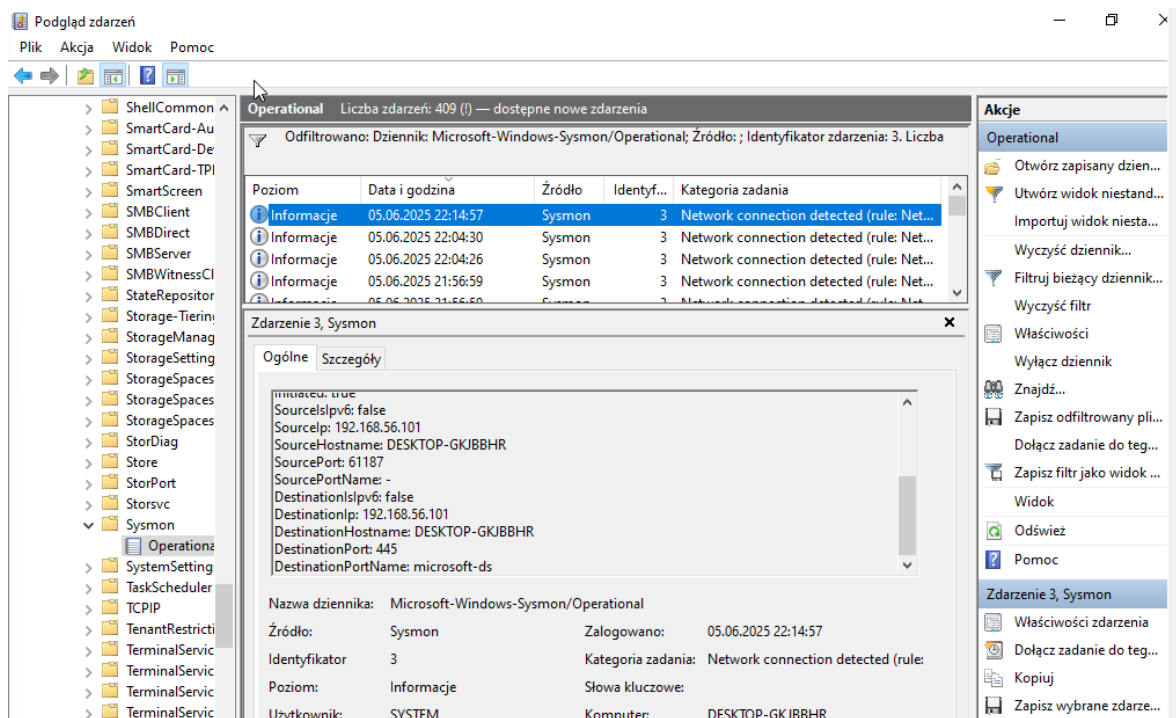
Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::4a0:23c2:bbe6:d291%3
    IPv4 Address. . . . . : 192.168.56.101
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

PS C:\Windows\system32> $start = Get-Date
PS C:\Windows\system32> 1..1024 | ForEach-Object {
>> if (Test-NetConnection -ComputerName 192.168.56.101 -Port $_ -InformationLevel Quiet){
>> Write-Output "$_ open"
>> }
>> }
WARNING: TCP connect to (192.168.56.101 : 1) failed
WARNING: TCP connect to (192.168.56.101 : 2) failed
WARNING: TCP connect to (192.168.56.101 : 3) failed
WARNING: TCP connect to (192.168.56.101 : 4) failed
WARNING: TCP connect to (192.168.56.101 : 5) failed
WARNING: TCP connect to (192.168.56.101 : 6) failed
WARNING: TCP connect to (192.168.56.101 : 7) failed
WARNING: TCP connect to (192.168.56.101 : 8) failed
WARNING: TCP connect to (192.168.56.101 : 9) failed
WARNING: TCP connect to (192.168.56.101 : 10) failed
WARNING: TCP connect to (192.168.56.101 : 11) failed
WARNING: TCP connect to (192.168.56.101 : 12) failed
WARNING: TCP connect to (192.168.56.101 : 13) failed
WARNING: TCP connect to (192.168.56.101 : 14) failed
WARNING: TCP connect to (192.168.56.101 : 15) failed
WARNING: TCP connect to (192.168.56.101 : 16) failed
WARNING: TCP connect to (192.168.56.101 : 17) failed
WARNING: TCP connect to (192.168.56.101 : 18) failed
WARNING: TCP connect to (192.168.56.101 : 19) failed
WARNING: TCP connect to (192.168.56.101 : 20) failed
WARNING: TCP connect to (192.168.56.101 : 21) failed
WARNING: TCP connect to (192.168.56.101 : 22) failed
WARNING: TCP connect to (192.168.56.101 : 23) failed
WARNING: TCP connect to (192.168.56.101 : 24) failed
WARNING: TCP connect to (192.168.56.101 : 25) failed
```

Rysunek 5.5 Uruchomienie skryptu skanującego porty

Na Rys. 5.7 przedstawiono konsolę PowerShell, która pokazuje wyniki działania wcześniej wspomnianego skryptu. Skrypt zidentyfikował otwarte porty: 135, 139 i 445, co oznacza, że były one dostępne i reagowały na zapytania TCP.



Rysunek 5.7 Zdarzenie Sysmon Event ID 3

Treść wyeksportowanego loga:

Tabela 5.1 Wyeksportowany log Sysmon Event ID 3

Atrybut	Wartość
Poziom logu	Informacje
Data/godzina lokalna	05.06.2025 22:14
Źródło zdarzenia	Microsoft-Windows-Sysmon
ID zdarzenia	3 (Network connection detected)
Proces	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Użytkownik	DESKTOP-GKJBBHR\Admin
Protokół	TCP
Szczegóły połączenia	
IP źródłowe	192.168.56.101 (DESKTOP-GKJBBHR)
Port źródłowy	61187
IP docelowe	192.168.56.101 (DESKTOP-GKJBBHR)
Port docelowy	445 (microsoft-ds)
Inicjacja	Połączenie inicjowane przez proces
Znaczenie zdarzenia	Lokalna próba połączenia z portem SMB (potencjalne skanowanie lokalne)

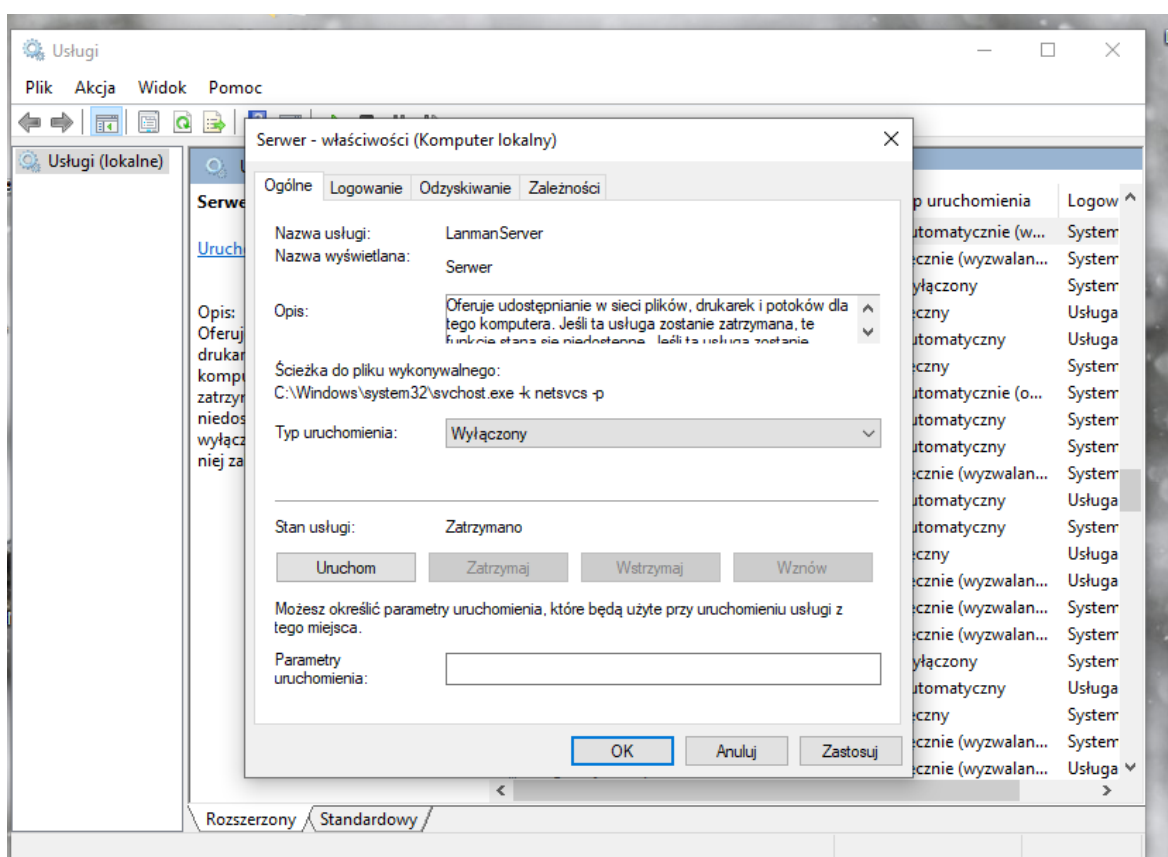
Źródło: Opracowanie własne

Po przeprowadzeniu testu przywrócono czysty snapshot maszyny. W ramach symulacji strategii obronnej M1042 - Disable or Remove Feature or Program, zdecydowano się na wyłączenie usługi „Server”, która obsługuje m.in. port 445.

W ramach tej operacji:

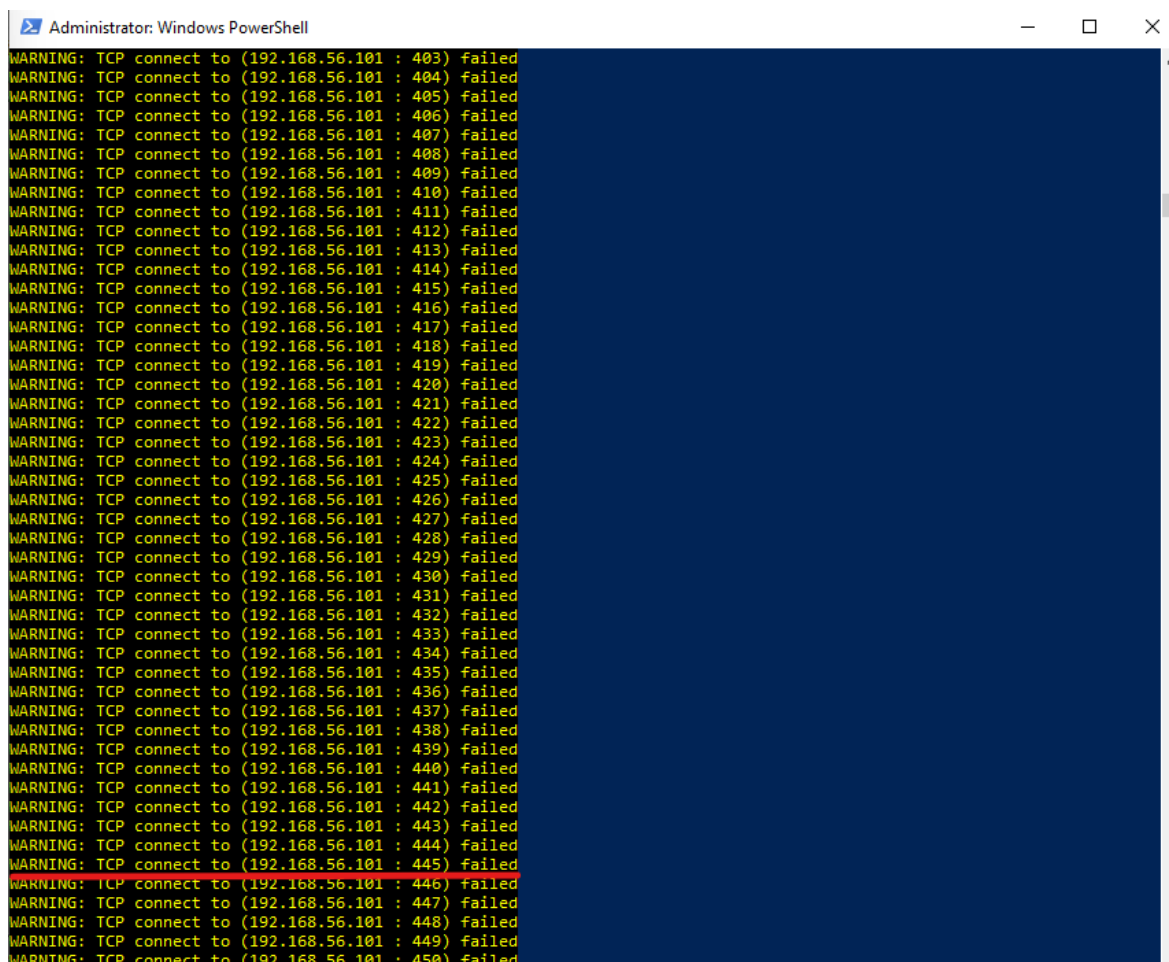
1. Otworzono services.msc.
2. Znaleziono usługę Lanman Server.
3. Zmieniono jej tryb uruchamiania na „Wyłączony”, a następnie ją zatrzymano.

Efekt tej operacji można zobaczyć na Rys. 5.9



Rysunek 5.8 Wyłączenie usługi Lanman Server

Po ponownym uruchomieniu testu skanowania portów, port 139 nie był już wykrywany jako otwarty, co oznacza, że nie był już dostępny z zewnątrz. Na Rys. 5.10 przedstawiono, że spośród wcześniej otwartych portów (135, 139, 445), port 139 nie pojawia się już w wynikach.



```
Administrator: Windows PowerShell
WARNING: TCP connect to (192.168.56.101 : 403) failed
WARNING: TCP connect to (192.168.56.101 : 404) failed
WARNING: TCP connect to (192.168.56.101 : 405) failed
WARNING: TCP connect to (192.168.56.101 : 406) failed
WARNING: TCP connect to (192.168.56.101 : 407) failed
WARNING: TCP connect to (192.168.56.101 : 408) failed
WARNING: TCP connect to (192.168.56.101 : 409) failed
WARNING: TCP connect to (192.168.56.101 : 410) failed
WARNING: TCP connect to (192.168.56.101 : 411) failed
WARNING: TCP connect to (192.168.56.101 : 412) failed
WARNING: TCP connect to (192.168.56.101 : 413) failed
WARNING: TCP connect to (192.168.56.101 : 414) failed
WARNING: TCP connect to (192.168.56.101 : 415) failed
WARNING: TCP connect to (192.168.56.101 : 416) failed
WARNING: TCP connect to (192.168.56.101 : 417) failed
WARNING: TCP connect to (192.168.56.101 : 418) failed
WARNING: TCP connect to (192.168.56.101 : 419) failed
WARNING: TCP connect to (192.168.56.101 : 420) failed
WARNING: TCP connect to (192.168.56.101 : 421) failed
WARNING: TCP connect to (192.168.56.101 : 422) failed
WARNING: TCP connect to (192.168.56.101 : 423) failed
WARNING: TCP connect to (192.168.56.101 : 424) failed
WARNING: TCP connect to (192.168.56.101 : 425) failed
WARNING: TCP connect to (192.168.56.101 : 426) failed
WARNING: TCP connect to (192.168.56.101 : 427) failed
WARNING: TCP connect to (192.168.56.101 : 428) failed
WARNING: TCP connect to (192.168.56.101 : 429) failed
WARNING: TCP connect to (192.168.56.101 : 430) failed
WARNING: TCP connect to (192.168.56.101 : 431) failed
WARNING: TCP connect to (192.168.56.101 : 432) failed
WARNING: TCP connect to (192.168.56.101 : 433) failed
WARNING: TCP connect to (192.168.56.101 : 434) failed
WARNING: TCP connect to (192.168.56.101 : 435) failed
WARNING: TCP connect to (192.168.56.101 : 436) failed
WARNING: TCP connect to (192.168.56.101 : 437) failed
WARNING: TCP connect to (192.168.56.101 : 438) failed
WARNING: TCP connect to (192.168.56.101 : 439) failed
WARNING: TCP connect to (192.168.56.101 : 440) failed
WARNING: TCP connect to (192.168.56.101 : 441) failed
WARNING: TCP connect to (192.168.56.101 : 442) failed
WARNING: TCP connect to (192.168.56.101 : 443) failed
WARNING: TCP connect to (192.168.56.101 : 444) failed
WARNING: TCP connect to (192.168.56.101 : 445) failed
WARNING: TCP connect to (192.168.56.101 : 446) failed
WARNING: TCP connect to (192.168.56.101 : 447) failed
WARNING: TCP connect to (192.168.56.101 : 448) failed
WARNING: TCP connect to (192.168.56.101 : 449) failed
WARNING: TCP connect to (192.168.56.101 : 450) failed
```

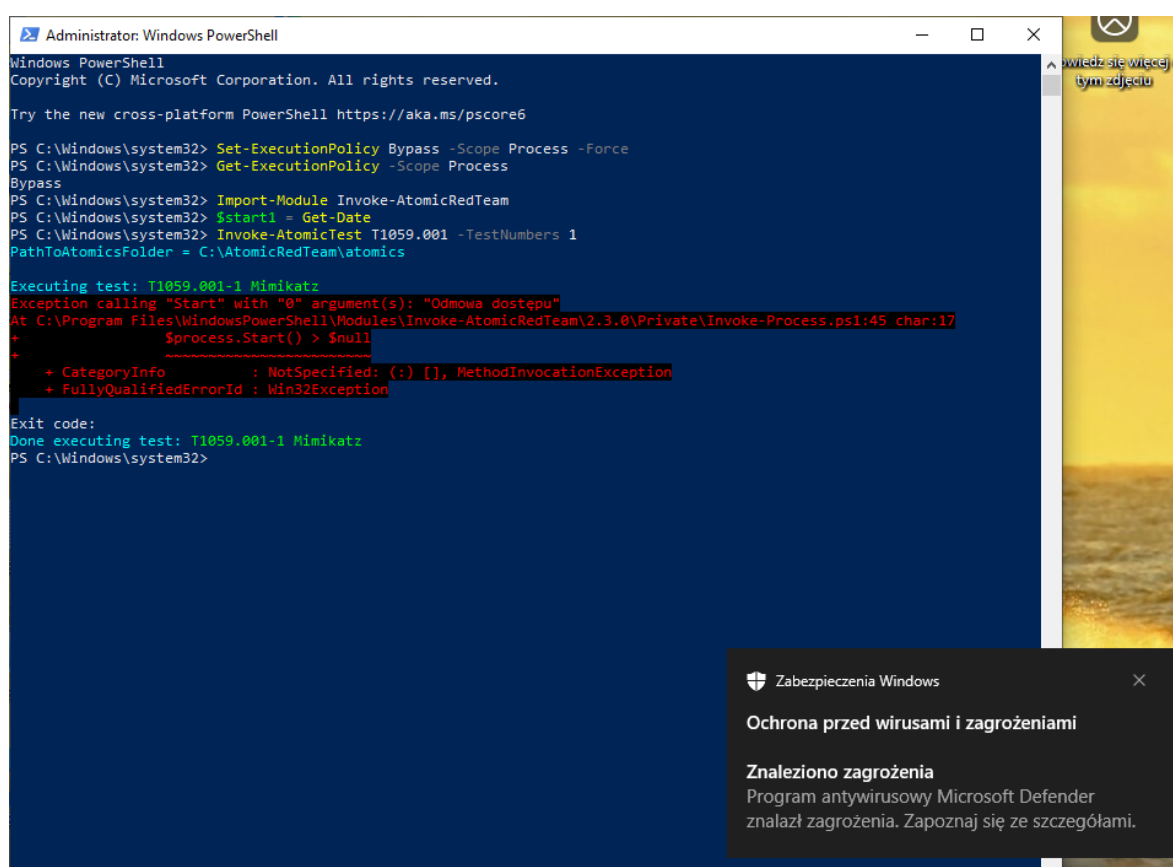
Rysunek 5.9 Zamknięty port 445

Scenariusz A potwierdził, że narzędzie Sysmon jest stanie rejestrować aktywność skanowania portów. Zastosowanie strategii M1042 poprzez wyłączenie zbędnej usługi (Lanman Server) skutecznie „ukryło” port 445 przed skanowaniem. Taka forma obrony może znacząco ograniczyć możliwość wykrycia potencjalnych szans atakującego na wykrycie potencjalnych punktów wejścia, co z kolei utrudnia mu podjęcie kolejnych działań w planowanym łańcuchu ataku.

5.3 Scenariusz B (Wykorzystanie skryptu PowerShell do pobrania i uruchomienia pliku wykonywalnego)

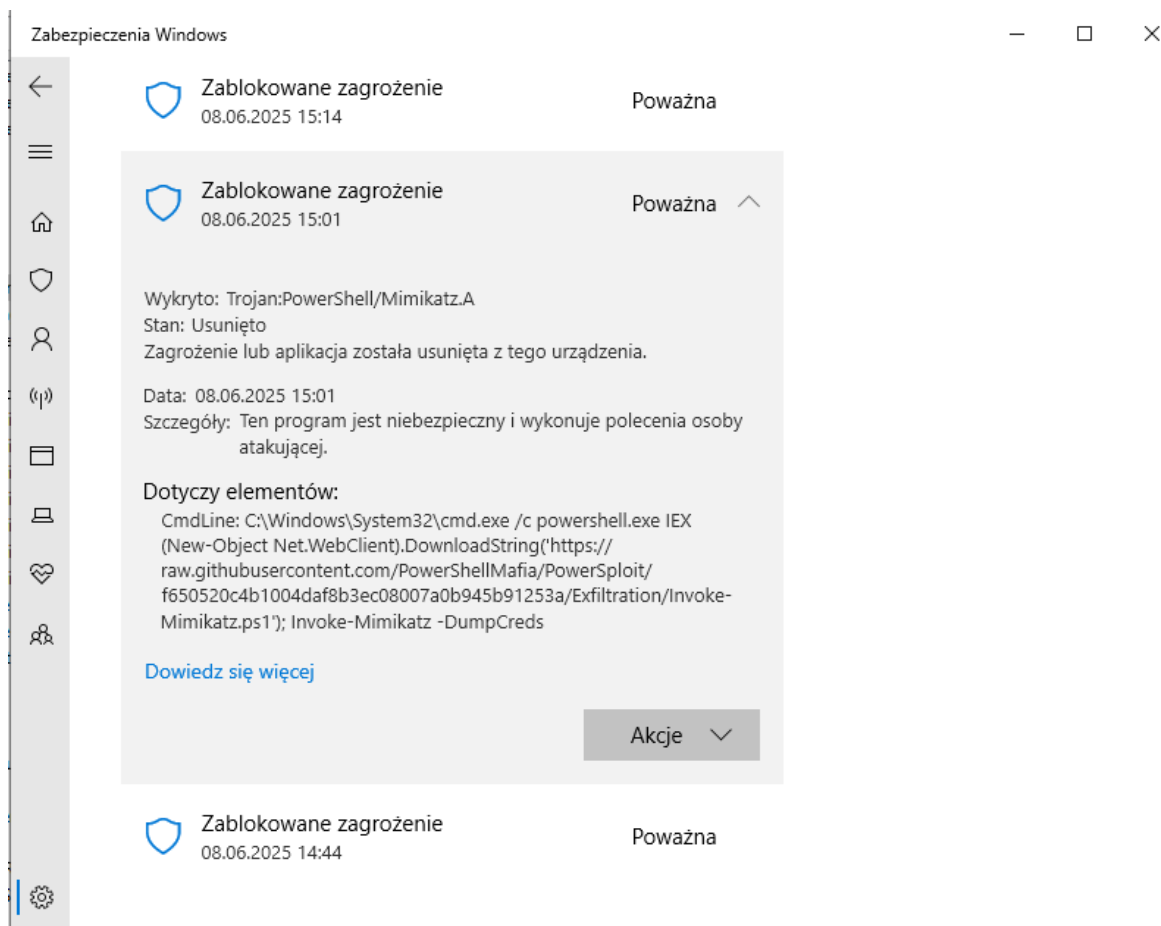
Scenariusz B miał na celu sprawdzenie czy mechanizmy obronne są w stanie wykryć i zatrzymać zdalne pobranie oraz uruchomienie skryptu przy użyciu PowerShell.

Test rozpoczął się od próby wywołania skryptu przy użyciu modułu Invoke-AtomicTest. Polecenie nie wykonało się, ponieważ zostało wykryte i zablokowane poprzez działającą „ochronę w czasie rzeczywistym” Windows Defendera co przedstawiono na rysunku Rys. 5.11.



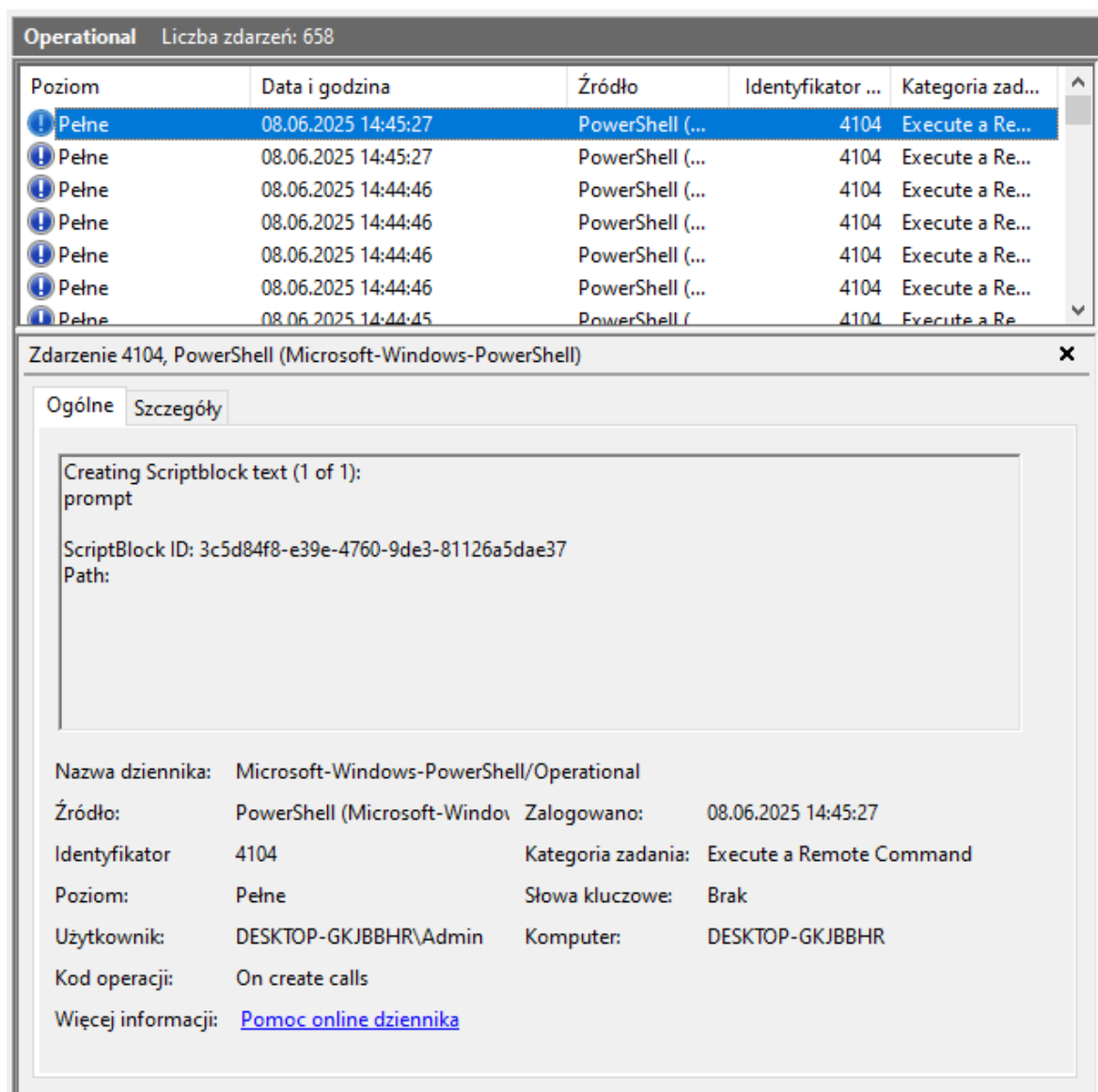
Rysunek 5.10 Próba wykonania testu T1059.001

Na rysunku Rys. 5.12, widoczna jest szczegółowa lista zablokowanych zagrożeń. Każdy wpis dotyczył pliku lub operacji sklasyfikowanej przez Defendera jako niebezpieczna, co potwierdza skuteczność strategii ochrony opisanej jako M1049 (Antivirus/Antimalware)



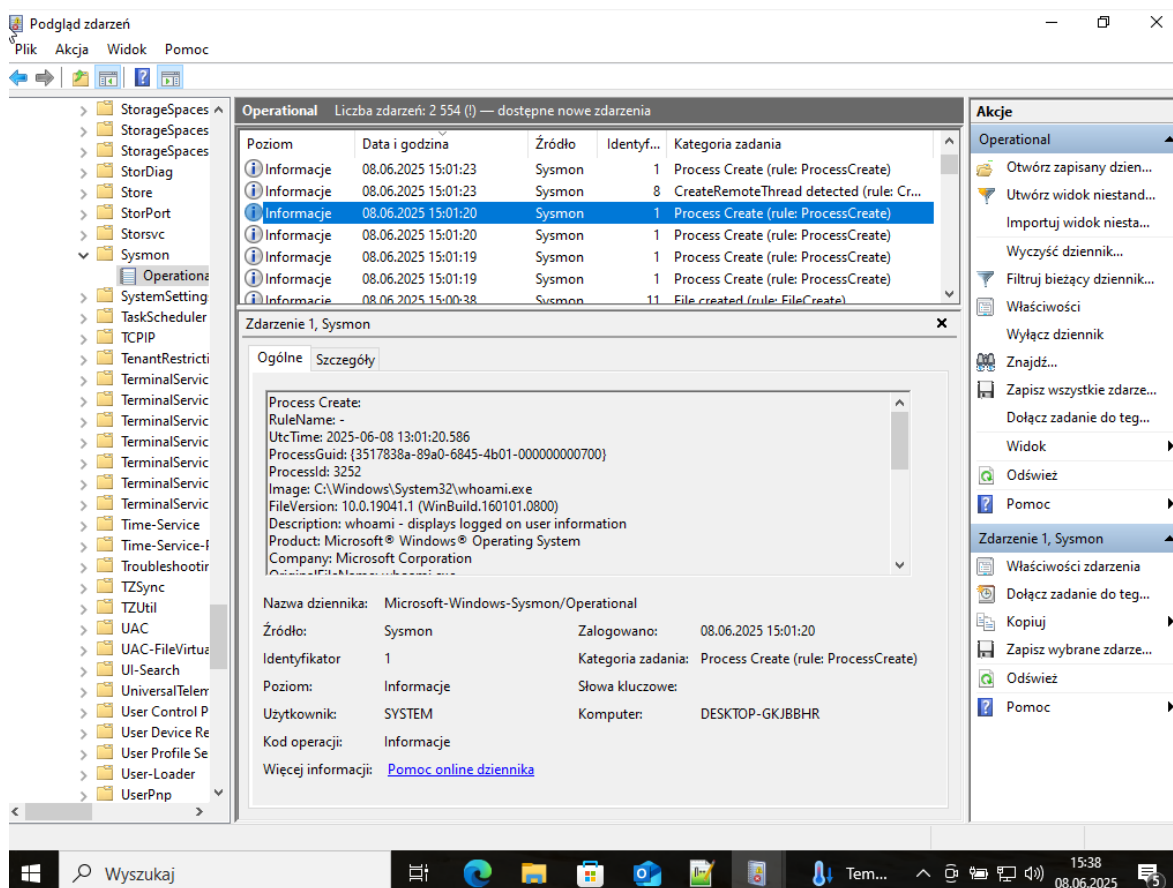
Rysunek 5.11 Zablokowane zagrożenia

Po uruchomieniu testu, który symuluje technikę T1059.001, w dzienniku Microsoft-Windows-PowerShell/Operational zarejestrowano ponad 40 wpisów co przedstawiono na Rys. 5.13. Te logi dokumentują uruchomienie skryptu, wykonanie konkretnych poleceń PowerShell oraz reakcję systemu.



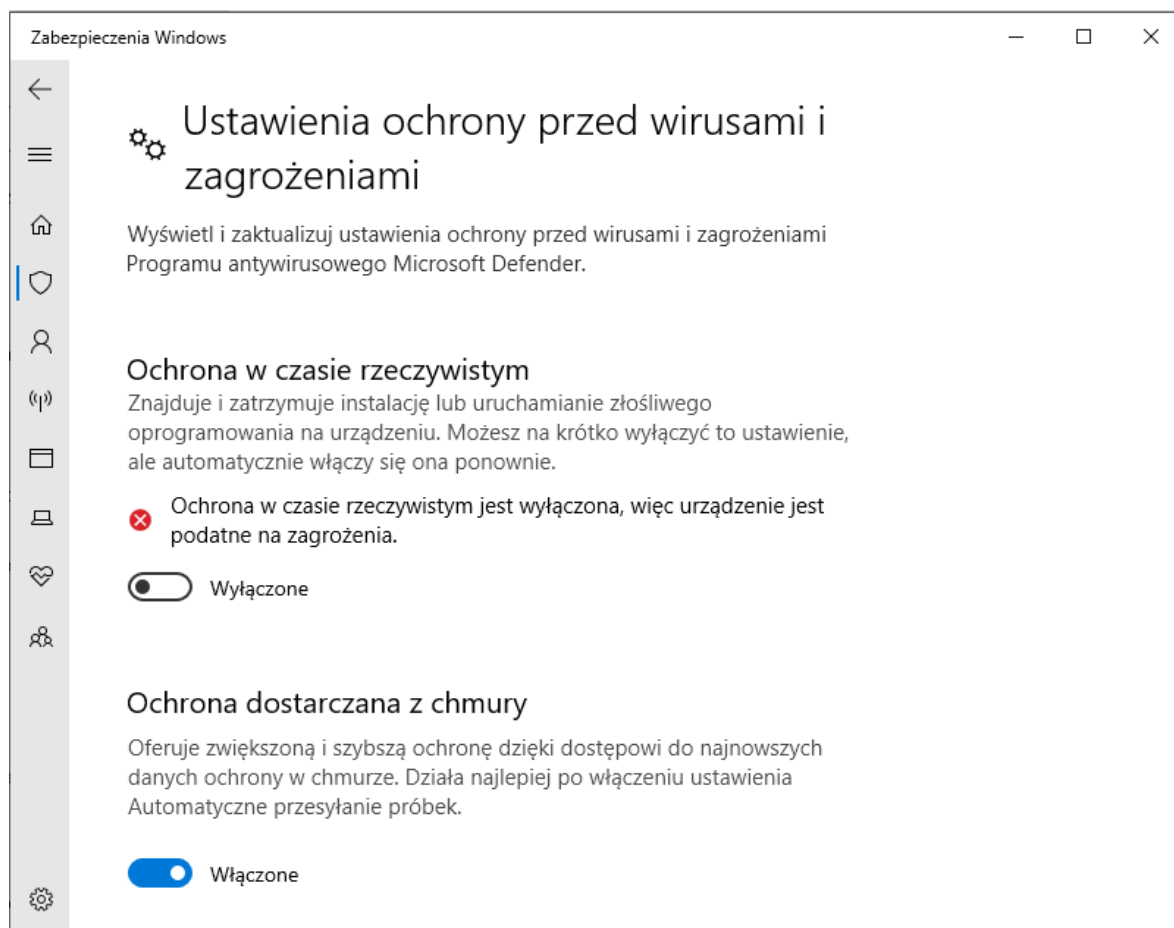
Rysunek 5.12 Logi PowerShell/Operational

Mimo włączonej ochrony mechanizm Sysmon zarejestrował próbę utworzenia nowego procesu co przedstawiono na Rys. 5.14. Na obrazie można zauważyć kilka kolejnych wpisów, z których wynika, że podczas ataku aktywne jest zdarzenie Event ID 1 (Process Create).



Rysunek 5.13 Zarejestrowany Event 1

Kolejnym krokiem było przywrócenie czystej migawki maszyny oraz wyłączenie ochrony w czasie rzeczywistym w Windows Defenderze. Na Rys. 5.15 można zobaczyć panel ustawień, gdzie opcja ochrony w czasie rzeczywistym pozostaje nieaktywna.



Rysunek 5.14 Wyłączona "ochrona w czasie rzeczywistym"

Po wyłączeniu ochrony skrypt zadziałał bez przeszkód co przedstawiono na Rys. 5.16.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Import-Module Invoke-AtomicRedTeam
PS C:\Windows\system32> Invoke-AtomicTest T1059.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

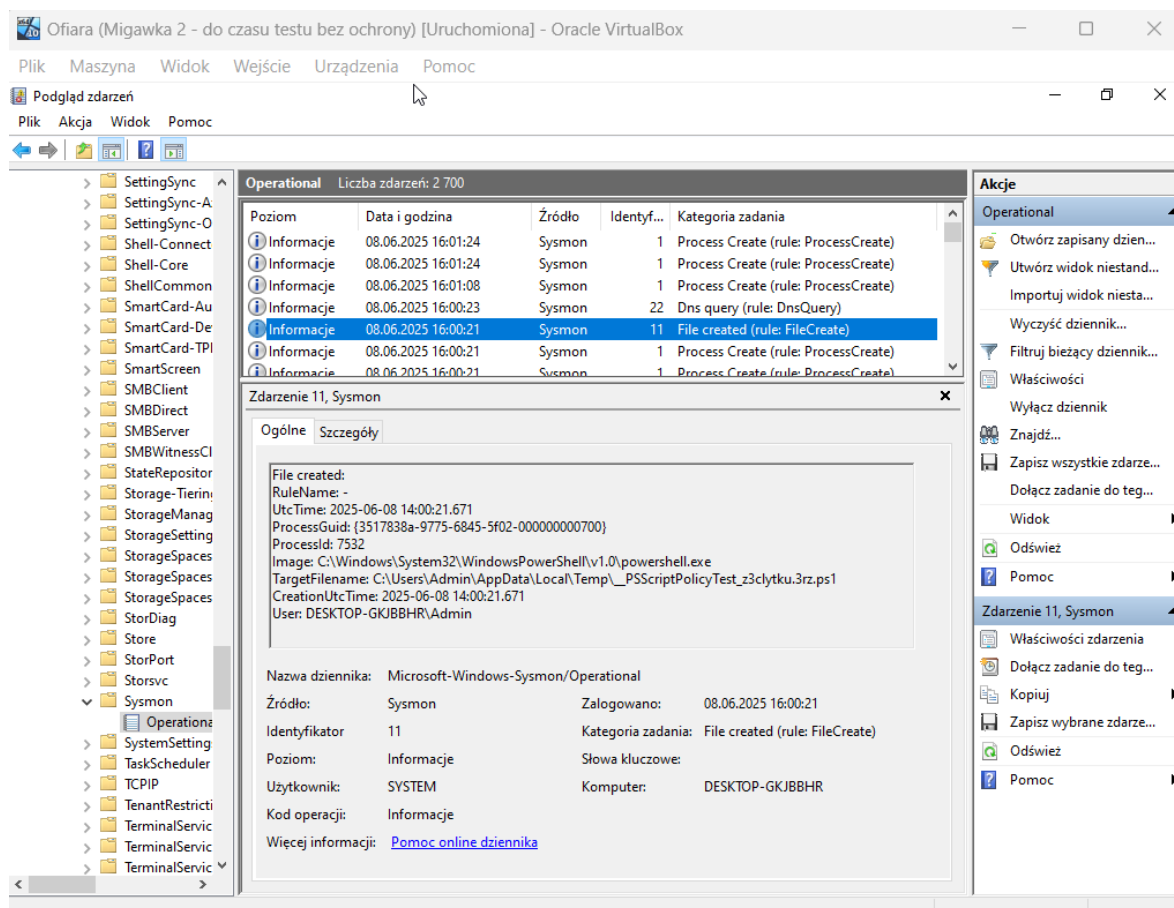
Executing test: T1059.001-1 Mimikatz
Exception calling "DownloadString" with "1" argument(s): "Nie można rozpoznać nazwy zdalnej: 'raw.githubusercontent.com'."
At line:1 char:1
+ IEX (New-Object Net.WebClient).DownloadString('https://raw.githubuser ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : WebException

Invoke-Mimikatz : The term 'Invoke-Mimikatz' is not recognized as the name of a cmdlet, function, script file, or opera
ble program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:187
+ ... 45b91253a/Exfiltration/Invoke-Mimikatz.ps1'); Invoke-Mimikatz -DumpCr ...
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (Invoke-Mimikatz:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

Exit code: 1
Done executing test: T1059.001-1 Mimikatz
PS C:\Windows\system32>
```

Rysunek 5.15 Wykonanie się testu T1059.001

Na Rysunku 5.17 widnieje wpis Sysmon Event ID 11 (File Create), pokazujący, że powershell.exe faktycznie utworzył plik testowy na dysku.



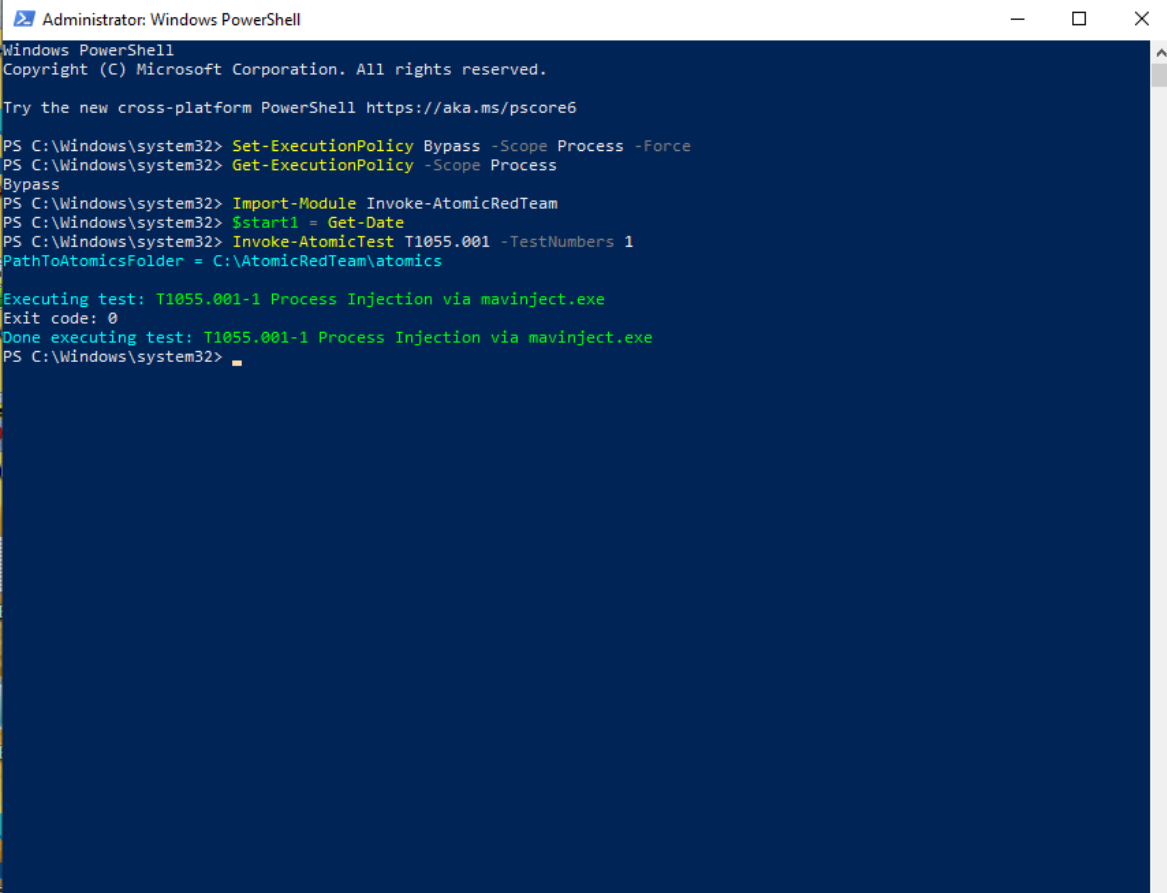
Rysunek 5.16 Zarejestrowany Event 11

Podsumowując, przeprowadzony Scenariusz B potwierdza, że działająca ochrona w czasie rzeczywistym Windows Defendera (strategia M1049) spełnia ważną rolę w powstrzymywaniu zdalnych ataków realizowanych przez PowerShell.

5.4 Scenariusz C (Wstrzyknięcie kodu do procesu)

Scenariusz C miał za zadanie sprawdzić, czy mechanizmy ochronne systemu potrafią wykryć i zablokować próbę wstrzyknięcia kodu do procesu.

Test rozpoczął się od wykonania skryptu, przy pomocy modułu Invoke-AtomicTest co zostało przedstawione jest na Rys. 5.18.



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

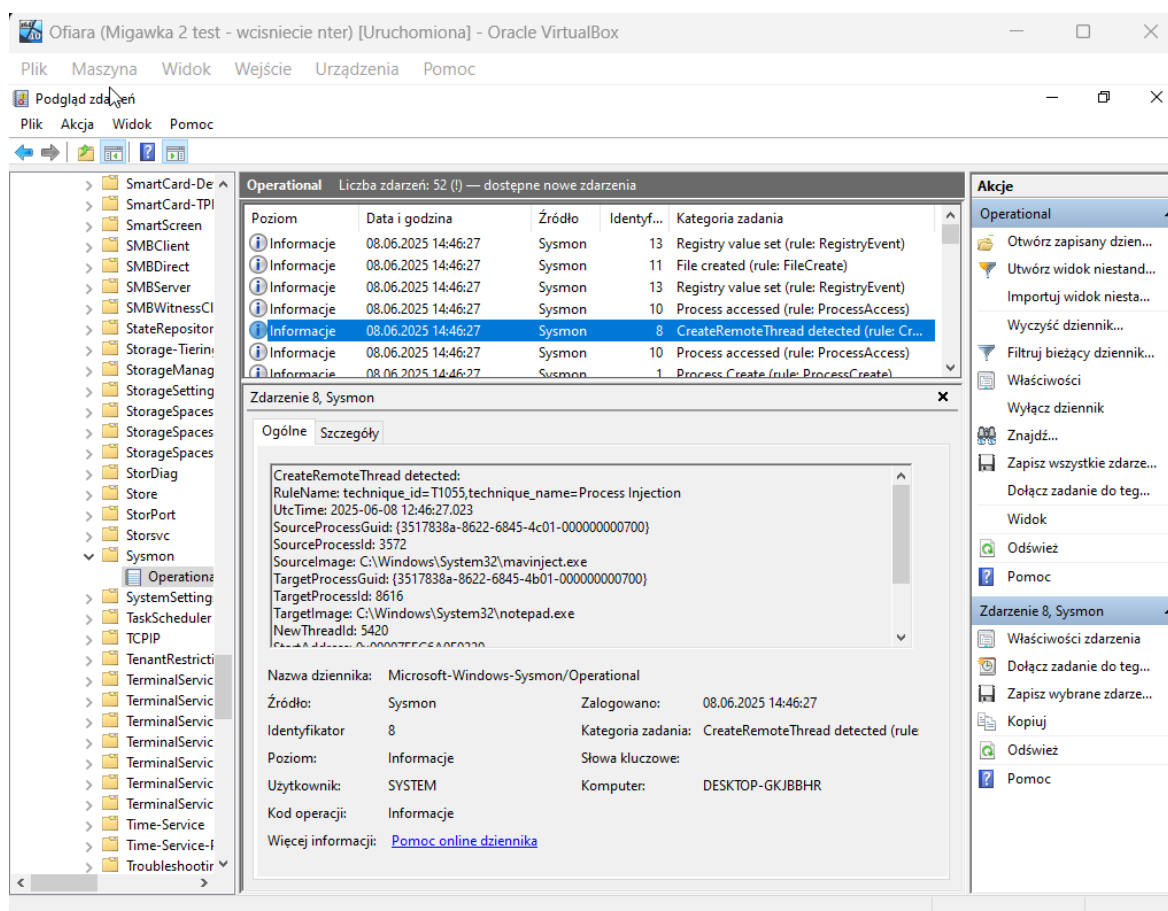
Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Get-ExecutionPolicy -Scope Process
Bypass
PS C:\Windows\system32> Import-Module Invoke-AtomicRedTeam
PS C:\Windows\system32> $start1 = Get-Date
PS C:\Windows\system32> Invoke-AtomicTest T1055.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1055.001-1 Process Injection via mavinject.exe
Exit code: 0
Done executing test: T1055.001-1 Process Injection via mavinject.exe
PS C:\Windows\system32>
```

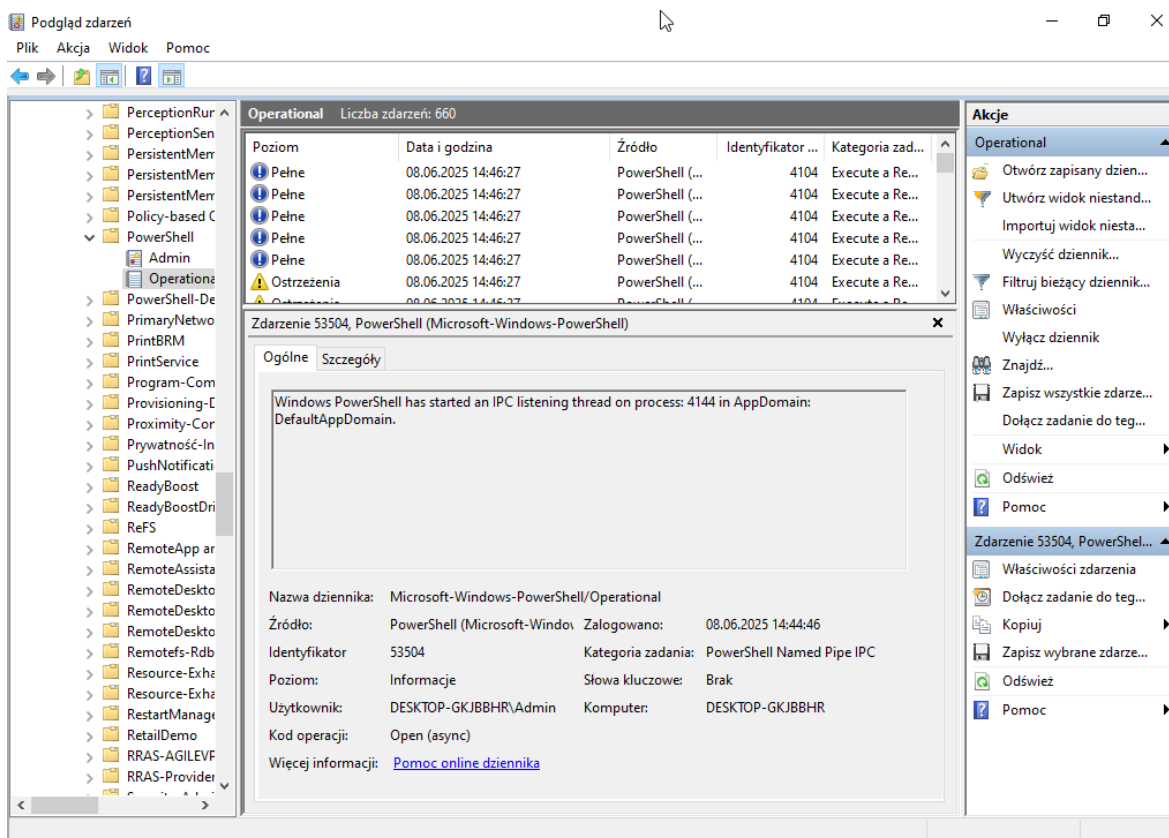
Rysunek 5.17 Wykonanie testu T1055.001

Na Rys. 5.19 przedstawiono, że wyniku ataku zebrano wszystkie powiązane logi z Sysmon, w tym między innymi wpisy: Event ID 1 (Process Create), Event ID 7, 8, 10, 11, 13 oraz 26.



Rysunek 5.18 Logi Sysmon

Dodatkowo, w dzienniku PowerShell zidentyfikowano aktywność związaną z testem: 31 pełnych wpisów (PowerShell Operational ID 4104), 33 ostrzeżenia oraz 3 wpisy informacyjne co ukazuje Rys. 5.20 Zakres i różnorodność tych danych jednoznacznie wskazują na wykonanie sekwencji ataku w środowisku.



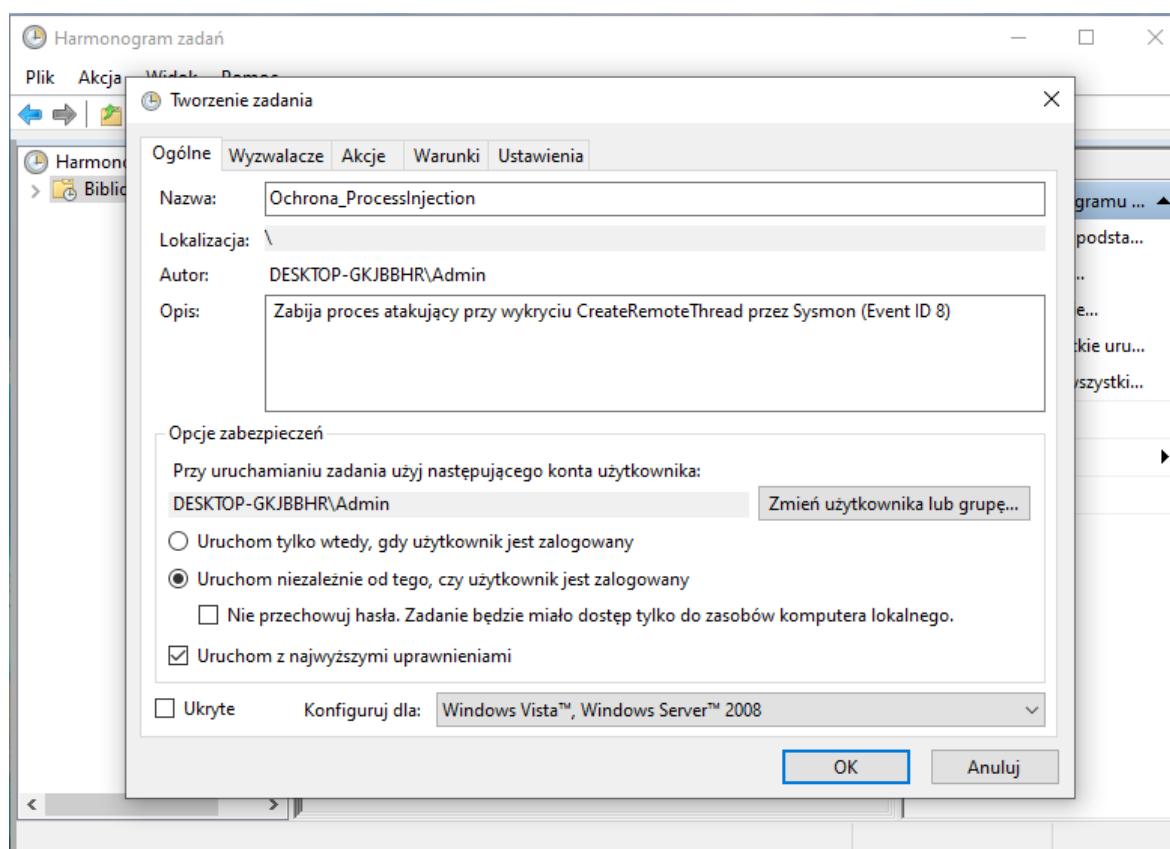
Rysunek 5.19 Logi PowerShell

W kolejnym kroku, zasymulowano działanie strategii ochronnej M1040 - Behavior Prevention on Endpoint. Zastosowano uproszczony mechanizm reakcji. Na maszynie skonfigurowano harmonogram zadań, monitorujący zdarzenia Sysmon o Event ID 8 (CreateRemoteThread). Gdy tylko takie zdarzenie zostało wykryte, automatycznie uruchamiany był skrypt PowerShell zamykający każdy nowo otwarty proces powershell.exe. Skrypt wyglądał następująco:

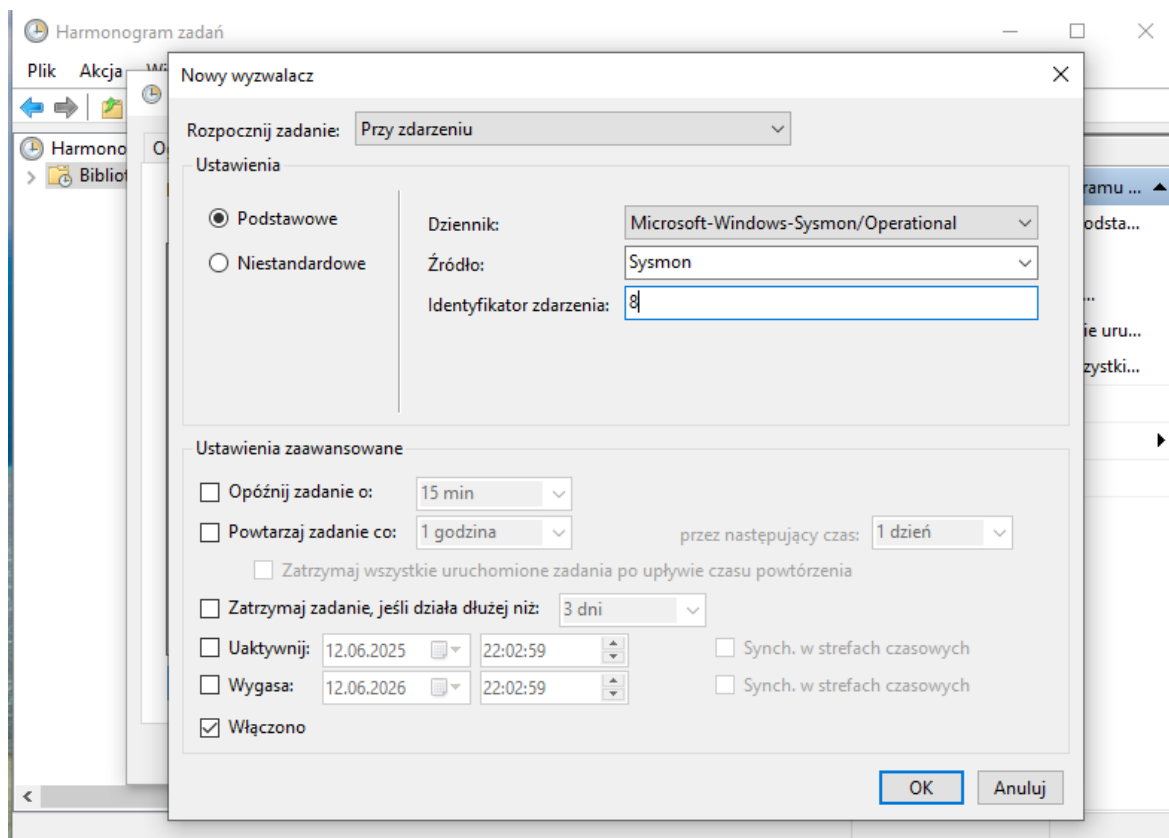
```
PS C:\Users\Admin> „-WindowStyle Hidden -Command "Get-Process -Name powershell
| Where-Object { $_.StartTime -gt (Get-Date).AddSeconds(-10) } | Stop-Process -
Force"”
```

Rysunek 5.20 Listing kodu

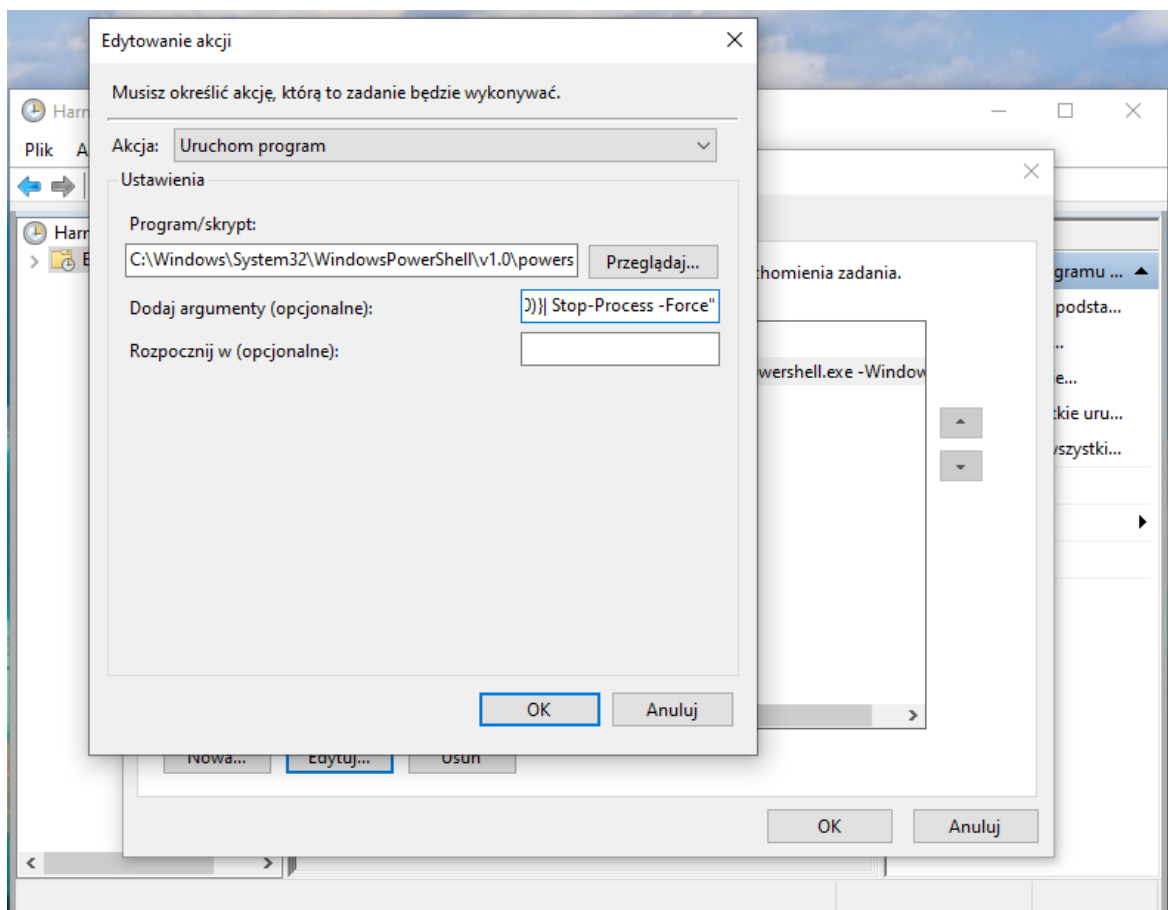
Na Rysunkach 5.22, 5.23, 5.24 przedstawiono konfiguracje Harmonogramu zadań.



Rysunek 5.21 Harmonogram zadań - tworzenie zadania

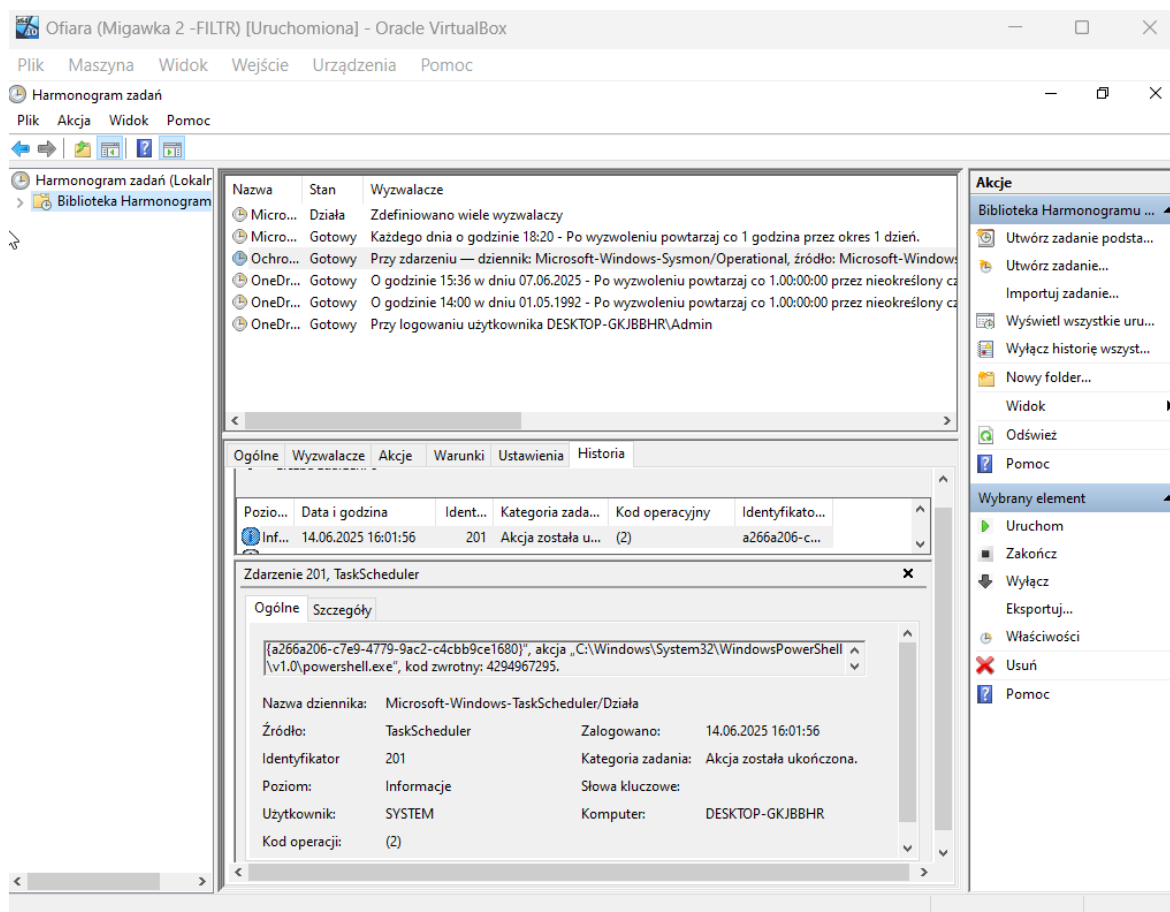


Rysunek 5.22 Harmonogram zadań - wyzwalacz



Rysunek 5.23 Harmonogram zadań - edytowanie akcji

Choć to podejście dosyć proste, oddaje ideę „*behavior blockingu*” - czyli szybkiej reakcji na nietypowe, potencjalnie szkodliwe zachowanie procesu. Wynik wykrycia i wykonania akcji można zobaczyć na Rys. 5.25.

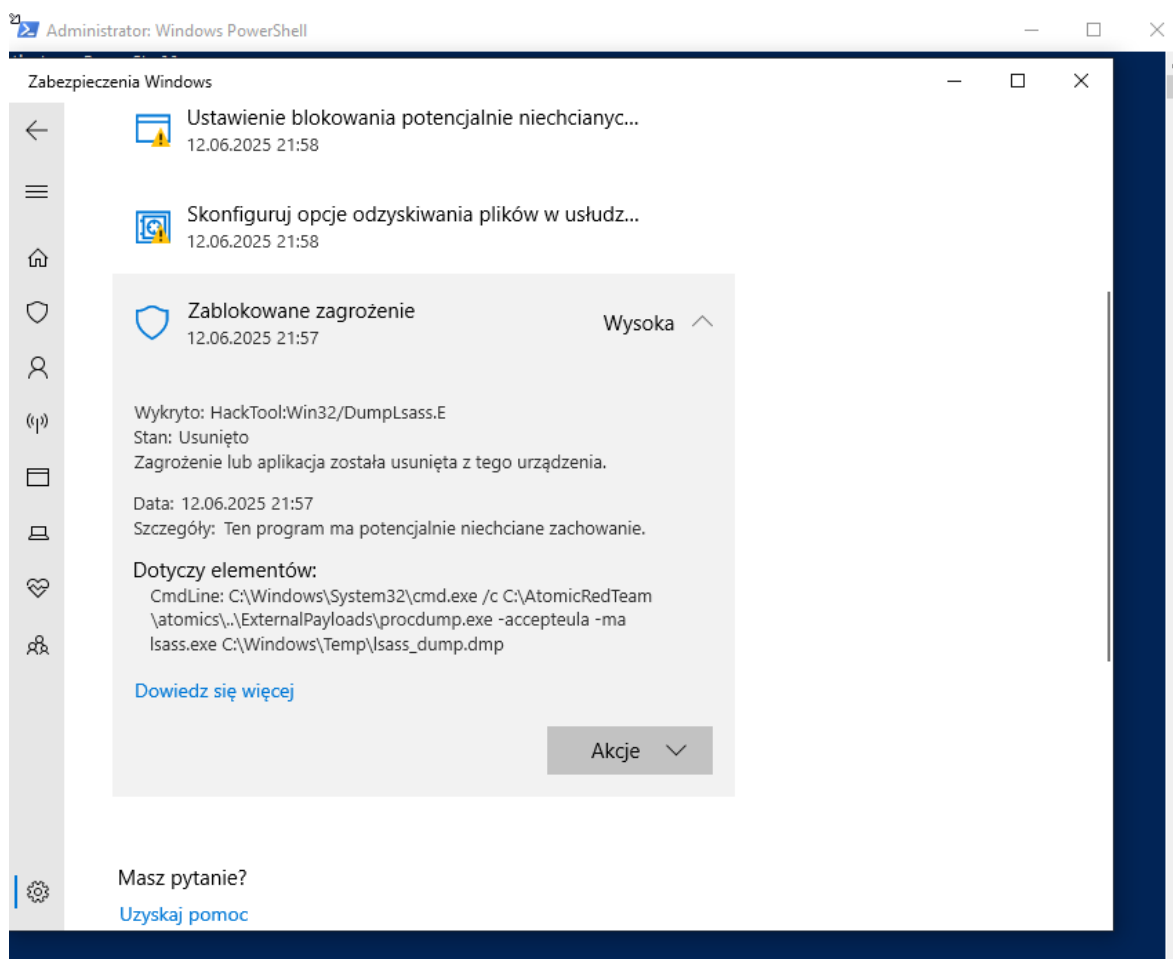


Rysunek 5.24 Harmonogram Zadań - Reakcja na Event ID 8 Sysmon

5.5 Scenariusz D (Dumping pamięci LSASS)

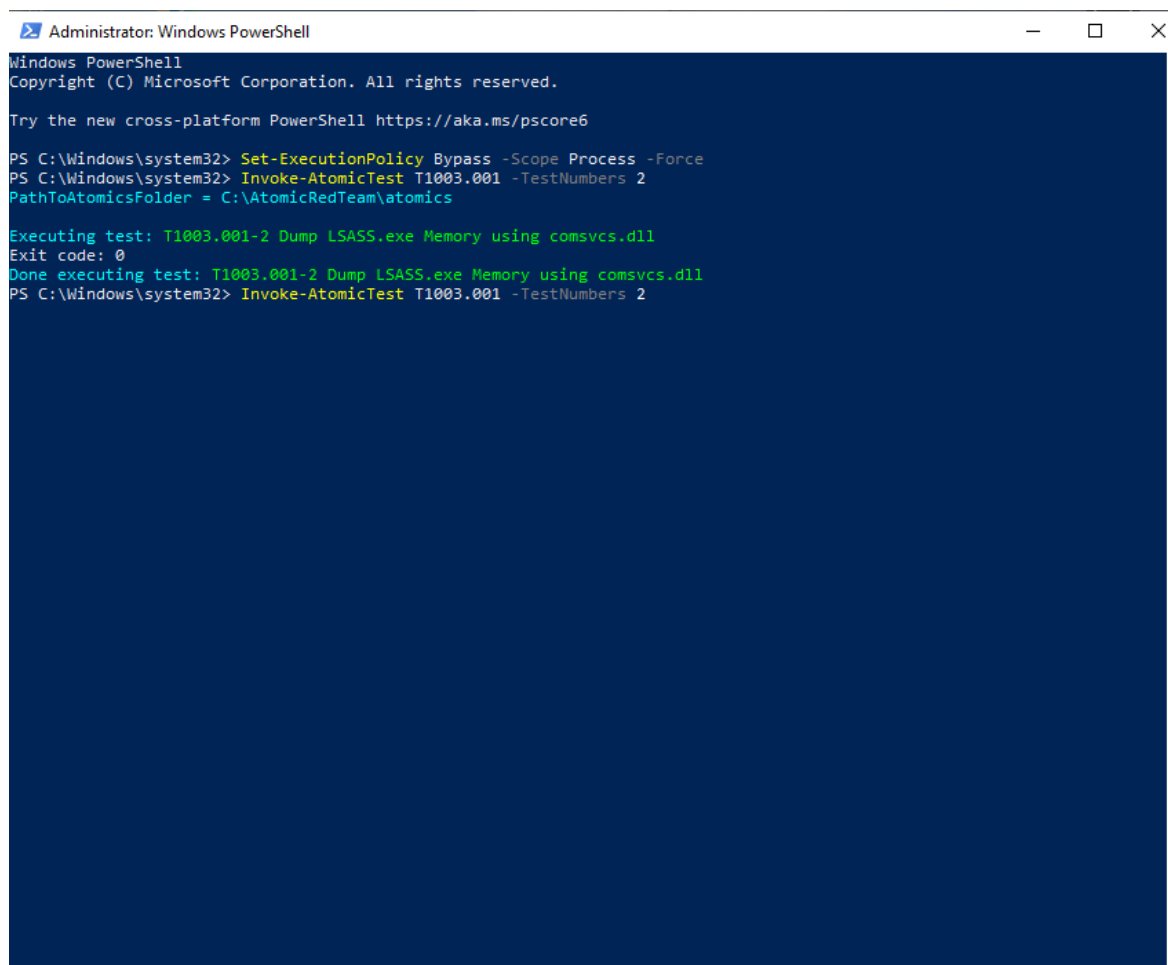
Scenariusz D miał na celu sprawdzenie czy mechanizmy ochronne na maszynie „Ofiara” są w stanie zarejestrować i zablokować próbę zrzutu pamięci procesu LSASS.

Pierwszym krokiem symulacji było wykonanie polecenia `Invoke-AtomicTest T1003.001` w konsoli PowerShell. Pierwsza próba została zablokowana przez ochronie w czasie rzeczywistym Windows Defender, jak pokazano na rysunku 5.26.



Rysunek 5.26 Zablokowane zagrożenie

Następnie powtórzono test przy wyłączonej ochronie w czasie rzeczywistym. Skrypt wykonał się co potwierdza rysunek 5.27.



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

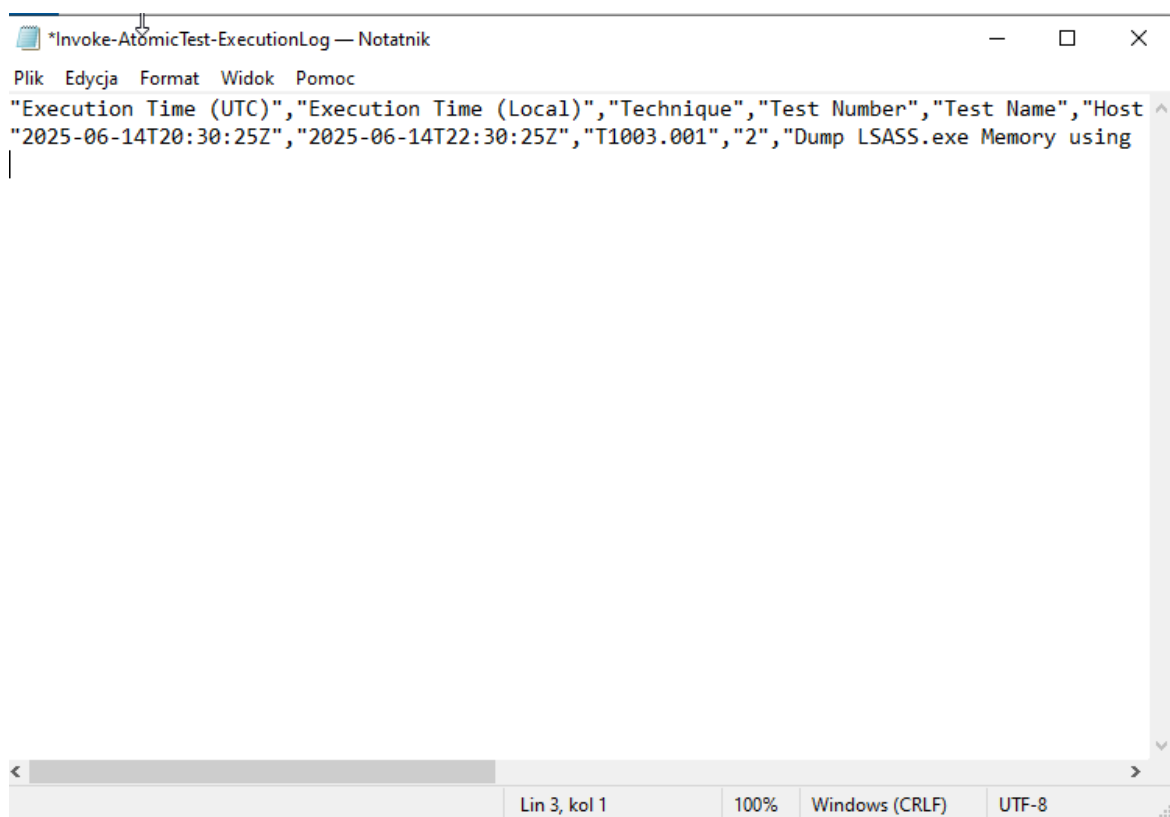
Try the new cross-platform PowerShell https://aka.ms/powershell

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Invoke-AtomicTest T1003.001 -TestNumbers 2
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
Exit code: 0
Done executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
PS C:\Windows\system32> Invoke-AtomicTest T1003.001 -TestNumbers 2
```

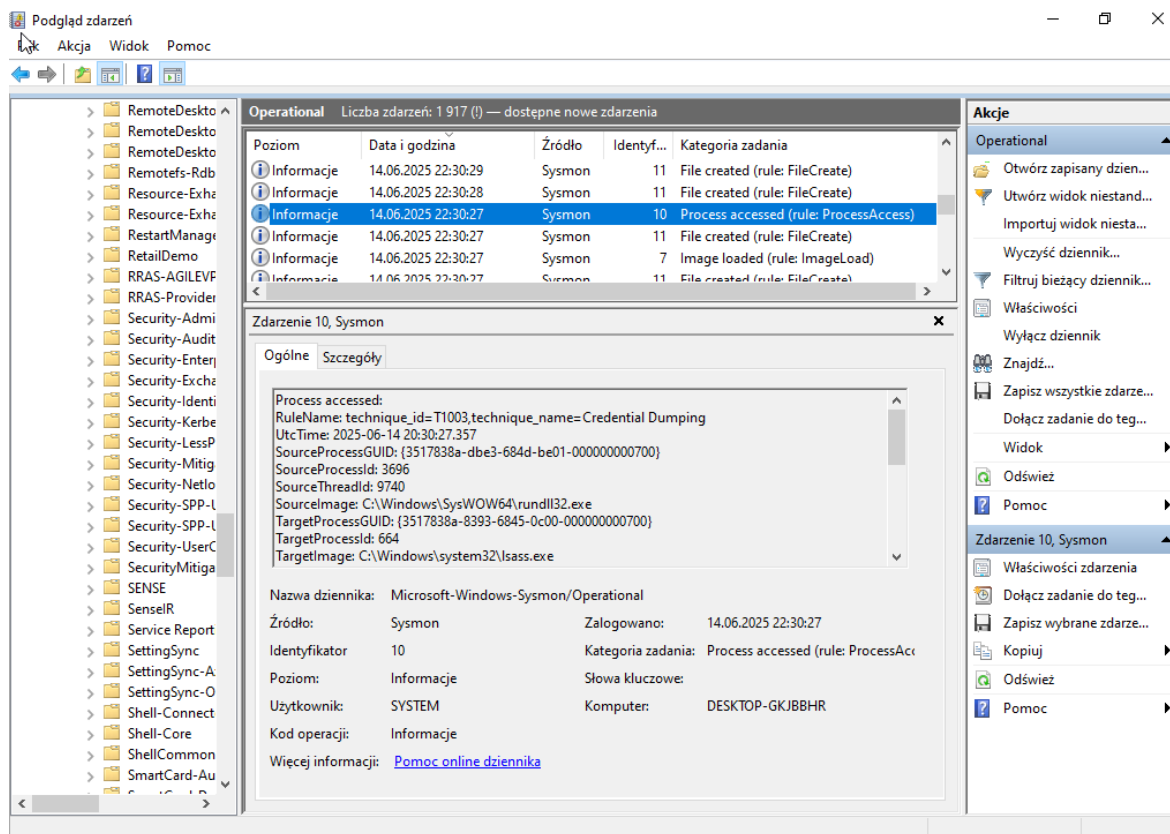
Rysunek 5.27 Wykonanie się testu T1003.001

Poprawne wykonanie się testu potwierdza również fakt pojawienia się pliku „Invoke-AtomicTest-ExecutionLog” na wirtualnej maszynie w katalogu tymczasowym. Treść tego pliku widzimy na Rys. 5.29.



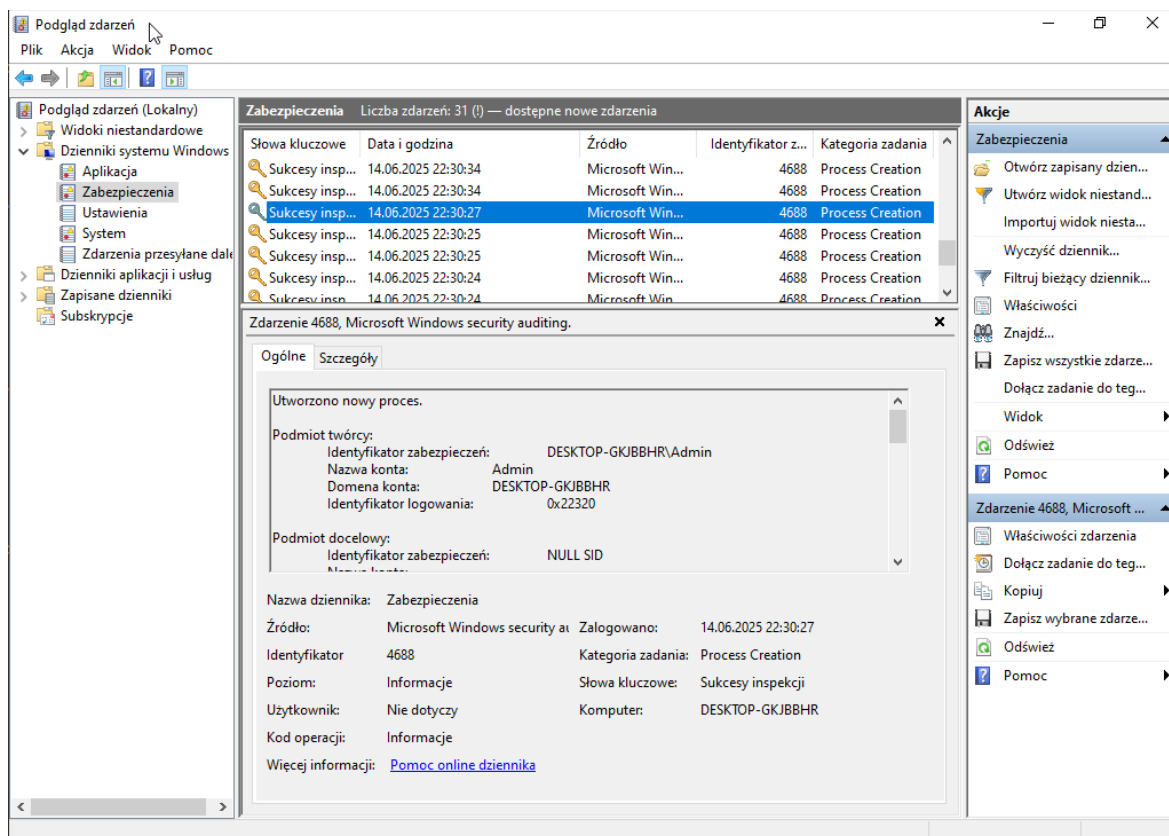
Rysunek 5.28 Treść pliku „Invoke-AtomicTest-ExecutionLog”

W dzienniku Sysmon odnotowano wpisy Event ID 1, informujące o rozpoczęciu procesu zrzutu pamięci oraz Event ID 10, który opisuje próbę dostępu do pamięci procesu lsass.exe. Wpisy te przedstawiono na Rys. 5.30.



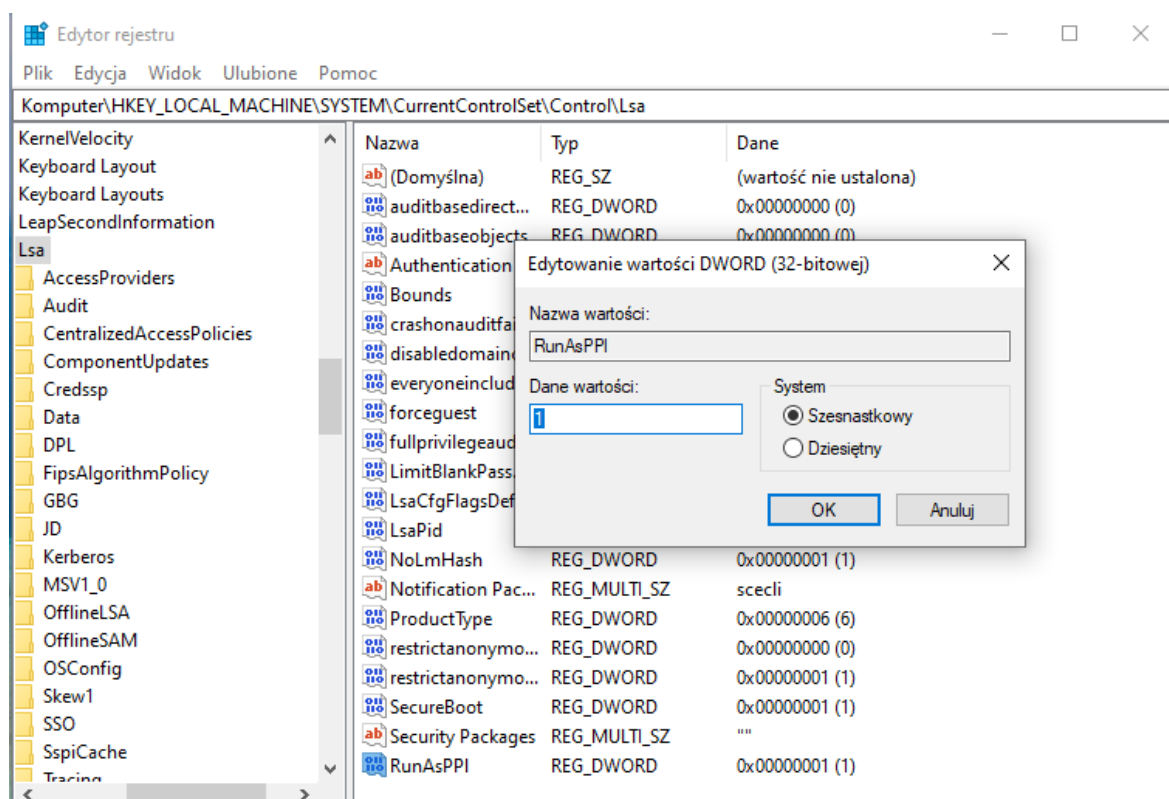
Rysunek 5.29 Wpisy Sysmon

Na rysunku 5.31 przedstawiono wpisy systemowego dziennika zabezpieczeń Event ID 4688 informujące o wykonywanym procesie.



Rysunek 5.30 Wpisy systemowego dziennika zabezpieczeń

Kolejnym krokiem było wprowadzenie obrony M1025 - Privileged Process Integrity. Przywrócono maszynę do ustawień początkowych, a następnie w Edytorze rejestru systemowego ustawiono wartość „DWORD” „RunAsPPL” na 1 w gałęzi „HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa” co widać na Rys 5.32. Po tej modyfikacji system został ponownie uruchomiony, aby zmiana mogła zacząć działać na poziomie jądra. Dzięki temu proces LSASS objęto ochroną w modelu „Protected Process Light”. W praktyce oznacza to, że tylko procesy posiadające odpowiednie uprawnienia mają dostęp do jego pamięci. To właśnie ma zapobiegać nieautoryzowanym próbom przechwytywania lub zrzutu danych, które są tam przechowywane.



Rysunek 5.31 Zmiana wartości w Edytorze rejestru

Po ponownym powtórzeniu testu nie zauważono, aby plik „Invoke-AtomicTest-ExecutionLog” został utworzony.

Włączenie wartości RunAsPPL=1 chroni LSASS na poziomie jądra, co oznacza, że tylko procesy z odpowiednimi uprawnieniami mogą uzyskać do niego dostęp. Dzięki temu standardowe narzędzia nie mogą „dumpować” pamięci LSASS, co znacznie utrudnia kradzież poświadczeń.

Podsumowanie i wnioski

Przeprowadzone symulacje typowych technik ataku dostarczyły pełnego obrazu zarówno możliwości detekcji, jak i skuteczności obrony w środowisku Windows. Każdy z testów odnosił się bezpośrednio do wybranych technik z macierzy, co pozwoliło na systematyczne sprawdzenie skuteczności poszczególnych mechanizmów obronnych przy zastosowaniu standardowych narzędzi zaimplementowanych w systemach Windows oraz dodatkowych zabezpieczeń.

Symulacje przeprowadzone z użyciem modułu Invoke-AtomicTest w połączeniu z taksonomią macierzy MITRE ATT&CK ukazały praktyczną wartość podejścia opartego na taktykach i technikach ataku. Struktura macierzy nie tylko umożliwia klasyfikację działań ofensywnych, ale także pozwala na ich klasyfikację i przypisanie im odpowiednich środków detekcji oraz obrony.

Mechanizmy rejestracji zdarzeń, szczególnie Sysmon, okazały się niezwykle cennym narzędziem do wykrywania ataku oraz do uzyskania wiadomości o jego przebiegu. Dzięki zastosowaniu różnych mechanizmów rejestracji zdarzeń, każde z badanych zagrożeń ujawniało się poprzez unikalny zestaw eventów, co umożliwiało jednoznaczną identyfikację rodzaju ataku. Przykładowo podczas skanowania portów (scenariusz A) dominowały wpisy Sysmon Event ID 3, które sygnalizowały próby nawiązywania połączeń sieciowych do portów. Prowadzi to do wniosku, że nawet bez komercyjnych rozwiązań klasy SIEM, dobrze skonfigurowane mechanizmy rejestrujące mogą znacznie pomóc z wykrywaniem i analizowaniem incydentów.

Zastosowanie symulacji zachowań typu „behavior blocking”, w tym tych opartych na regułach ASR oraz reakcjach na konkretne zdarzenia Sysmon, pokazało, że zablokowanie zachowania już na etapie jego wykrycia może skutecznie uniemożliwić dalsze kroki ataku. Nawet w uproszczonej formie, jak w przypadku użycia harmonogramu zadań reagującego na Event ID 8. Takie podejście okazało się efektywne i dobrze ilustruje potencjał strategii znanej jako Behavior Prevention on Endpoint (M1040).

W scenariuszu zdalnego pobierania i wykonywania kodu PowerShell (T1059.001), ochrona w czasie rzeczywistym Windows Defender (strategia M1049) spełniła swoje, skutecznie blokując nieautoryzowany ładunek i uniemożliwiając tworzenie plików wykonywalnych. Co więcej, domyślny Windows Defender zadziałał zaskakująco dobrze również w przypadku zrzutu pamięci LSASS (T1003.001), zatrzymując operację już na

etapie początkowym, mimo że pierwotnie nie przewidywano jego roli w tym teście. Potwierdza to, że ochrona w czasie rzeczywistym Windows Defendera może oferować solidną odporność nie tylko na tradycyjne metody pobierania i uruchamiania złośliwego oprogramowania, ale też na bardziej skomplikowane działania, które mogą naruszać integralność systemu, testy z użyciem modułu Atomic Red Team pokazały, że ochrona działa szybko i skutecznie. Umożliwia to zablokowanie ataku już na wczesnym etapie, co świadczy o jej wysokiej odporności na różnorodne techniki ofensywne.

Wyniki przeprowadzonych symulacji pokazały, że wykorzystanie różnorodnych mechanizmów obronnych takich jak rejestrowanie zdarzeń, ochrona antywirusowa, detekcja zachowań oraz zabezpieczanie procesów systemowych, może znacznie poprawić skuteczność w identyfikowaniu i blokowaniu działań typowych dla technik ataku opisanych w macierzy MITRE ATT&CK. Kluczowe jest tutaj podejście warstwowe, w którym różne strategie nie działają w izolacji, ale wzajemnie się uzupełniają. Taka kombinacja zabezpieczeń umożliwia skuteczne wykrywanie zagrożeń, nawet gdy jeden z mechanizmów zawiedzie lub zostanie pominięty przez atakującego.

Bibliografia

Źródła tradycyjne

1. Boonkrong S., Prompunjai K., Watcharawongbodee S., Chueachantuek S.: The Evolution of Cyberattack Motives. International Journal on Advanced Science, Engineering and Information Technology, 2022;
2. Chałubińska-Jentkiewicz K., Radoniewicz F., Zieliński T.: Cybersecurity in Poland: Legal Aspects. Springer International Publishing, Cham, 2022;
3. Georgiadou A., Mouzakitis S., Askounis D.: Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework. Sensors, 2021;
4. ISO/IEC 27001:2013: Information technology - Security techniques - Information security management systems - Requirements;
5. Rose S., Borchert O., Mitchell S., Connelly S.: Zero Trust Architecture. National Institute of Standards and Technology, 2020;
6. Roy S., Panaousis E., Noakes C., Laszka A., Panda S., Loukas G.: SoK: The MITRE ATT&CK Framework in Research and Practice, 2023;
7. ROZPORZĄDZENIE PARLAMENTU EUROPEJSKIEGO I RADY (UE) 2016/679 - z dnia 27 kwietnia 2016 r. - w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych);
8. Skoczylas D.: Cyberzagrożenia w cyberprzestrzeni. Cyberprzestępczość, cyberterroryzm i incydenty sieciowe. Prawo w Działaniu, 2023;
9. Strom B.E., Applebaum A., Miller D.P., Nickels K.C., Pennington A.G., Thomas C.B.: MITRE ATT&CK: Design and Philosophy;
10. Taherdoost H.: Understanding Cybersecurity Frameworks and Information Security Standards—A Review and Comprehensive Overview. Electronics, 2022;
11. THE APPLICATION of MITRE ATT&CK FRAMEWORK IN MITIGATING CYBERSECURITY THREATS IN THE PUBLIC SECTOR. Issues In Information Systems, 2024.

Źródła internetowe

12. Adlam S., 10 Most Common Types of Cyber Attacks & Examples 2025, Gridinsoft Blog (2025), <https://gridinsoft.com/blogs/cyber-attacks/> (dostęp z dnia 06.02.2025 r.)
13. Aidle L., Assessing 2024's Most Common Cyberattacks and Effective Defense Strategies, Telecom Curated, <https://telecommunicationscurated.com/security/assessing-2024s-most-common-cyberattacks-and-effective-defense-strategies/> (dostęp z dnia 06.02.2025 r.)
14. Ataki DDoS: czym są i jak się przed nimi chronić?, SEOSki, <https://seoski.pl/seo/ataki-ddos-czym-sa-i-jak-sie-przed-nimi-chronic/> (dostęp z dnia 22.03.2025 r.)
15. Baker K., 12 Most Common Types of Cyberattacks, [CrowdStrike.com](https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/common-cyberattacks/), <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/common-cyberattacks/> (dostęp z dnia 06.02.2025 r.)
16. Best practices for setting up a security operations centre (SOC) - ITSAP.00.500, Canadian Centre for Cyber Security, <https://www.cyber.gc.ca/en/guidance/best-practices-setting-security-operations-centre-soc-itsap00500> (dostęp z dnia 18.03.2025 r.)
17. CIS Controls, Center for Internet Security, <https://www.cisecurity.org/controls/> (dostęp z dnia 22.03.2025 r.)
18. A Complete Guide to CIS Critical Security Controls, ORDR, <https://ordr.net/article/complete-guide-to-cis-critical-security-controls/> (dostęp z dnia 22.03.2025 r.)
19. Cybersecurity compliance: What you need to know, Nordlayer, <https://nordlayer.com/learn/regulatory-compliance/cybersecurity-compliance/> (dostęp z dnia 11.02.2025 r.)
20. Cybersecurity Framework 1.1 Components, National Institute of Standards and Technology, <https://www.nist.gov/cyberframework/cybersecurity-framework-components> (dostęp z dnia 21.03.2025 r.)
21. Czym jest phishing? Zobacz przykłady i sposoby obrony, SEOSki, <https://seoski.pl/seo/czym-jest-phishing-definicja-przyklady/> (dostęp z dnia 22.03.2025 r.)
22. Fedorenko I., Will NIS 2 be as problematic as the NIS 1 directive?, Centria Bulletin, <https://centriabulletin.fi/will-nis-2-be-as-problematic-as-the-nis-1->

- [directive/](#) (dostęp z dnia 22.03.2025 r.)
23. Jones J., Why Defense in Depth is a Must for Modern Cybersecurity: Building Resilient Systems, Jaima Jones, <https://www.trainingtraining.training/blog/defense-in-depth-building-resilient-systems> (dostęp z dnia 17.03.2025 r.)
 24. Kirvan P., Kerner S.M., What is Extended Detection and Response (XDR)?, TechTarget, <https://www.techtarget.com/searchsecurity/definition/extended-detection-and-response-XDR> (dostęp z dnia 18.03.2025 r.)
 25. McMahon J., MITRE ATT&CK at Seven: The Seven Biggest Milestones, AttackIQ, <https://www.attackiq.com/2022/05/31/mitre-attck-at-seven-the-seven-biggest-milestones/> (dostęp z dnia 14.05.2025 r.)
 26. MITRE ATT&CK®, The MITRE Corporation (2024), <https://attack.mitre.org/> (dostęp z dnia 14.05.2025 r.)
 27. Mohan V., What are ISO 27001 Requirements? - Information Security Management*, Sprinto, <https://sprinto.com/blog/iso-27001-requirements/> (dostęp z dnia 18.04.2025 r.)
 28. NIS2 requirements, The NIS2 Directive, <https://nis2directive.eu/nis2-requirements/> (dostęp z dnia 18.04.2025 r.)
 29. Rothschild M., NIST Cybersecurity Framework Examples and Best Practices, Armis, <https://www.armis.com/blog/nist-cybersecurity-framework-examples-and-best-practices/> (dostęp z dnia 21.03.2025 r.)
 30. Sadoian L., GDPR Compliance: The Critical Role of Data Protection Officers, UpGuard, <https://www.upguard.com/blog/data-protection-officers/> (dostęp z dnia 18.04.2025 r.)
 31. Sectrio, Complete Guide to NIST CSF 2.0, Security Boulevard, <https://securityboulevard.com/2024/06/complete-guide-to-nist-csf-2-0/> (dostęp z dnia 21.03.2025 r.)
 32. Shah M., Challenges Faced by SOCs and How to Overcome Them, Techrab, <https://techrab.com/challenges-for-socs/> (dostęp z dnia 18.03.2025 r.)
 33. 15 Regulatory and Security Compliance Frameworks to Secure Your Business, Secureframe, <https://secureframe.com/hub/grc/compliance-frameworks> (dostęp z dnia 11.02.2025 r.)
 34. Spanning Cloud Apps, Defense in Depth: Definition, Layers, Benefits & More, Spanning, <https://www.spanning.com/blog/defense-in-depth/> (dostęp z dnia

17.03.2025 r.)

35. Standards Catalogue, Standards Australia, <https://www.standards.org.au/> (dostęp z dnia 15.05.2025 r.)
36. The role of a Data Protection Officer in GDPR compliance—a complete guide, Thoropass, <https://thoropass.com/blog/compliance/data-protection-officer/> (dostęp z dnia 18.04.2025 r.)
37. The Six Types of Cyberattacks You're Most Likely to Face, Cybersecurity Exchange, <https://www.eccouncil.org/cybersecurity-exchange/cyber-novice/six-most-common-types-cyberattacks/> (dostęp z dnia 06.02.2025 r.)
38. The top cyber threats facing financial services firms, Field Effect, <https://fieldeffect.com/blog/financial-services-cyber-threats/> (dostęp z dnia 06.02.2025 r.)
39. Top 15 Techniques — Sightings Ecosystem v2.0.0 documentation, Center for Threat-Informed Defense, https://center-for-threat-informed-defense.github.io/sightings_ecosystem/top-15-techniques/ (dostęp z dnia 17.05.2025 r.)
40. Types of Cyberthreats, IBM, <https://www.ibm.com/think/topics/cyberthreats-types> (dostęp z dnia 04.02.2025 r.)
41. Types of Malware & Malware Examples, Kaspersky, <https://www.kaspersky.com/resource-center/threats/types-of-malware> (dostęp z dnia 06.02.2025 r.)
42. What Are MITRE ATT&CK Use Cases?, Palo Alto Networks, <https://www.paloaltonetworks.in/cyberpedia/what-are-mitre-attack-use-cases> (dostęp z dnia 14.05.2025 r.)
43. What is Defence-in-Depth Security?, Sectona, <https://sectona.com/technology/what-is-defence-in-depth-security/> (dostęp z dnia 17.03.2025 r.)
44. What is Extended Detection and Response (XDR)?, Palo Alto Networks, <https://www.paloaltonetworks.com/cyberpedia/what-is-extended-detection-response-XDR> (dostęp z dnia 18.03.2025 r.)
45. What is NIS2?, The NIS2 Directive, <https://nis2directive.eu/what-is-nis2/> (dostęp z dnia 18.04.2025 r.)
46. What is the MITRE ATT&CK Framework?, IBM, <https://www.ibm.com/think/topics/mitre-attack> (dostęp z dnia 14.05.2025 r.)

47. What is Zero Trust Architecture?, Fortinet, <https://www.fortinet.com/resources/cyberglossary/zero-trust-architecture> (dostęp z dnia 11.02.2025 r.)
48. What Is a Security Operations Center and Why Is It Important?, CertiSEC, <https://certisec.org/what-is-a-security-operations-center-and-why-is-it-important/> (dostęp z dnia 18.03.2025 r.)
49. Why NIS2?, The NIS2 Directive, <https://nis2directive.eu/why-nis2/> (dostęp z dnia 18.04.2025 r.)
50. Welford B., Everything you need to know about the GDPR Data Protection Officer (DPO), GDPR , <https://gdpr.eu/data-protection-officer/> (dostęp z dnia 18.04.2025 r.)

Spis rysunków

Rysunek 4.1 Treść skryptu.....	67
Rysunek 5.1 Instalacja modułu Invoke-AtomicRedTeam	72
Rysunek 5.2 Instalacja Sysmon	73
Rysunek 5.3 Skrypt uruchamiający rejestrację zdarzenia 4104 dla PowerShella ...	73
Rysunek 5.4 Włączenie rejestrowania event 4668 dla PowerShella	74
Rysunek 5.6 Uruchomienie skryptu skanującego porty	75
Rysunek 5.7 Otwarte porty	76
Rysunek 5.8 Zdarzenie Sysmon Event ID 3	77
Rysunek 5.9 Wyłączenie usługi Lanman Server	78
Rysunek 5.10 Zamknięty port 445	79
Rysunek 5.11 Próba wykonania testu T1059.001	80
Rysunek 5.12 Zablokowane zagrożenia	81
Rysunek 5.13 Logi PowerShell/Operational	82
Rysunek 5.14 Zarejestrowany Event 1	83
Rysunek 5.15 Wyłączona "ochrona w czasie rzeczywistym"	84
Rysunek 5.16 Wykonanie się testu T1059.001	85
Rysunek 5.17 Zarejestrowany Event 11	86
Rysunek 5.18 Wykonanie testu T1055.001	87
Rysunek 5.19 Logi Sysmon.....	88
Rysunek 5.20 Logi PowerShell	89
Rysunek 5.21 Listing kodu	89
Rysunek 5.22 Harmonogram zadań - tworzenie zadania	90
Rysunek 5.23 Harmonogram zadań - wyzwalacz	91
Rysunek 5.24 Harmonogram zadań - edytowanie akcji	92
Rysunek 5.25 Harmonogram Zadań - Reakcja na Event ID 8 Sysmon	93
Rysunek 5.26 Próba wykonania skryptu ataku T1003.001 z włączoną "ochroną w czasie rzeczywistym"	94
Rysunek 5.27 Zablokowane zagrożenie	95
Rysunek 5.28 Wykonanie się testu T1003.001	96
Rysunek 5.29 Treść pliku „Invoke-AtomicTest-ExecutionLog”	97
Rysunek 5.30 Wpisy Sysmon	98

Rysunek 5.31 Wpisy systemowego dziennika zabezpieczeń	99
Rysunek 5.32 Zmiana wartości w Edytorze rejestru	100

Spis tabel

Tabela 1.1 Typy oprogramowania Malware	10
Tabela 1.2 Typy ataków phishingowych.....	13
Tabela 5.1 Wyeksportowany log Sysmon Event ID 3	77

Zastosowanie macierzy MITRE ATT&CK w modelowaniu i ocenie efektywności strategii obronnych wobec technik ataków cybernetycznych

Słowa kluczowe: cyberbezpieczeństwo, macierz MITRE ATT&CK, cyberataki, strategie obronne

Streszczenie

Praca dotyczy wykorzystania macierzy MITRE ATT&CK w modelowaniu i ocenie efektywności strategii obronnych w stosunku do zagrożeń cybernetycznych. W części teoretycznej zaprezentowano przegląd literatury dotyczącej aktualnych zagrożeń, taksonomii technik ataków oraz opisano główne frameworki, strategie obronne oraz standardy bezpieczeństwa. Szczególnie omówiono macierz MITRE ATT&CK, pokazując jej rolę jako uniwersalnego narzędzia do klasyfikacji technik ataku, analizy ich powiązań oraz doboru odpowiednich metod mitygacji.

W części praktycznej przeprowadzono cztery symulacje ataków zgodnie z technikami z macierzy MITRE ATT&CK: T1046 (Skanowanie portów), T1059.001 (Wykorzystanie skryptu PowerShell do pobrania i uruchomienia pliku wykonywalnego), T1055 (Wstrzykiwanie kodu do procesu) oraz T1003.001 (Dumping pamięci LSASS). Do przeprowadzenia tych symulacji utworzono środowisko testowe oparte na maszynie wirtualnej z systemem Windows 10 stworzonej w programie VirtualBox. Następnie do wykonania ataków wykorzystano narzędzie Atomic Red Team. Procesy wykrywania i reagowania były analizowane przy użyciu narzędzia Sysmon, Windows Defender, zapór sieciowych i PowerShell Logging. Każdy scenariusz został wykonany dwukrotnie - bez mechanizmów aktywnej ochrony oraz z włączonymi mechanizmami, zgodnie z zalecanymi strategiami mitygacji z bazy danych MITRE ATT&CK. Przeprowadzone badania potwierdziły, że macierz MITRE ATT&CK stanowi efektywne narzędzie wspierające projektowanie, testowanie i ocenę mechanizmów obronnych w systemach informatycznych.

Application of the MITRE ATT&CK Matrix in Modeling and Assessing the Effectiveness of Defense Strategies Against Cyber Attack Techniques

Keywords: cybersecurity, MITRE ATT&CK Matrix, cyberthreats, defense tactics

Summary

This thesis investigates how to model and evaluate the efficacy of defense tactics against cyberthreats using the MITRE ATT&CK Matrix. The theoretical section outlines important security frameworks, defense tactics, and security standards in addition to providing a literature review on contemporary threats and attack technique taxonomies. The MITRE ATT&CK Matrix is given special attention, emphasizing its function as a general-purpose instrument for categorizing attack methods, examining their connections, and choosing suitable mitigation strategies.

During the hands-on portion, four attack simulations were carried out using techniques from the MITRE ATT&CK Matrix: T1003.001 (LSASS Memory Dumping), T1059.001 (PowerShell: Download and Execute), T1055 (Process Injection), and T1046 (Network Service Scanning). For these simulations, a Windows 10 virtual machine built with VirtualBox was used to create a test environment. The Atomic Red Team tool was used to carry out the attacks. Tools like Sysmon, Windows Defender, firewalls, and PowerShell Logging were used to analyze detection and response procedures. Following the suggested mitigation techniques from the MITRE ATT&CK database, each scenario was run twice, once with and once without active protection mechanisms.

The results of the study demonstrated that the MITRE ATT&CK Matrix is a useful instrument for assisting in the development, testing, and assessment of information system defense mechanisms.